



ΔΙΕΘΝΕΣ
ΠΑΝΕΠΙΣΤΗΜΙΟ
ΕΛΛΑΔΟΣ

Δ Ι Ε Θ Ν Ε Σ Π Α Ν Ε Π Ι Σ Τ Η Μ Ι Ο Τ Η Σ Ε Λ Λ Α Δ Ο Σ
Π Ο Λ Υ Τ Ε Χ Ν Ι Κ Η Σ Χ Ο Λ Η
Τ Μ Η Μ Α Μ Η Χ Α Ν Ι Κ Ω Ν Π Λ Η Ρ Ο Φ Ο Ρ Ι Κ Η Σ ,
Υ Π Ο Λ Ο Γ Ι Σ Τ Ω Ν Κ Α Ι Τ Η Λ Ε Π Ι Κ Ο Ι Ν Ω Ν Ι Ω Ν

**Ανίχνευση και Αντιμετώπιση Επιθέσεων σε Δίκτυα
Οριζόμενα από Λογισμικό (SDN)**

Detection and Handling of Attacks in Software Defined Networks

Διπλωματική Εργασία της

Ζαφείρω Μπάρδα

(ΑΕΜ : 21015)

Επιβλέπων Καθηγητής:

Κωνσταντίνος Χειλάς, Καθηγητής

ΣΕΡΡΕΣ, Ιούλιος 2026

Περίληψη

Η ραγδαία υιοθέτηση των Δικτύων Οριζόμενων από Λογισμικό (Software-Defined Networking, SDN) στα σύγχρονα κέντρα δεδομένων και στις υποδομές παρόχων έχει μεταβάλει θεμελιωδώς τον τρόπο διαχείρισης των δικτύων, εισάγοντας ταυτόχρονα μια νέα και ιδιαίτερα κρίσιμη επιφάνεια επίθεσης. Ο διαχωρισμός του επιπέδου ελέγχου (control plane) από το επίπεδο δεδομένων (data plane) και η λογική κεντρικοποίηση της ευφυΐας του δικτύου στον ελεγκτή μετατρέπουν τον τελευταίο σε μοναδικό σημείο αποτυχίας (single point of failure) και σε προνομιακό στόχο επιθέσεων άρνησης εξυπηρέτησης.

Η παρούσα διπλωματική σχεδιάζει, υλοποιεί και αξιολογεί ένα ολοκληρωμένο σύστημα ανίχνευσης και αυτόματης αντιμετώπισης κυβερνοεπιθέσεων σε περιβάλλον SDN, βασισμένο σε τεχνικές Μηχανικής Μάθησης. Η προσέγγιση αναπτύσσεται σε δύο συμπληρωματικά επίπεδα. Το πρώτο (Μέθοδος Β) αφορά την offline ανάλυση ροών με επιβλεπόμενα και μη επιβλεπόμενα μοντέλα σε δεδομένα δομής InSDN/CICFlowMeter, όπου συγκρίνονται οκτώ αλγόριθμοι, έξι κλασικοί και δύο βαθιάς μάθησης. Το δεύτερο (Μέθοδος Α) αφορά τη ζωντανή ανίχνευση και αντιμετώπιση μέσα σε προσομοιωμένο δίκτυο Mininet/Open vSwitch, όπου ένας ελεγκτής υπολογίζει συγκεντρωτικά χαρακτηριστικά ανά πηγή, εντοπίζει τον επιτιθέμενο με αλγόριθμο Isolation Forest και επιβάλλει αυτόματα κανόνα απόρριψης (drop) στον μεταγωγέα.

Τα πειραματικά αποτελέσματα δείχνουν ότι το Random Forest επιτυγχάνει F1-score άνω του 0,999 στο συνθετικό σύνολο και 0,945 (μακρο-F1) στο InSDN, ενώ το ζωντανό σύστημα ανιχνεύει και μπλοκάρει έξι διαφορετικές κατηγορίες επιθέσεων (SYN flood/DDoS, port scanning, εξαγωγή δεδομένων, εξάντληση πίνακα ροών, πλευρική κίνηση, ARP spoofing) εντός του παραθύρου παρατήρησης. Στο σενάριο αποκλειστικά νόμιμης κίνησης δεν καταγράφηκαν ψευδώς θετικά, ενώ περιορισμένος αριθμός τους εμφανίστηκε σε σενάρια με νόμιμη αλλά στατιστικά ακραία κίνηση, όπως η εξαγωγή δεδομένων και η πλευρική κίνηση. Η διπλωματική εμβαθύνει περαιτέρω μέσω ανάλυσης ερμηνευσιμότητας (SHAP), ανάλυσης καθυστέρησης, αξιολόγησης της αποτελεσματικότητας αντιμετώπισης, μελέτης της SDN-specific επίθεσης κορεσμού του control plane και διερεύνησης της ανθεκτικότητας σε αντίπαλες (adversarial) επιθέσεις αποφυγής. Συνολικά τεκμηριώνεται ότι η συνδυασμένη, πολυεπίπεδη ML-based άμυνα

προσφέρει ταχύτερη, ακριβέστερη και πιο ευέλικτη προστασία έναντι των παραδοσιακών προσεγγίσεων βάσει υπογραφών.

Abstract

The rapid adoption of Software-Defined Networking (SDN) in modern data centres and provider infrastructures has fundamentally changed the way networks are managed, while simultaneously introducing a new and highly critical attack surface. The separation of the control plane from the data plane and the logical centralisation of network intelligence in the controller turn the latter into a single point of failure and a prime target for denial-of-service attacks.

This diploma thesis designs, implements and evaluates a complete system for the detection and automated mitigation of cyber-attacks in an SDN environment, based on Machine Learning techniques. The approach is developed on two complementary levels. The first (Method B) concerns the offline analysis of flows using supervised and unsupervised models on InSDN/CICFlowMeter-structured data, comparing eight algorithms, six classical and two deep-learning ones. The second (Method A) concerns live detection and mitigation inside a simulated Mininet/Open vSwitch network, where a controller computes aggregate per-source features, identifies the attacker with an Isolation Forest model and automatically installs a drop rule on the switch.

Experimental results show that Random Forest achieves an F1-score above 0.99 on the synthetic dataset and 0.95 on InSDN, while the live system detects and blocks six distinct attack categories (SYN flood/DDoS, port scanning, data exfiltration, flow-table exhaustion, lateral movement and ARP spoofing) within the observation window. No false positives were recorded in the legitimate-only scenario, while a limited number appeared in scenarios involving legitimate but statistically extreme traffic, such as data exfiltration and lateral movement. The work is further deepened through interpretability analysis (SHAP), detection-latency analysis, evaluation of mitigation effectiveness, a study of the SDN-specific control-plane saturation attack, and an investigation of robustness against adversarial evasion attacks. Overall, it is demonstrated that combined, multi-layer ML-based defence offers faster, more accurate and more flexible protection than traditional signature-based approaches.

Υπεύθυνη Δήλωση: Βεβαιώνω ότι είμαι συγγραφέας αυτής της διπλωματικής και ότι κάθε βοήθεια την οποία είχα για την προετοιμασία της, είναι πλήρως αναγνωρισμένη και αναφέρεται στην διπλωματική. Επίσης έχω αναφέρει τις όποιες πηγές από τις οποίες έκανα χρήση δεδομένων, ιδεών ή λέξεων, είτε αυτές αναφέρονται ακριβώς είτε παραφρασμένες. Επίσης, βεβαιώνω ότι αυτή η διπλωματική προετοιμάστηκε από εμένα προσωπικά ειδικά για τις απαιτήσεις του προγράμματος σπουδών του Τμήματος Μηχανικών Πληροφορικής, Υπολογιστών και Τηλεπικοινωνιών του Διεθνούς Πανεπιστημίου της Ελλάδας.

Z. Μπάρδα

Πίνακας Περιεχομένων

Περίληψη	2
Abstract.....	4
Πίνακας Περιεχομένων	6
Πίνακας Πινάκων	10
Πίνακας Σχημάτων	11
Πίνακας Συντομογραφιών	13
1. Εισαγωγή	14
1.1 Πλαίσιο και κίνητρο	14
1.2 Ορισμός του προβλήματος	15
1.3 Στόχοι της διπλωματικής	15
1.4 Συνεισφορά της διπλωματικής	15
1.5 Δομή της διπλωματικής	16
1.6 Ιστορικό πλαίσιο.....	16
1.7 Το μέγεθος του προβλήματος.....	17
1.8 Μεθοδολογική προσέγγιση	17
2. Αρχιτεκτονική των Δικτύων SDN.....	19
2.1 Τα τρία επίπεδα της αρχιτεκτονικής.....	19
2.1.1 Επίπεδο Δεδομένων (Data Plane).....	19
2.1.2 Επίπεδο Ελέγχου (Control Plane).....	19
2.1.3 Επίπεδο Εφαρμογών (Application Plane)	19
2.2 Διεπαφές επικοινωνίας και πρωτόκολλα νότιας διεπαφής.....	20
2.3 Το πρωτόκολλο OpenFlow: μηνύματα, διοχέτευση και στατιστικά	20
2.4 Ελεγκτές SDN: εσωτερική δομή, διαθεσιμότητα και ασφάλεια του καναλιού ελέγχου	23
2.5 Εργαλεία προσομοίωσης: Mininet και Open vSwitch	25

2.6 Σύγκριση με τα παραδοσιακά δίκτυα: πλεονεκτήματα και προκλήσεις	25
2.7 Σχέση με το NFV, τυποποίηση και οικοσύστημα	26
2.8 Περιπτώσεις χρήσης και υπηρεσίες του επιπέδου εφαρμογών	27
3. Απειλές και Επιθέσεις σε Δίκτυα SDN	29
3.1 Επιφάνεια επίθεσης ανά επίπεδο	29
3.2 Επιθέσεις άρνησης εξυπηρέτησης: μορφές, κύκλος ζωής και ταξινόμηση.....	29
3.3 Κορεσμός του πίνακα ροών και του καναλιού ελέγχου	31
3.4 Πλαστογράφηση, δηλητηρίαση τηλεμετρίας και επιθέσεις ενδιάμεσου.....	31
3.5 Σάρωση, πλευρική κίνηση και υποκλοπή.....	32
3.6 Ο ελεγκτής ως μοναδικό σημείο αποτυχίας και οι εσωτερικές απειλές.....	33
3.7 Ταξινόμηση των απειλών, υποδομή και αντίκτυπος των επιθέσεων	33
3.8 Μηχανισμοί άμυνας και ο ρόλος του IDS	35
4. Μέθοδοι Ανίχνευσης και Μηχανική Μάθηση.....	36
4.1 Παραδοσιακές μέθοδοι και οι αδυναμίες τους	36
4.2 Ανίχνευση βασισμένη σε Μηχανική Μάθηση: επισκόπηση και μηχανισμοί των αλγορίθμων.....	36
4.3 Ο αλγόριθμος Isolation Forest και η μαθηματική του θεμελίωση	38
4.4 Δημόσια σύνολα δεδομένων και κατηγορίες κίνησης.....	39
4.5 Χαρακτηριστικά ροής: εξαγωγή, περιγραφή και επιλογή	40
4.6 Μετρικές αξιολόγησης και καμπύλες ROC	42
4.7 Σχετική βιβλιογραφία και αρχιτεκτονικές συστημάτων ανίχνευσης.....	43
4.8 Προεπεξεργασία, ρύθμιση υπερπαραμέτρων και γενίκευση.....	44
4.9 Ζητήματα ιδιωτικότητας και δεοντολογίας	47
4.10 Εκδόσεις και εξέλιξη του OpenFlow.....	47
5. Μεθοδολογία και Υλοποίηση.....	49
5.1 Συνολική αρχιτεκτονική του συστήματος	49
5.2 Αρχιτεκτονική ελέγχου: υβριδικό μοντέλο SDN	49

5.2.1 Αιτιολόγηση της σχεδιαστικής επιλογής.....	50
5.3 Μέθοδος B: offline ανάλυση και παραγωγή του συνθετικού συνόλου.....	51
5.4 Μέθοδος A: Ζωντανό σύστημα και αντιμετώπιση.....	52
5.4.1 Αποφυγή ψευδώς θετικών	52
5.5 Ασφάλεια της υλοποίησης και προστασία του ελεγκτή	52
5.6 REST διεπαφή του ελεγκτή	53
5.7 Ο βρόχος τηλεμετρίας: μορφή μηνυμάτων και αλγόριθμος απόφασης	54
5.8 Περιβάλλον εκτέλεσης: Docker, δικτύωση και WSL2	55
5.9 Οπτικοποίηση σε πραγματικό χρόνο	56
5.10 Διαχείριση κατάστασης, ταυτοχρονισμού και σφαλμάτων	57
5.11 Σχηματική αναπαράσταση της αρχιτεκτονικής και του βρόχου ελέγχου	57
5.12 Στρατηγική ελέγχου και συνεχής ενσωμάτωση	59
5.13 Κύκλος ζωής πειράματος: μοντέλα και παραγωγή κίνησης.....	60
6. Πειράματα και Αποτελέσματα	62
6.1 Πειραματική διάταξη.....	62
6.2 Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης.....	62
6.3 Σημαντικότητα χαρακτηριστικών και ερμηνευσιμότητα (SHAP)	64
6.4 Καμπύλες ROC και διασταυρούμενη επικύρωση	67
6.5 Σύγκριση με μοντέλα Βαθιάς Μάθησης.....	69
6.6 Αξιολόγηση στο πραγματικό σύνολο InSDN.....	71
6.7 Αξιολόγηση και ρύθμιση του Isolation Forest	72
6.8 Ζωντανά σενάρια επίθεσης και αντιμετώπισης.....	75
6.8.1 DDoS / SYN Flood.....	76
6.8.2 Σάρωση θυρών (Port Scan)	76
6.8.3 Εξαγωγή δεδομένων (Data Exfiltration)	76
6.8.4 Εξάντληση πίνακα ροών.....	77
6.8.5 Πλευρική κίνηση (Lateral Movement).....	77

6.8.6 ARP Spoofing / MITM.....	77
6.9 Καθυστέρηση ανίχνευσης και αποτελεσματικότητα αντιμετώπισης	78
6.10 Επιθέσεις ειδικές του SDN: κορεσμός του control plane και δηλητηρίαση τηλεμετρίας.....	81
6.11 Ανθεκτικότητα σε αντίπαλες επιθέσεις	84
6.11.1 Το φαινόμενο του γκρεμού (cliff effect)	84
6.11.2 Ανθεκτικότητα του ζωντανού μοντέλου	85
6.11.3 Μετρίασμός της αντίπαλης ευπάθειας μέσω adversarial training	87
6.12 Πρόσθετα αποτελέσματα, οπτικοποιήσεις και υπολογιστικό κόστος	88
6.13 Σύγκριση με signature-based IDS και με τη βιβλιογραφία	92
6.14 Απειλές εγκυρότητας και στατιστική αξιοπιστία	94
6.15 Συζήτηση, ζητήματα κλιμάκωσης και πρακτικές συστάσεις	95
7. Συμπεράσματα και Μελλοντική Εργασία	97
7.1 Σύνοψη ευρημάτων	97
7.2 Περιορισμοί της διπλωματικής.....	98
7.3 Μελλοντικές επεκτάσεις.....	99
7.4 Τελικό συμπέρασμα.....	99
8. Βιβλιογραφία	100
Παράρτημα Α: Οδηγίες αναπαραγωγής των πειραμάτων	102
Α.1 Απαιτήσεις συστήματος.....	102
Α.2 Εκκίνηση της στοίβας.....	102
Α.3 Εκτέλεση του offline pipeline (Μέθοδος Β).....	102
Α.4 Εκτέλεση των ζωντανών σεναρίων (Μέθοδος Α)	102
Α.5 Θέση των αποτελεσμάτων	103
Παράρτημα Β: Πλήρης πίνακας υπερπαραμέτρων του Isolation Forest.....	104

Πίνακας Πινάκων

Πίνακας 1: Βασικοί τύποι μηνυμάτων <i>OpenFlow</i>	21
Πίνακας 2: Σύγκριση των κυριότερων ελεγκτών <i>SDN</i>	23
Πίνακας 3: Συγκριτική επισκόπηση παραδοσιακών δικτύων και <i>SDN</i>	26
Πίνακας 4: Ταξινόμηση των εξεταζόμενων επιθέσεων.	34
Πίνακας 5: Τα 24 χαρακτηριστικά ροής της δομής <i>CICFlowMeter/InSDN</i>	41
Πίνακας 6: Τα τέσσερα <i>containers</i> του ζωντανού συστήματος και ο ρόλος τους.	49
Πίνακας 7: Μηχανισμοί ασφαλείας του ελεγκτή.....	53
Πίνακας 8: Κυριότερα <i>REST endpoints</i> του ελεγκτή.	54
Πίνακας 9: Σύγκριση κλασικών μοντέλων στο συνθετικό σύνολο (24 χαρακτηριστικά).	62
Πίνακας 10: Τα πέντε σημαντικότερα χαρακτηριστικά κατά την ανάλυση <i>SHAP</i>	65
Πίνακας 11: Διασταυρούμενη επικύρωση 5-fold (<i>F1-score</i>).	68
Πίνακας 12: Απόδοση των μοντέλων Βαθιάς Μάθησης στο συνθετικό σύνολο.	69
Πίνακας 13: Σύγκριση μοντέλων στο πραγματικό σύνολο <i>InSDN</i>	71
Πίνακας 14: Μετρικές του <i>Isolation Forest</i>	72
Πίνακας 15: Σύνοψη των ζωντανών σεναρίων επίθεσης (μετρήσεις <i>live</i>).	75
Πίνακας 16: Αναλυτικά δεδομένα ανά ζωντανό σενάριο.	78
Πίνακας 17: Ρυθμός ανίχνευσης και καθυστέρηση ανά ένταση επίθεσης (30 δοκιμές).....	79
Πίνακας 18: Μετρικές αποτελεσματικότητας αντιμετώπισης (50 δοκιμές).....	79
Πίνακας 19: Μετρήσεις κατά τη διάρκεια της επίθεσης κορεσμού <i>control plane</i>	81
Πίνακας 20: Επίθεση μίμησης εναντίον του <i>Random Forest</i> : ρυθμός αποφυγής vs διαταραχή ε.	85
Πίνακας 21: Ανθεκτικότητα του ζωντανού μοντέλου έναντι φυσικών στρατηγικών αποφυγής.....	86
Πίνακας 22: Ρυθμός αποφυγής (<i>mimicry</i>) <i>Original</i> vs <i>Robust Random Forest</i> ανά διαταραχή ε.	87
Πίνακας 23: Ποιοτική σύγκριση του <i>ML</i> συστήματος με παραδοσιακά <i>signature-based IDS</i>	92
Πίνακας 24: Ποιοτική σύγκριση της διπλωματικής με αντιπροσωπευτικές εργασίες του πεδίου.....	94
Πίνακας 25: Κορυφαίοι συνδυασμοί υπερπαραμέτρων του <i>Isolation Forest</i>	104

Πίνακας Σχημάτων

Σχήμα 1: Σχηματική αναπαράσταση της αρχιτεκτονικής του συστήματος.	58
Σχήμα 2: Τοπολογία του προσομοιωμένου δικτύου με έξι hosts.	58
Σχήμα 3: Ο κλειστός βρόχος εποπτείας-απόφασης-δράσης.....	59
Σχήμα 4: Η ροή ανίχνευσης και αντιμετώπισης βήμα προς βήμα.....	59
Σχήμα 5: Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης ως προς τις τέσσερις βασικές μετρικές.	63
Σχήμα 6: Πίνακας σύγκρισης του βέλτιστου κλασικού μοντέλου (Random Forest).....	63
Σχήμα 7: Σημαντικότητα των σημαντικότερων χαρακτηριστικών κατά το Random Forest. 64	
Σχήμα 8: Διάγραμμα SHAP (beeswarm), κατεύθυνση και μέγεθος επίδρασης ανά χαρακτηριστικό.	66
Σχήμα 9: Global σημαντικότητα χαρακτηριστικών κατά SHAP (μέση απόλυτη τιμή).	67
Σχήμα 10: Θερμικός χάρτης SHAP: ποια χαρακτηριστικά ανιχνεύουν ποια κατηγορία επίθεσης.	67
Σχήμα 11: Καμπύλες ROC ανά κατηγορία επίθεσης (one-vs-rest).....	68
Σχήμα 12: Διασταυρούμενη επικύρωση 5-fold: F1-score (μέσος $\pm$ τυπική απόκλιση).	69
Σχήμα 13: Συνολική σύγκριση και των οκτώ μοντέλων (κλασικά και βαθιάς μάθησης).	70
Σχήμα 14: Πίνακας σύγκρισης του μοντέλου Deep MLP.	70
Σχήμα 15: Ιστορικό εκπαίδευσης των μοντέλων Βαθιάς Μάθησης (loss/accuracy ανά εποχή).....	71
Σχήμα 16: Σύγκριση μοντέλων στο πραγματικό σύνολο δεδομένων InSDN.....	72
Σχήμα 17: Ρύθμιση υπερπαραμέτρων του Isolation Forest (ROC-AUC και F1 ανά συνδυασμό).	73
Σχήμα 18: Πίνακας σύγκρισης του Isolation Forest.....	73
Σχήμα 19: Καμπύλη ROC του Isolation Forest.	74
Σχήμα 20: Κατανομή anomaly scores του Isolation Forest για νόμιμη και κακόβουλη κίνηση.	74
Σχήμα 21: Καθυστέρηση ανίχνευσης και ρυθμός ανίχνευσης συναρτήσει της έντασης της επίθεσης.	79
Σχήμα 22: Κατανομές (violin plots) των μετρικών αποτελεσματικότητας αντιμετώπισης..	80
Σχήμα 23: Χρονολόγιο τυπικού σεναρίου αντιμετώπισης (ανίχνευση, αποκλεισμός, επανα-ανίχνευση).	80

Σχήμα 24: <i>Επισκόπηση της επίθεσης κορεσμού control plane (ρυθμός Packet-In, ουρά, RTT, πίνακας ροών).</i>	82
Σχήμα 25: <i>Ανίχνευση της επίθεσης κορεσμού μέσω εντροπίας Shannon.</i>	83
Σχήμα 26: <i>Χρονολόγιο της επίθεσης δηλητηρίασης τηλεμετρίας και της αντιμετώπισής της.</i>	83
Σχήμα 27: <i>Σύνοψη της αποτελεσματικότητας της άμυνας έναντι της δηλητηρίασης τηλεμετρίας.</i>	84
Σχήμα 28: <i>Ρυθμός αποφυγής συναρτήσει της διαταραχής ϵ (mimicry εναντίον Random Forest) και το trade-off ισχύος επίθεσης.</i>	85
Σχήμα 29: <i>Ευαισθησία ανά χαρακτηριστικό (στοχευμένη μίμηση).</i>	85
Σχήμα 30: <i>Φυσικές στρατηγικές αποφυγής εναντίον του ζωντανού μοντέλου.</i>	86
Σχήμα 31: <i>Εναλλακτικός πίνακας σύγχυσης του Isolation Forest.</i>	89
Σχήμα 32: <i>Κατανομή anomaly scores του Isolation Forest.</i>	89
Σχήμα 33: <i>Πίνακας σύγχυσης του Random Forest (thesis έκδοση).</i>	90
Σχήμα 34: <i>Σημαντικότητα χαρακτηριστικών (thesis έκδοση).</i>	90
Σχήμα 35: <i>Συγκριτική απόδοση μοντέλων (thesis έκδοση).</i>	91
Σχήμα 36: <i>Χρονολόγιο offline replay: ανίχνευση επίθεσης σε επανάληψη καταγεγραμμένης κίνησης.</i>	91
Σχήμα 37: <i>Καθυστέρηση αντιμετώπισης της επίθεσης δηλητηρίασης τηλεμετρίας.</i>	91

Πίνακας Συντομογραφιών

Συντομογραφία	Επεξήγηση
SDN	Software-Defined Networking, Δίκτυα Οριζόμενα από Λογισμικό
NFV	Network Functions Virtualization
IDS	Intrusion Detection System, Σύστημα Ανίχνευσης Εισβολών
ML	Machine Learning, Μηχανική Μάθηση
DL	Deep Learning, Βαθιά Μάθηση
DoS / DDoS	(Distributed) Denial of Service
OVS	Open vSwitch
TCAM	Ternary Content-Addressable Memory
IAT	Inter-Arrival Time, Χρόνος μεταξύ αφίξεων
RF	Random Forest
IF	Isolation Forest
SVM	Support Vector Machine
KNN	K-Nearest Neighbors
MLP	Multi-Layer Perceptron
CNN	Convolutional Neural Network
SHAP	SHapley Additive exPlanations
ROC / AUC	Receiver Operating Characteristic / Area Under Curve
MITM	Man-in-the-Middle
ARP	Address Resolution Protocol
API	Application Programming Interface
REST	Representational State Transfer
CI	Continuous Integration, Συνεχής Ενσωμάτωση
FP / TP	False Positive / True Positive
TTD	Time-to-Detect, Χρόνος έως την ανίχνευση

1. Εισαγωγή

1.1 Πλαίσιο και κίνητρο

Η ραγδαία αύξηση των απαιτήσεων των σύγχρονων δικτυακών εφαρμογών, από το υπολογιστικό νέφος (cloud computing) και το Διαδίκτυο των Πραγμάτων (Internet of Things, IoT) μέχρι τη ροή δεδομένων υψηλής ευκρίνειας και τις εφαρμογές πραγματικού χρόνου, έχει αναδείξει με έντονο τρόπο τους διαρθρωτικούς περιορισμούς της παραδοσιακής δικτυακής αρχιτεκτονικής. Στα συμβατικά δίκτυα, η λογική ελέγχου (control logic) και η προώθηση των δεδομένων (data forwarding) είναι στενά συνυφασμένες μέσα σε κάθε δικτυακή συσκευή. Κάθε δρομολογητής ή μεταγωγέας λαμβάνει τοπικές, αυτόνομες αποφάσεις, με αποτέλεσμα η διαχείριση του δικτύου να καθίσταται δύσκαμπτη, η κλιμάκωση δαπανηρή και η εισαγωγή νέων λειτουργιών ιδιαίτερα αργή, καθώς εξαρτάται από κλειστό, ιδιόκτητο υλικολογισμικό των κατασκευαστών.

Τα Δίκτυα Οριζόμενα από Λογισμικό (Software-Defined Networking, SDN) προτείνουν μια ριζική αναδιάρθρωση αυτού του μοντέλου: τον σαφή διαχωρισμό του επιπέδου ελέγχου από το επίπεδο δεδομένων. Η λογική του δικτύου αφαιρείται από τις μεμονωμένες συσκευές και συγκεντρώνεται σε έναν λογικά κεντρικό ελεγκτή (controller), ο οποίος διαθέτει σφαιρική εικόνα της τοπολογίας και προγραμματίζει τη συμπεριφορά των μεταγωγέων μέσω ανοιχτών, τυποποιημένων πρωτοκόλλων, κατεξοχήν του OpenFlow. Το αποτέλεσμα είναι ένα δίκτυο που καθίσταται προγραμματιζόμενο, ευέλικτο και δυναμικά αναδιατάξιμο μέσω λογισμικού, με προφανή οφέλη για την αυτοματοποίηση, τη διαχείριση πολιτικών και την ταχύτητα καινοτομίας.

Η ίδια, ωστόσο, αρχιτεκτονική επιλογή που προσδίδει την ευελιξία, δημιουργεί και μια νέα, κρίσιμη επιφάνεια επίθεσης. Η λογική κεντριοποίηση του ελέγχου μετατρέπει τον ελεγκτή σε μοναδικό σημείο αποτυχίας (single point of failure): αν αυτός τεθεί εκτός λειτουργίας ή κορεστεί, ολόκληρο το δίκτυο κινδυνεύει να παραλύσει. Επιπλέον, το κανάλι ελέγχου (control channel) μεταξύ ελεγκτή και μεταγωγέων, καθώς και ο μηχανισμός με τον οποίο τα «άγνωστα» πακέτα προωθούνται στον ελεγκτή για απόφαση, ανοίγουν νέους δρόμους για επιθέσεις άρνησης εξυπηρέτησης που δεν υφίστανται καν στα παραδοσιακά δίκτυα. Η προστασία του ελεγκτή SDN αναδεικνύεται, επομένως, σε ζήτημα υψίστης σημασίας για την αξιοπιστία ολόκληρης της υποδομής.

1.2 Ορισμός του προβλήματος

Το πρόβλημα που πραγματεύεται η παρούσα διπλωματική είναι η έγκαιρη και ακριβής ανίχνευση κακόβουλης δικτυακής κίνησης σε περιβάλλον SDN, καθώς και η αυτόματη αντιμετώπισή της πριν προκληθεί ουσιαστική ζημιά στην υποδομή. Οι παραδοσιακές μέθοδοι άμυνας, όπως τα συστήματα ανίχνευσης εισβολών βάσει υπογραφών (signature-based IDS), παρουσιάζουν δύο βασικές αδυναμίες: αφενός αδυνατούν να ανιχνεύσουν άγνωστες (zero-day) επιθέσεις για τις οποίες δεν υπάρχει προκαθορισμένη υπογραφή, και αφετέρου εισάγουν καθυστέρηση, καθώς απαιτούν επιθεώρηση κάθε πακέτου. Σε ένα περιβάλλον όπου ο ελεγκτής μπορεί να κορεστεί μέσα σε δευτερόλεπτα, η καθυστέρηση αυτή είναι κρίσιμη.

Η Μηχανική Μάθηση προσφέρει μια εναλλακτική προσέγγιση: αντί για στατικές υπογραφές, τα μοντέλα μαθαίνουν τα στατιστικά χαρακτηριστικά της νόμιμης και της κακόβουλης κίνησης και γενικεύουν σε νέες, άγνωστες παραλλαγές επιθέσεων. Το ερώτημα που τίθεται είναι κατά πόσον μια τέτοια προσέγγιση μπορεί να ενσωματωθεί αποτελεσματικά στην αρχιτεκτονική SDN, αξιοποιώντας τα ίδια τα στατιστικά ροών που ο μεταγωγέας ήδη συλλέγει, ώστε να επιτυγχάνεται ανίχνευση σε πραγματικό χρόνο και αυτόματη αντιμετώπιση μέσω δυναμικής εγκατάστασης κανόνων ροής.

1.3 Στόχοι της διπλωματικής

Οι στόχοι της παρούσας διπλωματικής περιλαμβάνουν τη μελέτη της αρχιτεκτονικής SDN και του πρωτοκόλλου OpenFlow, με έμφαση στις επιπτώσεις τους στην ασφάλεια του δικτύου, τη συστηματική ανάλυση των βασικών κατηγοριών επιθέσεων ανά επίπεδο της αρχιτεκτονικής, καθώς και τον σχεδιασμό και την υλοποίηση συστήματος ανίχνευσης βασισμένου σε τεχνικές Μηχανικής Μάθησης. Επιπλέον, η διπλωματική στοχεύει στην ενσωμάτωση του μηχανισμού ανίχνευσης σε ζωντανό περιβάλλον προσομοίωσης Mininet/Open vSwitch, στην αυτόματη αντιμετώπιση επιθέσεων μέσω κανόνων απόρριψης και στην πειραματική αξιολόγηση της απόδοσης ως προς τις μετρικές ταξινόμησης, την καθυστέρηση ανίχνευσης, την αποτελεσματικότητα αντιμετώπισης και την εμφάνιση ψευδώς θετικών. Τέλος, εξετάζονται ζητήματα ερμηνευσιμότητας, κορεσμού του control plane και ανθεκτικότητας έναντι αντίπαλων στρατηγικών αποφυγής.

1.4 Συνεισφορά της διπλωματικής

Η συνεισφορά της παρούσας διπλωματικής εντοπίζεται σε τρία επίπεδα. Πρώτον, πραγματοποιείται συγκριτική αξιολόγηση οκτώ μοντέλων Μηχανικής Μάθησης σε

δεδομένα δομής SDN/InSDN, με στόχο την ανάδειξη του καταλληλότερου αλγορίθμου για ταξινόμηση ροών. Δεύτερον, υλοποιείται ζωντανό σύστημα ανίχνευσης και αντιμετώπισης σε προσομοιωμένο περιβάλλον Mininet/Open vSwitch, το οποίο συνδέει την απόφαση του μοντέλου με την αυτόματη εγκατάσταση κανόνων απόρριψης. Τρίτον, η αξιολόγηση επεκτείνεται πέρα από τις κλασικές μετρικές ταξινόμησης, εξετάζοντας την καθυστέρηση ανίχνευσης, την αποτελεσματικότητα της αντιμετώπισης, την ερμηνευσιμότητα μέσω SHAP και την ανθεκτικότητα έναντι αντίπαλων στρατηγικών αποφυγής, όπου αναδεικνύεται και το φαινόμενο του γκρεμού (cliff effect) στα δέντρα απόφασης.

1.5 Δομή της διπλωματικής

Το υπόλοιπο της διπλωματικής οργανώνεται ως εξής. Το Κεφάλαιο 2 παρουσιάζει το θεωρητικό υπόβαθρο των δικτύων SDN και του πρωτοκόλλου OpenFlow. Το Κεφάλαιο 3 αναλύει τις απειλές και τις κατηγορίες επιθέσεων σε περιβάλλον SDN. Το Κεφάλαιο 4 επισκοπεί τις μεθόδους ανίχνευσης εισβολών και τα θεμέλια της Μηχανικής Μάθησης που αξιοποιούνται. Το Κεφάλαιο 5 περιγράφει αναλυτικά τη μεθοδολογία και την υλοποίηση, τόσο του offline pipeline όσο και του ζωντανού συστήματος. Το Κεφάλαιο 6 παρουσιάζει και σχολιάζει τα πειραματικά αποτελέσματα. Τέλος, το Κεφάλαιο 7 συνοψίζει τα συμπεράσματα, τους περιορισμούς και τις κατευθύνσεις μελλοντικής εργασίας.

1.6 Ιστορικό πλαίσιο

Η ιδέα του διαχωρισμού ελέγχου και προώθησης δεν είναι εντελώς νέα, προϋπήρξε σε ερευνητικές προσπάθειες όπως τα active networks και τα προγραμματιζόμενα δίκτυα της δεκαετίας του 1990. Ωστόσο, η πρακτική καθιέρωση των SDN συνδέεται με την εισαγωγή του OpenFlow το 2008 από την ερευνητική ομάδα του Stanford, το οποίο για πρώτη φορά προσέφερε μια τυποποιημένη, ανοιχτή διεπαφή για τον προγραμματισμό εμπορικών μεταγωγέων. Η επακόλουθη υιοθέτηση από μεγάλους παρόχους νεφοϋπολογιστικής (cloud computing) και η ίδρυση οργανισμών τυποποίησης εδραίωσαν τα SDN ως κυρίαρχο παράδειγμα για τα σύγχρονα κέντρα δεδομένων.

Παράλληλα με τη λειτουργική ωρίμανση, αναδείχθηκε και η ανάγκη για εξειδικευμένη έρευνα ασφάλειας. Η πρωτοποριακή εργασία των Braga κ.ά. [1] έδειξε ότι τα ίδια τα στατιστικά ροών του OpenFlow μπορούν να τροφοδοτήσουν ελαφρείς ανιχνευτές DDoS, θέτοντας τα θεμέλια της προσέγγισης που ακολουθεί και η παρούσα διπλωματική. Έκτοτε, η βιβλιογραφία έχει εμπλουτιστεί με πλήθος μεθόδων Μηχανικής Μάθησης, τις οποίες αναλύουμε στο Κεφάλαιο 4.

1.7 Το μέγεθος του προβλήματος

Η σημασία της προστασίας των δικτύων από επιθέσεις άρνησης εξυπηρέτησης δεν είναι θεωρητική. Οι επιθέσεις DDoS έχουν αυξηθεί σημαντικά σε συχνότητα, όγκο και πολυπλοκότητα κατά την τελευταία δεκαετία, με σύγχρονες επιθέσεις να ξεπερνούν τα εκατοντάδες gigabits ανά δευτερόλεπτο. Η διάδοση ανασφαλών συσκευών του Διαδικτύου των Πραγμάτων (IoT) έχει προσφέρει στους επιτιθέμενους τεράστια δίκτυα παραβιασμένων συσκευών, ικανά να εξαπολύσουν επιθέσεις πρωτοφανούς κλίμακας. Παράλληλα, η μετάβαση κρίσιμων υπηρεσιών στο νέφος (cloud) έχει αυξήσει το κόστος της διακοπής λειτουργίας, καθιστώντας την ασφάλεια του δικτύου ζήτημα άμεσης επιχειρησιακής προτεραιότητας.

Σε αυτό το πλαίσιο, η κεντροποίηση των SDN λειτουργεί ως δόικο μαχαίρι. Από τη μία, προσφέρει κατάλληλη θέση για την εγκατάσταση κεντρικού μηχανισμού άμυνας με καθολική εποπτεία του δικτύου. Από την άλλη, συγκεντρώνει το ρίσκο, καθιστώντας τον ελεγκτή ελκυστικό στόχο. Η παρούσα διπλωματική τοποθετείται σε αυτό το σημείο τομής, αξιοποιώντας το πλεονέκτημα της κεντρικής εποπτείας για την προστασία του ίδιου του σημείου που τη συγκεντρώνει.

1.8 Μεθοδολογική προσέγγιση

Η μεθοδολογία που ακολουθήθηκε συνδυάζει τη θεωρητική μελέτη με την πειραματική επαλήθευση, σε μια επαναληπτική διαδικασία. Αρχικά μελετήθηκε το θεωρητικό υπόβαθρο των SDN και των απειλών τους, ώστε να προσδιοριστούν οι απαιτήσεις του συστήματος. Στη συνέχεια σχεδιάστηκε και υλοποιήθηκε το offline pipeline, το οποίο επέτρεψε την επιλογή των καταλληλότερων αλγορίθμων. Ακολούθησε η ανάπτυξη του ζωντανού συστήματος, με διαρκή αξιολόγηση και βελτίωση μέσω των πειραματικών σεναρίων. Τέλος, πραγματοποιήθηκαν οι εμβασύνσεις σε ζητήματα ερμηνευσιμότητας και ασφάλειας. Η προσέγγιση αυτή, με τη σταδιακή οικοδόμηση από τη θεωρία στην πράξη και την πειραματική επικύρωση κάθε σταδίου, διασφάλισε ότι οι σχεδιαστικές αποφάσεις τεκμηριώνονται από δεδομένα και όχι από υποθέσεις.

Καθ' όλη τη διάρκεια δόθηκε έμφαση στην αναπαραγωγιμότητα και στην τεκμηρίωση. Κάθε πείραμα σχεδιάστηκε ώστε να είναι επαναλήψιμο, κάθε αποτέλεσμα καταγράφηκε σε μορφή που επιτρέπει την ανεξάρτητη επαλήθευση, και κάθε σχεδιαστική επιλογή αιτιολογήθηκε ρητά. Η προσέγγιση αυτή αντικατοπτρίζει την πεποίθηση ότι η

επιστημονική αξία μιας εργασίας έγκειται εξίσου στα αποτελέσματα και στη δυνατότητα ελέγχου τους.

2. Αρχιτεκτονική των Δικτύων SDN

Η θεμελιώδης ιδέα των Δικτύων Οριζόμενων από Λογισμικό είναι ο διαχωρισμός των αρμοδιοτήτων που στα παραδοσιακά δίκτυα συνυπάρχουν στην ίδια συσκευή. Αντί κάθε δρομολογητή να ενσωματώνει τόσο τη λογική απόφασης όσο και τον μηχανισμό προώθησης, τα SDN αποσυνδέουν αυτά τα δύο και εισάγουν μια σαφή, ιεραρχική οργάνωση σε τρία λογικά επίπεδα, τα οποία επικοινωνούν μέσω καλά ορισμένων διεπαφών προγραμματισμού.

2.1 Τα τρία επίπεδα της αρχιτεκτονικής

2.1.1 Επίπεδο Δεδομένων (Data Plane)

Το επίπεδο δεδομένων αποτελείται από τους δικτυακούς μεταγωγείς (switches), οι οποίοι στα SDN είναι απλές, «ανόητες» συσκευές προώθησης, χωρίς ενσωματωμένη λογική ελέγχου. Κάθε μεταγωγέας διατηρεί έναν ή περισσότερους πίνακες ροών (flow tables), οι οποίοι περιέχουν κανόνες που υπαγορεύουν πώς θα χειριστεί τα εισερχόμενα πακέτα. Όταν ένα πακέτο ταιριάζει σε έναν κανόνα, εκτελείται η αντίστοιχη ενέργεια (προώθηση σε θύρα, απόρριψη, τροποποίηση κεφαλίδων). Όταν όμως δεν ταιριάζει σε κανέναν υπάρχοντα κανόνα, γεγονός που ονομάζεται table-miss, το πακέτο (ή μια περίληψή του) προωθείται στον ελεγκτή μέσω μηνύματος Packet-In, ώστε ο τελευταίος να αποφασίσει.

2.1.2 Επίπεδο Ελέγχου (Control Plane)

Το επίπεδο ελέγχου περιέχει τον ελεγκτή, ο οποίος αποτελεί τον λογικό «εγκέφαλο» του δικτύου. Ο ελεγκτής διατηρεί μια σφαιρική εικόνα της τοπολογίας (global network view), λαμβάνει αποφάσεις δρομολόγησης και προγραμματίζει τους πίνακες ροών των μεταγωγέων μέσω μηνυμάτων Flow-Mod. Η λογική συγκέντρωση της ευφυΐας απλοποιεί σημαντικά τη διαχείριση: μια πολιτική ασφαλείας ή δρομολόγησης ορίζεται μία φορά, κεντρικά, και εφαρμόζεται συνεπώς σε ολόκληρο το δίκτυο. Ταυτόχρονα, όμως, η ίδια συγκέντρωση δημιουργεί ένα κρίσιμο σημείο ευπάθειας, στο οποίο εστιάζει και η παρούσα διπλωματική.

2.1.3 Επίπεδο Εφαρμογών (Application Plane)

Στο ανώτερο επίπεδο βρίσκονται οι δικτυακές εφαρμογές, μηχανισμοί εξισορρόπησης φορτίου, τείχη προστασίας, συστήματα ανίχνευσης εισβολών, εφαρμογές traffic engineering, που υλοποιούν την επιχειρησιακή πολιτική του οργανισμού. Οι εφαρμογές

αυτές δεν επικοινωνούν απευθείας με το υλικό. Αντ' αυτού αλληλεπιδρούν με τον ελεγκτή μέσω της βόρειας διεπαφής (northbound API), συνήθως μιας RESTful διεπαφής. Το σύστημα ανίχνευσης που αναπτύσσεται στην παρούσα διπλωματική εντάσσεται εννοιολογικά ακριβώς σε αυτό το επίπεδο: αποτελεί μια εφαρμογή ασφαλείας που εποπτεύει το δίκτυο και επιβάλλει πολιτικές μέσω του ελεγκτή.

2.2 Διεπαφές επικοινωνίας και πρωτόκολλα νότιας διεπαφής

Η νότια διεπαφή (southbound API) συνδέει τον ελεγκτή με τους μεταγωγείς. Το επικρατέστερο πρωτόκολλο είναι το OpenFlow, ενώ υποστηρίζονται και άλλα, όπως τα NETCONF και OVSDB για τη διαμόρφωση των συσκευών. Η βόρεια διεπαφή (northbound API), αντίθετα, εκθέτει τις λειτουργίες του ελεγκτή προς τις εφαρμογές του ανώτερου επιπέδου. Ενώ η νότια διεπαφή είναι σε μεγάλο βαθμό τυποποιημένη, η βόρεια παραμένει λιγότερο πρότυπη και συχνά εξαρτάται από τον εκάστοτε ελεγκτή.

Άλλα πρωτόκολλα νότιας διεπαφής

Παρότι το OpenFlow είναι το επικρατέστερο πρωτόκολλο νότιας διεπαφής, το οικοσύστημα SDN περιλαμβάνει και άλλα. Το NETCONF, σε συνδυασμό με το μοντέλο δεδομένων YANG, χρησιμοποιείται για τη διαμόρφωση συσκευών. Το OVSDB είναι το πρωτόκολλο διαχείρισης του Open vSwitch, το οποίο λειτουργεί συμπληρωματικά προς το OpenFlow: το πρώτο διαμορφώνει τη δομή του μεταγωγέα (γέφυρες, θύρες), ενώ το δεύτερο προγραμματίζει τη συμπεριφορά προώθησης. Πιο πρόσφατα, η γλώσσα P4 επιτρέπει τον προγραμματισμό της ίδιας της διοχέτευσης επεξεργασίας του μεταγωγέα, προσφέροντας ακόμη μεγαλύτερη ευελιξία. Η επίγνωση αυτού του ευρύτερου τοπίου βοηθά στην τοποθέτηση της υλοποίησης της διπλωματικής, η οποία αξιοποιεί τη σημασιολογία OpenFlow μέσω του Open vSwitch.

2.3 Το πρωτόκολλο OpenFlow: μηνύματα, διοχέτευση και στατιστικά

Το OpenFlow, που εισήχθη από τους McKeown κ.ά. [2], είναι το πρότυπο πρωτόκολλο επικοινωνίας ελεγκτή-μεταγωγέα και αποτελεί τον ακρογωνιαίο λίθο των SDN. Ορίζει τη δομή των πινάκων ροών, όπου κάθε καταχώρηση αποτελείται από τρία βασικά μέρη: τα πεδία ταιριάσματος (match fields, π.χ. διευθύνσεις MAC/IP, θύρες, πρωτόκολλο), τους μετρητές (counters, που καταγράφουν πλήθος πακέτων και bytes ανά ροή) και τις ενέργειες (actions). Η αρχή λειτουργίας match-action είναι απλή αλλά ιδιαίτερα

εκφραστική: για κάθε εισερχόμενο πακέτο, ο μεταγωγέας βρίσκει την καταχώρηση με την υψηλότερη προτεραιότητα που ταιριάζει και εκτελεί την αντίστοιχη ενέργεια.

Ιδιαίτερη σημασία για την παρούσα διπλωματική έχουν οι μετρητές ανά ροή. Καθώς ο μεταγωγέας καταγράφει αυτόματα το πλήθος πακέτων, το πλήθος bytes και τη διάρκεια κάθε ροής, τα στατιστικά αυτά (OpenFlow Flow-Stats / Port-Stats) μπορούν να ανακτηθούν περιοδικά από τον ελεγκτή και να τροφοδοτήσουν απευθείας το μοντέλο Μηχανικής Μάθησης, χωρίς ανάγκη για βαθιά επιθεώρηση πακέτων (deep packet inspection). Αυτό καθιστά την ανίχνευση βάσει ροών εγγενώς αποδοτική και κλιμακώσιμη.

Τύποι μηνυμάτων OpenFlow

Το πρωτόκολλο OpenFlow ορίζει μια σειρά μηνυμάτων για την επικοινωνία ελεγκτή-μεταγωγέα. Τα σημαντικότερα για την κατανόηση των επιθέσεων και της άμυνας της διπλωματικής συνοψίζονται στον ακόλουθο πίνακα.

Μήνυμα	Κατεύθυνση	Σκοπός
Packet-In	Switch → Controller	Πρόωθηση πακέτου που δεν ταίριαζε σε κανόνα (table-miss).
Packet-Out	Controller → Switch	Εντολή αποστολής πακέτου από τον ελεγκτή.
Flow-Mod	Controller → Switch	Εγκατάσταση, τροποποίηση ή διαγραφή κανόνα ροής.
Flow-Stats Request/Reply	Αμφίδρομο	Αίτηση και επιστροφή στατιστικών ανά ροή.
Port-Stats Request/Reply	Αμφίδρομο	Αίτηση και επιστροφή στατιστικών ανά θύρα (χρησιμοποιείται στην τηλεμετρία της διπλωματικής).

Πίνακας 1: Βασικοί τύποι μηνυμάτων OpenFlow.

Στην υλοποίηση της διπλωματικής, η περιοδική ανάκτηση στατιστικών θυρών αντιστοιχεί εννοιολογικά σε μια ακολουθία Port-Stats Request/Reply, ενώ η εγκατάσταση κανόνα απόρριψης αντιστοιχεί σε ένα μήνυμα Flow-Mod. Έτσι, παρά τη χρήση του `ons-ofctl` ως μηχανισμού μεταφοράς, η σημασιολογία παραμένει πλήρως OpenFlow-συμβατή.

Η διοχέτευση επεξεργασίας του OpenFlow

Στις νεότερες εκδόσεις του OpenFlow, η επεξεργασία ενός πακέτου δεν περιορίζεται σε έναν μόνο πίνακα ροών αλλά διέρχεται από μια διοχέτευση (pipeline) πολλαπλών

πινάκων. Κάθε πακέτο εισέρχεται στον πρώτο πίνακα, όπου αναζητείται η καταχώρηση με την υψηλότερη προτεραιότητα που ταιριάζει. Η αντίστοιχη ενέργεια μπορεί είτε να ολοκληρώσει την επεξεργασία είτε να προωθήσει το πακέτο σε επόμενο πίνακα μέσω της εντολής Goto-Table. Κατά τη διαδρομή αυτή, το πακέτο συνοδεύεται από ένα σύνολο ενεργειών (action set) που συσσωρεύεται και εκτελείται στο τέλος. Η αρχιτεκτονική πολλαπλών πινάκων επιτρέπει τον διαχωρισμό της λογικής (π.χ. ένας πίνακας για ασφάλεια, ένας για δρομολόγηση) και τη συμπαγέστερη έκφραση σύνθετων πολιτικών.

Πέραν των απλών πινάκων ροών, το OpenFlow ορίζει και πίνακες ομάδων (group tables), οι οποίοι υποστηρίζουν προηγμένες λειτουργίες όπως πολλαπλή προώθηση (multicast), εξισορρόπηση φορτίου και ταχεία εναλλαγή διαδρομής σε περίπτωση αστοχίας (fast failover). Παρότι η υλοποίηση της παρούσας διπλωματικής εστιάζει στη σημασιολογία match-action ενός πίνακα, η κατανόηση της πλήρους διοχέτευσης είναι σημαντική για την εκτίμηση των δυνατοτήτων και των περιορισμών ενός προγραμματιζόμενου επιπέδου δεδομένων.

Το Open vSwitch υλοποιεί πλήρως αυτή τη διοχέτευση, διατηρώντας παράλληλα μια δομή γρήγορης διαδρομής (fast path) στον πυρήνα για την αποδοτική προώθηση των ήδη εγκατεστημένων ροών, και μια αργή διαδρομή (slow path) στον χώρο χρήστη για τις νέες αποφάσεις. Αυτή η αρχιτεκτονική δύο επιπέδων εξηγεί γιατί οι επιθέσεις που παράγουν συνεχώς νέες ροές, και επομένως αναγκάζουν συνεχή χρήση της αργής διαδρομής, είναι ιδιαίτερα επιζήμιες.

Πεδία ταιριάσματος και δομή καταχώρησης ροής

Η εκφραστικότητα του OpenFlow απορρέει από το πλούσιο σύνολο πεδίων ταιριάσματος που μπορεί να χρησιμοποιήσει μια καταχώρηση ροής. Τα πεδία αυτά καλύπτουν πολλαπλά επίπεδα της στοίβας πρωτοκόλλων: τη θύρα εισόδου του μεταγωγέα, τις διευθύνσεις MAC προέλευσης και προορισμού, τον τύπο Ethernet, τις διευθύνσεις IP, το πρωτόκολλο μεταφοράς και τις θύρες TCP ή UDP. Ο συνδυασμός αυτών των πεδίων επιτρέπει τον καθορισμό κανόνων με διαφορετική κοκκομέτρηση: από γενικούς κανόνες που ταιριάζουν σε ολόκληρα υποδίκτυα, μέχρι εξειδικευμένους κανόνες για μια συγκεκριμένη ροή. Στην υλοποίηση της διπλωματικής, ο κανόνας απόρριψης του επιτιθέμενου χρησιμοποιεί ταίριασμα στη διεύθυνση IP προέλευσης, επιτυγχάνοντας στοχευμένο αποκλεισμό χωρίς επίπτωση στη νόμιμη κίνηση.

Κάθε καταχώρηση ροής συνοδεύεται από προτεραιότητα, χρονόμετρα λήξης (idle και hard timeout) και μετρητές. Η προτεραιότητα καθορίζει ποιος κανόνας υπερισχύει όταν πολλοί ταιριάζουν. Γι' αυτό ο κανόνας απόρριψης εγκαθίσταται με υψηλή προτεραιότητα, ώστε να υπερισχύει των κανόνων προώθησης. Τα χρονόμετρα λήξης επιτρέπουν την αυτόματη αφαίρεση κανόνων που δεν χρησιμοποιούνται, αποτρέποντας τη συσσώρευση άχρηστων καταχωρήσεων, μηχανισμός ιδιαίτερα σημαντικός στο πλαίσιο των επιθέσεων εξάντλησης του πίνακα ροών.

Μηχανισμός συλλογής στατιστικών

Η δυνατότητα ανίχνευσης βάσει ροών στηρίζεται στους μετρητές που διατηρεί αυτόματα ο μεταγωγέας για κάθε καταχώρηση και για κάθε θύρα. Κάθε φορά που ένα πακέτο ταιριάζει σε έναν κανόνα, οι αντίστοιχοι μετρητές πακέτων και bytes αυξάνονται. Ο ελεγκτής μπορεί να ανακτήσει αυτά τα στατιστικά ανά πάσα στιγμή, χωρίς πρόσθετο κόστος στο επίπεδο δεδομένων. Στην υλοποίηση της διπλωματικής, η περιοδική ανάκτηση των στατιστικών θυρών κάθε πέντε δευτερόλεπτα παρέχει μια χρονοσειρά μετρήσεων, από την οποία, με απλή διαφόριση, προκύπτει η δραστηριότητα κάθε παραθύρου. Η προσέγγιση αυτή είναι ελαφριά, μη παρεμβατική και κλιμακώσιμη, καθιστώντας την ιδανική βάση για ανίχνευση σε πραγματικό χρόνο.

2.4 Ελεγκτές SDN: εσωτερική δομή, διαθεσιμότητα και ασφάλεια του καναλιού ελέγχου

Στη βιβλιογραφία και στην πράξη έχουν αναπτυχθεί πολλοί ελεγκτές SDN, με διαφορετικά χαρακτηριστικά ως προς τη γλώσσα υλοποίησης, την παραγωγικότητα και το πεδίο χρήσης. Οι πιο διαδεδομένοι είναι:

Ελεγκτής	Γλώσσα	Χαρακτηριστικά / Χρήση
POX / NOX	Python / C++	Εκπαιδευτικοί, απλοί, ιδανικοί για prototyping.
Ryu	Python	Ευρέως χρησιμοποιούμενος στην ακαδημαϊκή έρευνα.
ONOS	Java	Παραγωγικός, κατανεμημένος, υψηλής διαθεσιμότητας.
OpenDaylight	Java	Modular, βιομηχανικό πρότυπο, μεγάλη κοινότητα.

Πίνακας 2: Σύγκριση των κυριότερων ελεγκτών SDN.

Στην παρούσα διπλωματική, η αρχική επιλογή ήταν ο Ryu, λόγω της ευρείας του χρήσης στην ακαδημαϊκή βιβλιογραφία και της υλοποίησής του σε Python. Ωστόσο, όπως αναλύεται στο Κεφάλαιο 5, τεχνικές ασυμβατότητες του Ryu με σύγχρονες εκδόσεις της Python οδήγησαν σε μια υβριδική αρχιτεκτονική ελέγχου, η οποία διατηρεί πλήρως τη σημασιολογία του OpenFlow μέσω του Open vSwitch, χωρίς εξάρτηση από εξωτερικό framework.

Εσωτερική δομή και υψηλή διαθεσιμότητα του ελεγκτή

Ένας σύγχρονος ελεγκτής SDN δεν είναι μονολιθικός. Αποτελείται από πολλαπλά υποσυστήματα, όπως η διαχείριση της τοπολογίας, η υπηρεσία δρομολόγησης, η διαχείριση συμβάντων και η διεπαφή προς τις εφαρμογές. Σε παραγωγικά περιβάλλοντα, όπου η διαθεσιμότητα είναι κρίσιμη, οι ελεγκτές αναπτύσσονται σε συστάδες (clusters) πολλαπλών κόμβων, με συγχρονισμό της κατάστασης μεταξύ τους. Έτσι, η αστοχία ενός κόμβου δεν συνεπάγεται κατάρρευση του δικτύου, καθώς ένας άλλος αναλαμβάνει αυτόματα. Η προσέγγιση αυτή αντιμετωπίζει εν μέρει τον περιορισμό του μοναδικού σημείου αποτυχίας, αλλά εισάγει με τη σειρά της προκλήσεις συνέπειας και συντονισμού.

Η κατανόηση αυτής της δομής είναι σημαντική για την τοποθέτηση της διπλωματικής: το σύστημα ανίχνευσης λειτουργεί ως ένα υποσύστημα ασφαλείας στο επίπεδο εφαρμογών, το οποίο, σε μια κατανεμημένη ανάπτυξη, θα έπρεπε και το ίδιο να συντονίζει την κατάστασή του (τους ενεργούς κανόνες απόρριψης) μεταξύ των κόμβων της συστάδας. Η αρθρωτή σχεδίαση του συστήματος διευκολύνει μια τέτοια επέκταση, καθώς η κατάσταση ασφαλείας είναι σαφώς διαχωρισμένη από τη λογική της ανίχνευσης.

Ασφάλεια του καναλιού ελέγχου

Το κανάλι ελέγχου μεταξύ ελεγκτή και μεταγωγέων αποτελεί το ίδιο έναν κρίσιμο στόχο. Το OpenFlow προβλέπει την προστασία του με TLS, ώστε να διασφαλίζεται η εμπιστευτικότητα και η ακεραιότητα των μηνυμάτων και να αποτρέπεται η πλαστοπροσωπία μεταγωγέα ή ελεγκτή. Στην πράξη, ωστόσο, η κρυπτογράφηση του καναλιού συχνά παραλείπεται σε πειραματικά περιβάλλοντα, αφήνοντας ανοιχτό ένα σημαντικό διάνυσμα επίθεσης. Η αυθεντικοποίηση με token που υιοθετεί η υλοποίηση της διπλωματικής για την τηλεμετρία και τα διαχειριστικά endpoints κινείται στο ίδιο πνεύμα προστασίας του καναλιού επικοινωνίας, σε επίπεδο εφαρμογής.

2.5 Εργαλεία προσομοίωσης: Mininet και Open vSwitch

Η πειραματική διάταξη της διπλωματικής στηρίζεται σε δύο θεμελιώδη εργαλεία του οικοσυστήματος SDN. Το Mininet, που παρουσιάστηκε από τους Lantz κ.ά. [3] και τιμήθηκε με το βραβείο Test of Time του ACM SIGCOMM, επιτρέπει τη δημιουργία ρεαλιστικών εικονικών δικτύων, με hosts, μεταγωγείς και συνδέσεις, σε έναν μόνο υπολογιστή, αξιοποιώντας τους μηχανισμούς απομόνωσης του πυρήνα Linux. Έτσι, ένα ολόκληρο δικτυακό σενάριο μπορεί να στηθεί, να εκτελεστεί και να καταστραφεί μέσα σε δευτερόλεπτα, γεγονός που το καθιστά ιδανικό για επαναλήψιμα πειράματα.

Το Open vSwitch (OVS), που περιγράφηκε από τους Pfaff κ.ά. [4] και απέσπασε το βραβείο Best Paper στο NSDI '15, είναι ένας πλήρης εικονικός μεταγωγέας ανοιχτού κώδικα με πλήρη υποστήριξη OpenFlow. Το OVS χρησιμοποιείται τόσο σε πειραματικά όσο και σε παραγωγικά περιβάλλοντα νεφούπολογιστικής και αποτελεί το πρότυπο για την υλοποίηση προγραμματιζόμενων μεταγωγέων. Στη διπλωματική, η διεπαφή διαχείρισης `ovs-ofctl` χρησιμοποιείται για την ανάκτηση στατιστικών θυρών και την εγκατάσταση κανόνων ροής, λειτουργίες σημασιολογικά ταυτόσημες με τα αντίστοιχα μηνύματα OpenFlow.

2.6 Σύγκριση με τα παραδοσιακά δίκτυα: πλεονεκτήματα και προκλήσεις

Ο διαχωρισμός του επιπέδου ελέγχου από το επίπεδο δεδομένων επιφέρει μια σειρά από ουσιαστικά λειτουργικά πλεονεκτήματα, τα οποία εξηγούν την ταχεία υιοθέτηση των SDN σε κέντρα δεδομένων και δίκτυα παρόχων. Πρώτον, η κεντρική διαχείριση επιτρέπει τον ενιαίο ορισμό πολιτικών: ο διαχειριστής περιγράφει την επιθυμητή συμπεριφορά μία φορά, και ο ελεγκτής την υλοποιεί συνεπώς σε όλες τις συσκευές, εξαλείφοντας τις αποκλίσεις διαμόρφωσης (configuration drift) που ταλανίζουν τα παραδοσιακά δίκτυα. Δεύτερον, η προγραμματισιμότητα μέσω της βόρειας διεπαφής επιτρέπει την αυτοματοποίηση και την ταχεία ανάπτυξη νέων υπηρεσιών χωρίς αναβάθμιση υλικού. Τρίτον, η καθολική εικόνα του δικτύου καθιστά δυνατή τη βελτιστοποίηση σε επίπεδο συστήματος, π.χ. καθολικό traffic engineering, αντί για τοπικές, μυωπικές αποφάσεις.

Οι ίδιες, όμως, ιδιότητες γεννούν και νέες προκλήσεις. Η κλιμακωσιμότητα του ελεγκτή αποτελεί ανοιχτό ζήτημα: ένας κεντρικός ελεγκτής πρέπει να εξυπηρετεί τα αιτήματα ολόκληρου του δικτύου, και ο ρυθμός με τον οποίο μπορεί να επεξεργάζεται μηνύματα Packet-In θέτει άνω όριο στη χωρητικότητα. Η αξιοπιστία (dependability) είναι εξίσου

κρίσιμη, καθώς ο ελεγκτής αποτελεί μοναδικό σημείο αποτυχίας. Τέλος, η ασφάλεια, το αντικείμενο της παρούσας διπλωματικής, απαιτεί ιδιαίτερη προσοχή, ακριβώς επειδή η συγκέντρωση της λογικής συγκεντρώνει και το ρίσκο. Οι Benzekki κ.ά. [5] εντοπίζουν αυτές τις τρεις προκλήσεις ως τις κυριότερες που πρέπει να αντιμετωπίσει η ώριμη υιοθέτηση των SDN.

Σύγκριση παραδοσιακών δικτύων και SDN

Πτυχή	Παραδοσιακό δίκτυο	SDN
Έλεγχος	Κατανεμημένος, ανά συσκευή	Λογικά κεντρικός
Διαμόρφωση	Χειροκίνητη, ανά συσκευή	Προγραμματιζόμενη, κεντρική
Καινοτομία	Αργή (κλειστό υλικό)	Ταχεία (λογισμικό)
Καθολική εικόνα	Απούσα	Παρούσα στον ελεγκτή
Σημείο αποτυχίας	Κατανεμημένο	Ο ελεγκτής

Πίνακας 3: Συγκριτική επισκόπηση παραδοσιακών δικτύων και SDN.

2.7 Σχέση με το NFV, τυποποίηση και οικοσύστημα

Στενά συνδεδεμένη με τα SDN είναι η έννοια της Δικτυακής Εικονικοποίησης Λειτουργιών (Network Functions Virtualization, NFV). Ενώ τα SDN αφορούν τον διαχωρισμό και την κεντροποίηση του ελέγχου, η NFV αφορά την υλοποίηση δικτυακών λειτουργιών, όπως τείχη προστασίας, εξισορροπητές φορτίου και συστήματα ανίχνευσης εισβολών, ως λογισμικού που εκτελείται σε τυποποιημένους διακομιστές, αντί για εξειδικευμένες συσκευές. Οι δύο τεχνολογίες είναι συμπληρωματικές: τα SDN παρέχουν την προγραμματιζόμενη διασύνδεση, ενώ η NFV παρέχει τις εικονικοποιημένες λειτουργίες που δρομολογούνται μέσω αυτής. Το σύστημα ανίχνευσης της παρούσας διπλωματικής μπορεί να ιδωθεί ως μια τέτοια εικονικοποιημένη λειτουργία ασφαλείας, η οποία συνεργάζεται με το προγραμματιζόμενο επίπεδο δεδομένων για την επιβολή πολιτικών.

Τυποποίηση και οικοσύστημα των SDN

Η ωρίμανση των SDN συνοδεύτηκε από την ανάπτυξη ενός ευρύτερου οικοσυστήματος προτύπων και φορέων. Η Open Networking Foundation ανέλαβε την τυποποίηση του OpenFlow, ενώ πλήθος έργων ανοιχτού κώδικα, από ελεγκτές όπως ο OpenDaylight και ο ONOS μέχρι πλατφόρμες εικονικοποίησης, συνέβαλαν στη διάδοση της τεχνολογίας. Η

ύπαρξη ανοιχτών προτύπων είναι θεμελιώδης για την αποφυγή του εγκλωβισμού σε συγκεκριμένο προμηθευτή (vendor lock-in) και για την προώθηση της καινοτομίας. Η παρούσα διπλωματική, στηριζόμενη εξ ολοκλήρου σε λογισμικό ανοιχτού κώδικα, Open vSwitch, Mininet, Python και το οικοσύστημα επιστημονικού υπολογισμού, εντάσσεται σε αυτή τη φιλοσοφία, διασφαλίζοντας την προσβασιμότητα και την αναπαραγωγικότητά της.

Παράλληλα με το OpenFlow, αναπτύχθηκαν και συμπληρωματικά πρότυπα, όπως τα διεπαφών βόρειας κατεύθυνσης και τα μοντέλα δεδομένων για τη διαμόρφωση. Η σύγκλιση των SDN με τη Δικτυακή Εικονικοποίηση Λειτουργιών οδήγησε σε ολοκληρωμένες αρχιτεκτονικές, όπου το προγραμματιζόμενο δίκτυο και οι εικονικοποιημένες λειτουργίες συνεργάζονται. Σε αυτό το τοπίο, η ασφάλεια αναδεικνύεται ως οριζόντια απαίτηση που διατρέχει όλα τα επίπεδα, από το προγραμματιζόμενο επίπεδο δεδομένων μέχρι τις εφαρμογές ασφαλείας του ανώτερου επιπέδου, όπου εντάσσεται και το σύστημα της διπλωματικής.

2.8 Περιπτώσεις χρήσης και υπηρεσίες του επιπέδου εφαρμογών

Η ευελιξία των SDN έχει οδηγήσει σε ευρύ φάσμα πρακτικών εφαρμογών. Στα κέντρα δεδομένων, τα SDN επιτρέπουν την αυτόματη παροχή δικτυακών πόρων και τη δυναμική απομόνωση πολλαπλών ενοίκων (multi-tenancy). Στα δίκτυα ευρείας περιοχής των παρόχων (SD-WAN), επιτρέπουν την έξυπνη δρομολόγηση με βάση την ποιότητα των συνδέσμων και το κόστος. Στα δίκτυα κορμού, διευκολύνουν το traffic engineering σε κλίμακα. Σε όλες αυτές τις περιπτώσεις, ωστόσο, η κεντρικοποίηση του ελέγχου συνοδεύεται από την ανάγκη προστασίας του ελεγκτή, γεγονός που καθιστά την παρούσα διπλωματική συναφή με ένα ευρύ φάσμα πραγματικών αναπτύξεων.

Το επίπεδο εφαρμογών και οι υπηρεσίες ασφαλείας

Το επίπεδο εφαρμογών των SDN φιλοξενεί ένα ευρύ φάσμα υπηρεσιών που αξιοποιούν την κεντρική εικόνα και την προγραμματισιμότητα του δικτύου. Στον τομέα της ασφαλείας, τέτοιες υπηρεσίες περιλαμβάνουν δυναμικά τείχη προστασίας, συστήματα ανίχνευσης και πρόληψης εισβολών, μηχανισμούς απομόνωσης παραβιασμένων κόμβων και εφαρμογές επιβολής πολιτικών. Το βασικό πλεονέκτημα της υλοποίησης τέτοιων λειτουργιών ως εφαρμογών SDN, αντί ως αυτόνομων συσκευών, είναι η στενή ολοκλήρωση με τον έλεγχο του δικτύου: μια εφαρμογή ασφαλείας δεν χρειάζεται απλώς να ανιχνεύει, αλλά μπορεί άμεσα να επιβάλλει την απόκρισή της,

επαναπρογραμματίζοντας το δίκτυο. Το σύστημα της διπλωματικής αποτελεί ακριβώς μια τέτοια εφαρμογή, ενσωματώνοντας ανίχνευση και επιβολή σε έναν ενιαίο βρόχο.

3. Απειλές και Επιθέσεις σε Δίκτυα SDN

Η αρχιτεκτονική SDN, παρά τα λειτουργικά της πλεονεκτήματα, εισάγει μια διευρυμένη και ποιοτικά διαφορετική επιφάνεια επίθεσης σε σύγκριση με τα παραδοσιακά δίκτυα. Στο κεφάλαιο αυτό αναλύονται συστηματικά οι απειλές ανά επίπεδο της αρχιτεκτονικής, με έμφαση στις επιθέσεις που στοχεύουν τον κεντρικό ελεγκτή, οι οποίες αποτελούν και το κύριο αντικείμενο του συστήματος άμυνας που αναπτύσσεται.

3.1 Επιφάνεια επίθεσης ανά επίπεδο

Η επισκόπηση ασφάλειας των Scott-Hayward κ.ά. [6] κατηγοριοποιεί τις απειλές SDN σύμφωνα με το επίπεδο που πλήττουν. Στο επίπεδο εφαρμογών, οι απειλές αφορούν κακόβουλες ή ευάλωτες εφαρμογές που, μέσω της βόρειας διεπαφής, μπορούν να επιβάλουν επικίνδυνες πολιτικές. Στο επίπεδο ελέγχου, ο ελεγκτής και το κανάλι ελέγχου αποτελούν στόχους επιθέσεων άρνησης εξυπηρέτησης, πλαστοπροσωπίας και μη εξουσιοδοτημένης πρόσβασης. Στο επίπεδο δεδομένων, οι μεταγωγείς είναι ευάλωτοι σε επιθέσεις πλαστογράφησης ροών, δηλητηρίασης τοπολογίας και εξάντλησης πόρων.

3.2 Επιθέσεις άρνησης εξυπηρέτησης: μορφές, κύκλος ζωής και ταξινόμηση

Η πιο κρίσιμη κατηγορία επιθέσεων σε SDN είναι οι επιθέσεις άρνησης εξυπηρέτησης (Denial of Service, DoS) και οι κατανεμημένες εκδοχές τους (Distributed DoS, DDoS) που στοχεύουν τον ελεγκτή. Επειδή ο ελεγκτής είναι υπεύθυνος για τη λήψη αποφάσεων σχετικά με κάθε νέα ροή, ένας επιτιθέμενος που κατακλύζει το δίκτυο με μεγάλο όγκο κίνησης, π.χ. μέσω SYN flood, μπορεί να εξαντλήσει τους υπολογιστικούς του πόρους. Καθώς καθεμία νέα, «άγνωστη» ροή προκαλεί μήνυμα Packet-In προς τον ελεγκτή, ο τελευταίος κατακλύζεται από αιτήματα και δεν προλαβαίνει να εξυπηρετήσει τη νόμιμη κίνηση.

Κύκλος ζωής μιας επίθεσης DDoS σε SDN

Για να γίνει κατανοητή η δυναμική μιας επίθεσης άρνησης εξυπηρέτησης σε περιβάλλον SDN, είναι χρήσιμο να αναλυθεί ο κύκλος ζωής της. Στην αρχική φάση, ο επιτιθέμενος, συχνά ελέγχοντας ένα δίκτυο παραβιασμένων συσκευών (botnet), αρχίζει να παράγει μεγάλο όγκο πακέτων προς το θύμα, τυπικά με πλαστές ή τυχαίες διευθύνσεις προέλευσης.

Στα SDN, καθεμία από αυτές τις φαινομενικά νέες ροές δεν ταιριάζει σε υπάρχοντα κανόνα, προκαλώντας μήνυμα Packet-In προς τον ελεγκτή.

Στη δεύτερη φάση, ο ρυθμός των Packet-In αυξάνεται εκθετικά. Ο ελεγκτής, με πεπερασμένη χωρητικότητα επεξεργασίας, αρχίζει να συσσωρεύει αιτήματα σε ουρά. Ο χρόνος απόκρισης για τη νόμιμη κίνηση αυξάνεται σημαντικά, καθώς τα νόμιμα αιτήματα περιμένουν πίσω από τα κακόβουλα. Ταυτόχρονα, ο πίνακας ροών του μεταγωγέα αρχίζει να γεμίζει με εφήμερους κανόνες. Στην τρίτη, κρίσιμη φάση, ο ελεγκτής κορεννύεται πλήρως: δεν μπορεί πλέον να εξυπηρετήσει νόμιμα αιτήματα, και το δίκτυο, από τη σκοπιά του χρήστη, παύει ουσιαστικά να λειτουργεί, παρότι ο ίδιος ο σύνδεσμος δεδομένων μπορεί να μην είναι κορεσμένος.

Σε αυτόν τον κύκλο παρεμβαίνει το σύστημα της διπλωματικής. Ανιχνεύοντας την επίθεση ήδη από το πρώτο παράθυρο δειγματοληψίας, πριν δηλαδή ο ελεγκτής φτάσει στη φάση κορεσμού, και εγκαθιστώντας κανόνα απόρριψης στην πηγή, το σύστημα διακόπτει τον φαύλο κύκλο των Packet-In στην αφετηρία του. Η ταχύτητα της αντίδρασης, που τεκμηριώνεται στην ανάλυση καθυστέρησης, είναι επομένως όχι απλώς επιθυμητή αλλά καθοριστική για την αποτροπή της τρίτης φάσης.

Ταξινόμηση των επιθέσεων DDoS

Οι επιθέσεις άρνησης εξυπηρέτησης δεν είναι ομοιογενείς. Διακρίνονται σε τρεις βασικές κατηγορίες ανάλογα με το επίπεδο που στοχεύουν [7]. Οι ογκομετρικές επιθέσεις (volumetric) επιδιώκουν να κορέσουν το εύρος ζώνης του συνδέσμου με τεράστιο όγκο κίνησης. Οι επιθέσεις πρωτοκόλλου (protocol attacks), όπως το SYN flood, εκμεταλλεύονται αδυναμίες στη λειτουργία των πρωτοκόλλων για να εξαντλήσουν πόρους κατάστασης, όπως τους πίνακες συνδέσεων. Οι επιθέσεις επιπέδου εφαρμογής (application layer) στοχεύουν συγκεκριμένες υπηρεσίες με φαινομενικά νόμιμα αιτήματα που όμως εξαντλούν τους πόρους του διακομιστή. Στα SDN, όλες αυτές οι κατηγορίες αποκτούν μια πρόσθετη διάσταση: πέραν του θύματος, πλήττουν και τον ίδιο τον ελεγκτή μέσω της καταιγίδας μηνυμάτων που προκαλούν.

Ιδιαίτερη μνεία αξίζουν οι επιθέσεις ενίσχυσης (amplification), όπου ο επιτιθέμενος εκμεταλλεύεται υπηρεσίες που απαντούν με δυσανάλογα μεγάλο όγκο σε μικρά αιτήματα, πολλαπλασιάζοντας την ισχύ της επίθεσης ενώ ταυτόχρονα αποκρύπτει την ταυτότητά του μέσω πλαστογράφησης της διεύθυνσης προέλευσης. Η πλαστογράφηση αυτή είναι που καθιστά τις τυχαίες διευθύνσεις προέλευσης, και επομένως την επίθεση κορεσμού του

control plane, τόσο αποτελεσματικές, καθώς κάθε πλαστό πακέτο εμφανίζεται ως νέα, άγνωστη ροή.

Επιθέσεις χαμηλής έντασης και μακράς διάρκειας

Πέρα από τις θορυβώδεις επιθέσεις όγκου, υπάρχει μια κατηγορία επιθέσεων που είναι εξ ορισμού δυσκολότερο να ανιχνευθούν: οι επιθέσεις χαμηλής έντασης και μακράς διάρκειας (low-and-slow). Αντί να κατακλύζουν το θύμα με τεράστιο όγκο, οι επιθέσεις αυτές διατηρούν έναν χαμηλό, διακριτικό ρυθμό, ώστε να παραμένουν κάτω από τα κατώφλια των παραδοσιακών ανιχνευτών, ενώ σταδιακά εξαντλούν τους πόρους κατάστασης του θύματος. Η ανάλυση αντίπαλης ανθεκτικότητας της διπλωματικής εξέτασε ακριβώς τέτοιες στρατηγικές (slow-rate, pulse), διαπιστώνοντας ότι το ζωντανό μοντέλο διατηρεί την ανθεκτικότητά του ακόμη και σε πολύ χαμηλές εντάσεις, χάρη στην εστίασή του σε συμπεριφορικά χαρακτηριστικά που δεν εξαρτώνται αποκλειστικά από τον όγκο. Το εύρημα αυτό είναι σημαντικό, καθώς οι επιθέσεις χαμηλής έντασης αποτελούν από τις δυσκολότερες προκλήσεις για κάθε σύστημα ανίχνευσης.

3.3 Κορεσμός του πίνακα ροών και του καναλιού ελέγχου

Στενά συνδεδεμένη με τα παραπάνω είναι η επίθεση κορεσμού του πίνακα ροών (flow-table exhaustion). Ο πίνακας ροών ενός μεταγωγέα υλοποιείται συχνά σε ακριβή, περιορισμένης χωρητικότητας μνήμη TCAM, με τυπικό μέγεθος μερικών χιλιάδων καταχωρήσεων. Ένας επιτιθέμενος που παράγει τεχνητά μεγάλο πλήθος διακριτών ροών, για παράδειγμα, στέλνοντας πακέτα με τυχαίες διευθύνσεις προέλευσης, μπορεί να γεμίσει τον πίνακα, εμποδίζοντας την εγκατάσταση κανόνων για νόμιμες ροές. Ταυτόχρονα, κάθε τέτοια νέα ροή προκαλεί table-miss και επομένως Packet-In, υπερφορτώνοντας και το κανάλι ελέγχου. Πρόκειται για την πλέον SDN-specific επίθεση, η οποία δεν έχει αντίστοιχο στα παραδοσιακά δίκτυα και αναλύεται εκτενώς στο Κεφάλαιο 6.

3.4 Πλαστογράφηση, δηλητηρίαση τηλεμετρίας και επιθέσεις ενδιάμεσου

Πέραν των επιθέσεων όγκου, υπάρχουν και πιο εκλεπτυσμένες απειλές που στοχεύουν στην ακεραιότητα της πληροφορίας βάσει της οποίας ο ελεγκτής λαμβάνει αποφάσεις. Η πλαστογράφηση κανόνων ροής (flow-rule injection) αφορά την εισαγωγή κακόβουλων ή παραπλανητικών κανόνων. Μια ιδιαιτέρως ενδιαφέρουσα παραλλαγή, που εξετάζεται πειραματικά στην παρούσα διπλωματική, είναι η δηλητηρίαση τηλεμετρίας (telemetry

poisoning): ο επιτιθέμενος κατασκευάζει πλαστά στατιστικά ροών ώστε να «ενοχοποιήσει» έναν νόμιμο host, προκαλώντας τον ελεγκτή να τον μπλοκάρει και δημιουργώντας έτσι έμμεση άρνηση εξυπηρέτησης. Η επίθεση αυτή αναδεικνύει τη σημασία της αυθεντικοποίησης (authentication) της πηγής της τηλεμετρίας.

Πλαστογράφηση, υποκλοπή και επιθέσεις ενδιάμεσου

Οι επιθέσεις που στοχεύουν την ακεραιότητα και την εμπιστευτικότητα, παρά την ασφάλεια όγκου, αποτελούν ιδιαίτερη κατηγορία απειλών. Το ARP spoofing εκμεταλλεύεται την απουσία αυθεντικοποίησης στο πρωτόκολλο ανάλυσης διευθύνσεων: ο επιτιθέμενος αποστέλλει πλαστές αντιστοιχίσεις διεύθυνσης IP σε MAC, πείθοντας τα θύματα ότι η δική του συσκευή είναι η πύλη ή ένας άλλος νόμιμος κόμβος. Έτσι, η κίνηση δρομολογείται μέσω του επιτιθέμενου, ο οποίος μπορεί να την υποκλέψει ή να την τροποποιήσει, μια κλασική επίθεση ενδιάμεσου ανθρώπου. Σε περιβάλλον SDN, τέτοιες επιθέσεις μπορούν επιπλέον να δηλητηριάσουν την εικόνα τοπολογίας του ελεγκτή, οδηγώντας σε εσφαλμένες αποφάσεις δρομολόγησης.

Η ανίχνευση τέτοιων επιθέσεων απαιτεί διαφορετική οπτική από αυτή των επιθέσεων όγκου, καθώς το αποτύπωμά τους δεν είναι πάντοτε στατιστικά έντονο. Στη διπλωματική, το σενάριο ARP spoofing αντιμετωπίστηκε επιτυχώς μέσω της ανίχνευσης της ανώμαλης δραστηριότητας που συνοδεύει την επίθεση. Εντούτοις, η πλήρης αντιμετώπιση τέτοιων απειλών ενισχύεται σημαντικά από μηχανισμούς ακεραιότητας, όπως η αυθεντικοποίηση της τηλεμετρίας, υπογραμμίζοντας τη συμπληρωματικότητα στατιστικής ανίχνευσης και κλασικής ασφάλειας.

3.5 Σάρωση, πλευρική κίνηση και υποκλοπή

Η σάρωση θυρών (port scanning) αποτελεί συνήθως το πρώτο στάδιο μιας επίθεσης, καθώς ο επιτιθέμενος χαρτογραφεί τις ενεργές υπηρεσίες πριν επιλέξει διάνυσμα εκμετάλλευσης. Χαρακτηρίζεται από πολλές, σύντομες ροές προς διαφορετικές θύρες ή διευθύνσεις. Η πλευρική κίνηση (lateral movement) περιγράφει τη μετακίνηση ενός ήδη παραβιασμένου host προς άλλους εσωτερικούς κόμβους, με στόχο την κλιμάκωση της παρείσφρησης. Τέλος, επιθέσεις όπως το ARP spoofing επιτρέπουν την υποκλοπή ή τροποποίηση κίνησης (Man-in-the-Middle) μέσω πλαστών αντιστοιχίσεων διεύθυνσης. Όλες αυτές οι κατηγορίες περιλαμβάνονται στα ζωντανά σενάρια αξιολόγησης του Κεφαλαίου 6.

3.6 Ο ελεγκτής ως μοναδικό σημείο αποτυχίας και οι εσωτερικές απειλές

Το κοινό νήμα που διατρέχει τις παραπάνω απειλές είναι ο κεντρικός ρόλος του ελεγκτή. Η λογική κεντριοποίηση, ενώ αποτελεί το βασικό πλεονέκτημα των SDN, μετατρέπει τον ελεγκτή σε μοναδικό σημείο αποτυχίας: η επιτυχής παρεμπόδιση ή παραπλάνησή του έχει καθολικές συνέπειες για το δίκτυο. Η διαπίστωση αυτή θεμελιώνει τόσο την ανάγκη για έγκαιρη, αυτοματοποιημένη ανίχνευση όσο και τη σχεδιαστική επιλογή ενός υβριδικού μοντέλου ελέγχου (Κεφάλαιο 5), στο οποίο η βασική συνδεσιμότητα διατηρείται ακόμη και υπό πίεση, ενώ ο ελεγκτής αφιερώνεται στη λειτουργία ασφαλείας.

Εσωτερικές απειλές και παραβίαση ελεγκτή

Πέραν των εξωτερικών επιτιθέμενων, τα SDN είναι ευάλωτα και σε εσωτερικές απειλές. Μια παραβιασμένη εφαρμογή στο επίπεδο εφαρμογών, με πρόσβαση στη βόρεια διεπαφή, μπορεί να επιβάλει κακόβουλες πολιτικές σε ολόκληρο το δίκτυο. Ακόμη σοβαρότερη είναι η πλήρης παραβίαση του ίδιου του ελεγκτή: δεδομένου του κεντρικού του ρόλου, ο έλεγχός του από επιτιθέμενο ισοδυναμεί με έλεγχο ολόκληρου του δικτύου. Οι απειλές αυτές τεκμηριώνουν την ανάγκη για αυστηρό έλεγχο πρόσβασης, αυθεντικοποίηση και αρχή του ελάχιστου προνομίου στην αρχιτεκτονική ασφάλειας ενός SDN. Στην υλοποίηση της διπλωματικής, η προστασία των διαχειριστικών endpoints με token και η αυθεντικοποίηση του μεταγωγέα αποτελούν πρακτικά μέτρα προς αυτή την κατεύθυνση.

3.7 Ταξινόμηση των απειλών, υποδομή και αντίκτυπος των επιθέσεων

Για μια συνολική εικόνα, οι απειλές που εξετάστηκαν μπορούν να ταξινομηθούν ανά στόχο, μηχανισμό και επίπτωση, όπως στον ακόλουθο πίνακα. Η ταξινόμηση αυτή καθοδηγεί τον σχεδιασμό της άμυνας: κάθε κατηγορία απαιτεί διαφορετικά διαγνωστικά χαρακτηριστικά.

Επίθεση	Στόχος	Μηχανισμός	Κύρια επίπτωση
DDoS/SYN flood	Ελεγκτής	Πλημμύρα νέων ροών	Κορεσμός ελεγκτή
Flow-table exhaustion	Μεταγωγέας	Τυχαίες IPs	Γέμισμα TCAM
Telemetry poisoning	Ελεγκτής	Πλαστά στατιστικά	Μπλοκ νόμιμου host
Port scanning	Δίκτυο	Πολλές σύντομες ροές	Αναγνώριση στόχων

Lateral movement	Εσωτ. κόμβοι	Εξάπλωση παρείσφρησης	Κλιμάκωση
ARP spoofing	Hosts	Πλαστές αντιστοιχίσεις	Υποκλοπή (MITM)

Πίνακας 4: Ταξινόμηση των εξεταζόμενων επιθέσεων.

Παρατηρείται ότι οι επιθέσεις όγκου (DDoS, flow-table exhaustion) αφήνουν εμφανές αποτύπωμα στα συγκεντρωτικά χαρακτηριστικά και ανιχνεύονται εύκολα, ενώ οι εκλεπτυσμένες επιθέσεις (telemetry poisoning) απαιτούν μηχανισμούς ακεραιότητας και αυθεντικοποίησης, πέραν της καθαρής στατιστικής ανίχνευσης. Η άμυνα της διπλωματικής καλύπτει και τις δύο διαστάσεις.

Οικονομικός και λειτουργικός αντίκτυπος

Πέρα από την τεχνική διάσταση, οι επιθέσεις σε SDN έχουν σημαντικό οικονομικό και λειτουργικό αντίκτυπο. Σε περιβάλλοντα κέντρων δεδομένων και παρόχων υπηρεσιών, η διακοπή λειτουργίας του δικτύου, έστω και για λίγα λεπτά, μπορεί να συνεπάγεται σημαντική απώλεια εσόδων, παραβίαση συμφωνιών επιπέδου υπηρεσίας (SLA) και βλάβη της φήμης. Η αυτοματοποίηση της άμυνας, ώστε να μη βασίζεται σε ανθρώπινη παρέμβαση που εισάγει καθυστέρηση λεπτών, είναι επομένως όχι μόνο τεχνικά αλλά και επιχειρησιακά αναγκαία. Το σύστημα της διπλωματικής, ανιχνεύοντας και αντιδρώντας εντός του πρώτου παραθύρου παρατήρησης, ευθυγραμμίζεται με αυτή την ανάγκη.

Υποδομή των επιθέσεων και το οικονομικό μοντέλο

Η κατανόηση της υποδομής πίσω από τις σύγχρονες επιθέσεις φωτίζει και τα όρια της άμυνας. Οι μεγάλης κλίμακας επιθέσεις DDoS στηρίζονται σε δίκτυα παραβιασμένων συσκευών (botnets), τα οποία συχνά ενοικιάζονται ως υπηρεσία στη μαύρη αγορά. Το γεγονός αυτό μετατρέπει την επίθεση σε μια οικονομική συναλλαγή με κόστος και όφελος για τον επιτιθέμενο. Μια αποτελεσματική άμυνα δεν χρειάζεται απαραίτητα να είναι απόλυτη. Αρκεί να αυξήσει το κόστος της επιτυχούς επίθεσης πέρα από το αναμενόμενο όφελος. Υπό αυτό το πρίσμα, η ανάλυση αντίπαλης ανθεκτικότητας της διπλωματικής αποκτά πρόσθετη σημασία: δείχνοντας ότι η αποφυγή του ζωντανού μοντέλου απαιτεί είτε δραστική μείωση της ισχύος της επίθεσης είτε δαπανηρή υποδομή πολλαπλών πηγών, τεκμηριώνει ότι το σύστημα μετατοπίζει το οικονομικό ισοζύγιο εις βάρος του επιτιθέμενου.

Ο ρόλος του Διαδικτύου των Πραγμάτων

Η εκρηκτική διάδοση των συσκευών του Διαδικτύου των Πραγμάτων έχει μεταβάλει ριζικά το τοπίο των επιθέσεων. Πολλές τέτοιες συσκευές διατίθενται με αδύναμες ή προεπιλεγμένες ρυθμίσεις ασφαλείας, καθιστώντας τις εύκολο στόχο παραβίασης. Παραβιασμένες, εντάσσονται σε τεράστια botnets ικανά να εξαπολύσουν επιθέσεις πρωτοφανούς κλίμακας, όπως κατέδειξαν διαβόητες επιθέσεις της τελευταίας δεκαετίας. Το γεγονός αυτό έχει άμεση σημασία για τα SDN: η κλίμακα των σύγχρονων επιθέσεων καθιστά την ανθρώπινη παρέμβαση ανεπαρκή και επιβάλλει αυτοματοποιημένη, ταχεία άμυνα, ακριβώς το είδος άμυνας που προτείνει η παρούσα διπλωματική. Η ικανότητα του συστήματος να ανιχνεύει και να αντιμετωπίζει επιθέσεις σε χρόνο εντός του πρώτου παραθύρου παρατήρησης αποκτά ιδιαίτερη αξία σε ένα περιβάλλον όπου οι επιθέσεις μπορούν να κλιμακωθούν ακαριαία.

3.8 Μηχανισμοί άμυνας και ο ρόλος του IDS

Οι μηχανισμοί άμυνας έναντι των επιθέσεων σε SDN μπορούν να ταξινομηθούν σε τρεις μεγάλες κατηγορίες. Οι προληπτικοί μηχανισμοί (prevention) στοχεύουν στην αποτροπή της επίθεσης εξ αρχής, για παράδειγμα, μέσω αυθεντικοποίησης, ελέγχου πρόσβασης και κρυπτογράφησης του καναλιού ελέγχου. Οι ανιχνευτικοί μηχανισμοί (detection), στους οποίους εντάσσεται και το σύστημα της διπλωματικής, στοχεύουν στον έγκαιρο εντοπισμό μιας επίθεσης σε εξέλιξη. Οι μηχανισμοί απόκρισης (response) στοχεύουν στον περιορισμό της ζημιάς μετά την ανίχνευση, για παράδειγμα, μέσω απόρριψης κίνησης, rate limiting ή απομόνωσης του επιτιθέμενου. Η παρούσα διπλωματική συνδυάζει ανίχνευση και απόκριση σε έναν ενιαίο, αυτοματοποιημένο βρόχο, ενώ ενσωματώνει και προληπτικά στοιχεία (αυθεντικοποίηση τηλεμετρίας, rate limiting).

Ο ρόλος του IDS στην αρχιτεκτονική ασφάλειας

Ένα σύστημα ανίχνευσης εισβολών δεν λειτουργεί απομονωμένα αλλά ως μέρος μιας ευρύτερης αρχιτεκτονικής ασφάλειας βάθους (defense in depth). Στα SDN, το IDS αποκτά ένα μοναδικό πλεονέκτημα: χάρη στην κεντριοποιημένη εικόνα του δικτύου και στην προγραμματισιμότητα, μπορεί όχι μόνο να ανιχνεύει αλλά και να επιβάλλει άμεσα την απόκρισή του, χωρίς την ανάγκη εξωτερικού μηχανισμού. Αυτή η στενή σύζευξη ανίχνευσης και επιβολής, που στα παραδοσιακά δίκτυα απαιτεί ξεχωριστές συσκευές και χειροκίνητη διαμόρφωση, αποτελεί ένα από τα σημαντικότερα δομικά πλεονεκτήματα της προσέγγισης SDN για την ασφάλεια.

4. Μέθοδοι Ανίχνευσης και Μηχανική Μάθηση

4.1 Παραδοσιακές μέθοδοι και οι αδυναμίες τους

Τα κλασικά συστήματα ανίχνευσης εισβολών διακρίνονται σε δύο μεγάλες κατηγορίες. Τα συστήματα βάσει υπογραφών (signature-based), όπως τα Snort και Suricata [8], συγκρίνουν την κίνηση με μια βάση γνωστών προτύπων επίθεσης. Η προσέγγιση αυτή είναι ακριβής για γνωστές επιθέσεις αλλά αδυνατεί εξ ορισμού να ανιχνεύσει άγνωστες (zero-day) απειλές και απαιτεί συνεχή, χειροκίνητη ενημέρωση των υπογραφών. Τα συστήματα βάσει κατωφλίων (threshold-based) ενεργοποιούν συναγερμό όταν μια μετρική (π.χ. ρυθμός πακέτων) ξεπεράσει ένα προκαθορισμένο όριο. Είναι απλά αλλά επιρρεπή σε ψευδώς θετικά και εύκολα παρακάμψιμα από επιθέσεις χαμηλής έντασης.

4.2 Ανίχνευση βασισμένη σε Μηχανική Μάθηση: επισκόπηση και μηχανισμοί των αλγορίθμων

Η Μηχανική Μάθηση προσφέρει μια δυναμική εναλλακτική: αντί για στατικούς κανόνες, τα μοντέλα μαθαίνουν τα στατιστικά πρότυπα της νόμιμης και της κακόβουλης κίνησης από δεδομένα και γενικεύουν σε νέες παραλλαγές. Η επισκόπηση των Sultana κ.ά. [9] τεκμηριώνει την αυξανόμενη υιοθέτηση ML-based IDS σε περιβάλλοντα SDN, επειδή τα στατιστικά ροών που παρέχει το OpenFlow αποτελούν φυσική είσοδο για τέτοια μοντέλα. Στην παρούσα διπλωματική αξιοποιούνται δύο συμπληρωματικά παραδείγματα: η επιβλεπόμενη ταξινόμηση (supervised classification), όπου το μοντέλο εκπαιδεύεται σε δεδομένα με ετικέτες, και η μη επιβλεπόμενη ανίχνευση ανωμαλιών (unsupervised anomaly detection), όπου το μοντέλο μαθαίνει μόνο τη «φυσιολογική» κατάσταση και εντοπίζει αποκλίσεις.

Επισκόπηση αλγορίθμων

Στη συγκριτική μελέτη του Κεφαλαίου 6 αξιολογούνται οι ακόλουθοι αλγόριθμοι:

- **Random Forest:** σύνολο (ensemble) δέντρων απόφασης με ψηφοφορία. Είναι ισχυρός, ανθεκτικός στον θόρυβο και ιδιαίτερα αποδοτικός σε δομημένα δεδομένα ροών.
- **Decision Tree:** ενιαίο δέντρο κανόνων, ερμηνεύσιμο αλλά επιρρεπές σε υπερπροσαρμογή.

- **K-Nearest Neighbors (KNN):** ταξινόμηση βάσει εγγύτητας στον χώρο των χαρακτηριστικών.
- **Support Vector Machine (SVM):** εύρεση βέλτιστου διαχωριστικού υπερεπιπέδου με πυρήνα RBF.
- **Logistic Regression:** γραμμικός ταξινομητής, χρήσιμος ως βάση αναφοράς (baseline).
- **Multi-Layer Perceptron (MLP):** νευρωνικό δίκτυο πρόσθιας τροφοδότησης με κρυφά επίπεδα.
- **Deep MLP και 1D-CNN:** βαθύτερες αρχιτεκτονικές που εξετάζονται ως προς την απόδοσή τους σε δομημένα (tabular) δεδομένα.

Μηχανισμοί λειτουργίας των αλγορίθμων

Για την πληρότητα της ανάλυσης, παρατίθεται συνοπτικά ο μηχανισμός λειτουργίας καθενός από τους αλγορίθμους που συγκρίνονται. Το Random Forest κατασκευάζει πλήθος δέντρων απόφασης, καθένα εκπαιδευμένο σε τυχαίο υποσύνολο δειγμάτων και χαρακτηριστικών (bagging και τυχαία επιλογή χαρακτηριστικών). Η τελική πρόβλεψη προκύπτει από ψηφοφορία των δέντρων. Η στοχαστικότητα αυτή μειώνει τη διακύμανση και καθιστά το μοντέλο ανθεκτικό στον θόρυβο και στην υπερπροσαρμογή, εξηγώντας την κορυφαία του επίδοση στα δομημένα δεδομένα ροών.

Το Decision Tree, αντίθετα, είναι ένα ενιαίο δέντρο κανόνων. Είναι άκρως ερμηνεύσιμο αλλά επιρρεπές σε υπερπροσαρμογή, ιδίως σε βαθιά δέντρα. Ο K-Nearest Neighbors ταξινομεί κάθε νέο δείγμα βάσει της πλειοψηφίας των k πλησιέστερων γειτόνων του στον χώρο χαρακτηριστικών. Είναι απλός αλλά υπολογιστικά δαπανηρός κατά την πρόβλεψη, καθώς απαιτεί σύγκριση με όλο το σύνολο εκπαίδευσης. Το Support Vector Machine με πυρήνα RBF αναζητά το υπερεπίπεδο που μεγιστοποιεί το περιθώριο μεταξύ των κλάσεων σε έναν χώρο υψηλότερης διάστασης, προσφέροντας ισχυρή γενίκευση αλλά με μεγαλύτερο κόστος εκπαίδευσης.

Η Logistic Regression είναι ένας γραμμικός ταξινομητής που μοντελοποιεί την πιθανότητα κάθε κλάσης. Χρησιμοποιεί ως βάση αναφοράς και αναδεικνύει, μέσω της υποαπόδοσής της στο InSDN, την ανάγκη για μη γραμμικά μοντέλα σε πραγματικά δεδομένα. Το Multi-Layer Perceptron είναι νευρωνικό δίκτυο πρόσθιας τροφοδότησης με κρυφά επίπεδα και μη γραμμικές συναρτήσεις ενεργοποίησης, ικανό να μοντελοποιεί σύνθετες σχέσεις αλλά με μεγαλύτερη ευαισθησία στην επιλογή υπερπαραμέτρων. Τέλος, τα μοντέλα Βαθιάς Μάθησης (Deep MLP και 1D-CNN) εξετάζονται για να διαπιστωθεί κατά πόσον η

μεγαλύτερη χωρητικότητα τους αποδίδει σε δομημένα δεδομένα, συμπέρασμα που, όπως δείχνει το Κεφάλαιο 6, είναι αρνητικό, καθώς η απουσία χωρικής ή χρονικής δομής δεν αξιοποιεί τα πλεονεκτήματά τους.

Η θεωρία των μεθόδων συνόλου

Η επιτυχία των μεθόδων συνόλου, όπως το Random Forest, δεν είναι τυχαία αλλά θεμελιώνεται θεωρητικά. Η βασική ιδέα είναι ότι ο συνδυασμός πολλαπλών «αδύναμων» ή μέτριας ισχύος ταξινομητών, εφόσον αυτοί κάνουν ανεξάρτητα λάθη, μπορεί να παραγάγει έναν «ισχυρό» ταξινομητή με σημαντικά μειωμένο συνολικό σφάλμα. Στο Random Forest, η ανεξαρτησία των δέντρων ενισχύεται με δύο μηχανισμούς τυχαιότητας: την εκπαίδευση κάθε δέντρου σε διαφορετικό, τυχαία επιλεγμένο υποσύνολο δειγμάτων (bootstrap) και την εξέταση τυχαίου υποσυνόλου χαρακτηριστικών σε κάθε διαχωρισμό. Έτσι, τα δέντρα αποσυσχετίζονται, και ο μέσος όρος των προβλέψεών τους μειώνει τη διακύμανση χωρίς να αυξάνει τη μεροληψία.

Η ίδια αρχή εξηγεί γιατί το Random Forest είναι ανθεκτικό στον θόρυβο και στην υπερπροσαρμογή, χαρακτηριστικά που το καθιστούν ιδανικό για θορυβώδη δεδομένα ασφάλειας. Ταυτόχρονα, όμως, η ίδια αρχή φωτίζει και την ευπάθειά του σε αντίπαλες επιθέσεις: αν όλα τα δέντρα βασίζονται στα ίδια, περιορισμένα διαγνωστικά χαρακτηριστικά, τότε μια συντονισμένη διαταραχή αυτών των χαρακτηριστικών μπορεί να παραπλανήσει ολόκληρο το σύνολο ταυτόχρονα, ακριβώς το φαινόμενο του γκρεμού που παρατηρήθηκε πειραματικά.

4.3 Ο αλγόριθμος Isolation Forest και η μαθηματική του θεμελίωση

Ιδιαίτερη θέση στη διπλωματική κατέχει ο αλγόριθμος Isolation Forest [10], ο οποίος αποτελεί τη μηχανή ανίχνευσης του ζωντανού συστήματος. Σε αντίθεση με τους περισσότερους αλγορίθμους ανίχνευσης ανωμαλιών που μοντελοποιούν πρώτα τη φυσιολογική κατάσταση, ο Isolation Forest εκμεταλλεύεται την ίδια την ιδιότητα των ανωμαλιών: είναι λίγες και διαφορετικές, άρα «απομονώνονται» ευκολότερα. Κατασκευάζοντας τυχαία δέντρα διαχωρισμού, οι ανώμαλες παρατηρήσεις απαιτούν κατά μέσο όρο λιγότερους διαχωρισμούς για να απομονωθούν, δηλαδή έχουν μικρότερο μέσο βάθος. Το βασικό πλεονέκτημα του αλγορίθμου είναι η γραμμική υπολογιστική πολυπλοκότητα και η καταλληλότητά του για ανίχνευση χωρίς ετικέτες, ιδανική για ένα ζωντανό σύστημα που πρέπει να αποφασίζει σε πραγματικό χρόνο.

Μαθηματική θεμελίωση του Isolation Forest

Ο Isolation Forest κατασκευάζει ένα σύνολο από isolation trees, καθένα από τα οποία διαχωρίζει επαναληπτικά τα δεδομένα επιλέγοντας τυχαία ένα χαρακτηριστικό και ένα τυχαίο σημείο διαχωρισμού μεταξύ της ελάχιστης και της μέγιστης τιμής του. Το πλήθος των διαχωρισμών που απαιτούνται για την απομόνωση μιας παρατήρησης ισοδυναμεί με το μήκος διαδρομής από τη ρίζα έως το φύλλο. Καθώς οι ανωμαλίες είναι λίγες και διακριτές, απομονώνονται με λιγότερους διαχωρισμούς και έχουν μικρότερο μέσο μήκος διαδρομής. Η τιμή ανωμαλίας (anomaly score) ορίζεται ως $s(x, n) = 2^{-(E(h(x))/c(n))}$, όπου $E(h(x))$ το μέσο μήκος διαδρομής της παρατήρησης x στα δέντρα και $c(n)$ η μέση τιμή αναφοράς για n δείγματα. Τιμές κοντά στη μονάδα υποδεικνύουν ανωμαλία, ενώ τιμές αρκετά κάτω του 0,5 υποδεικνύουν φυσιολογικές παρατηρήσεις. Το βασικό πλεονέκτημα είναι η γραμμική πολυπλοκότητα ως προς το πλήθος των δειγμάτων και η ανεξαρτησία από ετικέτες, χαρακτηριστικά ιδανικά για ανίχνευση σε πραγματικό χρόνο.

4.4 Δημόσια σύνολα δεδομένων και κατηγορίες κίνησης

Η αξιολόγηση μοντέλων ML για ασφάλεια δικτύων απαιτεί αντιπροσωπευτικά σύνολα δεδομένων. Ιστορικά χρησιμοποιήθηκαν τα NSL-KDD και CICDDoS2019, τα οποία όμως δεν είναι ειδικά για SDN. Το σύνολο InSDN [11] σχεδιάστηκε ειδικά για περιβάλλοντα SDN και περιλαμβάνει τόσο νόμιμη κίνηση όσο και ευρύ φάσμα επιθέσεων (DoS, DDoS, probe, brute-force, web attacks), με χαρακτηριστικά εξαγόμενα από το εργαλείο CICFlowMeter. Η διπλωματική υιοθετεί τη δομή χαρακτηριστικών του InSDN/CICFlowMeter, ώστε το offline pipeline να είναι απευθείας συμβατό με το πραγματικό σύνολο.

Οι κατηγορίες κίνησης του συνόλου δεδομένων

Το σύνολο δεδομένων οργανώνεται σε πέντε κατηγορίες, καθεμία με διακριτό στατιστικό αποτύπωμα. Η κανονική κίνηση (Normal) αντιπροσωπεύει τη νόμιμη δραστηριότητα και χαρακτηρίζεται από μέτριους ρυθμούς πακέτων, ομαλούς χρόνους μεταξύ αφίξεων και ισορροπημένη κατανομή σημαιών TCP. Η κατηγορία DDoS αντιστοιχεί σε κατανεμημένες επιθέσεις πλημμύρας, με πολύ υψηλό ρυθμό πακέτων και σχεδόν μηδενική διακύμανση στους χρόνους άφιξης, ένδειξη μηχανικής, αυτοματοποιημένης προέλευσης. Η κατηγορία DoS μοιάζει με την DDoS αλλά προέρχεται από μεμονωμένη πηγή, γεγονός που εξηγεί τη στατιστική τους ομοιότητα και τη συγκέντρωση των λαθών ταξινόμησης μεταξύ τους.

Η κατηγορία Probe (σάρωση) χαρακτηρίζεται από πλήθος σύντομων ροών προς διαφορετικούς προορισμούς ή θύρες, με χαμηλό όγκο ανά ροή αλλά υψηλή διασπορά.

Τέλος, η κατηγορία BFA (Brute-Force Attack) αντιστοιχεί σε επαναλαμβανόμενες απόπειρες πρόσβασης, με χαρακτηριστικά μοτίβα μικρών, επαναλαμβανόμενων αιτημάτων. Η κατανόηση αυτών των αποτυπωμάτων φωτίζει τα ευρήματα της ανάλυσης SHAP: κάθε κατηγορία «ανιχνεύεται» κυρίως μέσω των χαρακτηριστικών που αποτυπώνουν την ιδιαίτερη φύση της.

4.5 Χαρακτηριστικά ροής: εξαγωγή, περιγραφή και επιλογή

Το CICFlowMeter μετατρέπει την ακατέργαστη κίνηση (πακέτα) σε διανύσματα χαρακτηριστικών ανά ροή. Κάθε ροή περιγράφεται από 24 χαρακτηριστικά, όπως η διάρκεια, ο αριθμός και το μέγεθος των πακέτων ανά κατεύθυνση, ο ρυθμός πακέτων και bytes ανά δευτερόλεπτο, οι χρόνοι μεταξύ διαδοχικών αφίξεων (inter-arrival times) και το πλήθος των σημαιών TCP (SYN, ACK, RST, FIN). Η επιλογή χαρακτηριστικών βάσει ροών, αντί βάσει πακέτων, είναι κρίσιμη: αποφεύγει τη βαθιά επιθεώρηση πακέτων, σέβεται την ιδιωτικότητα του περιεχομένου και είναι εγγενώς αποδοτική, καθώς τα στατιστικά αυτά παράγονται ούτως ή άλλως από τον μεταγωγέα. Όπως θα φανεί στην ανάλυση SHAP του Κεφαλαίου 6, η τυπική απόκλιση των χρόνων μεταξύ αφίξεων και ο ρυθμός πακέτων αναδεικνύονται στα πλέον διαγνωστικά χαρακτηριστικά για τις επιθέσεις πλημμύρας.

Τα 24 χαρακτηριστικά ροής

Ο ακόλουθος πίνακας παραθέτει το πλήρες σύνολο των 24 χαρακτηριστικών που εξάγονται ανά ροή, μαζί με τη δικτυακή τους ερμηνεία. Η ποσοτική συνεισφορά κάθε χαρακτηριστικού στην ανίχνευση, όπως προκύπτει από την ανάλυση SHAP, παρουσιάζεται και σχολιάζεται στο Κεφάλαιο 6 (ενότητα 6.3), ώστε τα αποτελέσματα να παραμένουν συγκεντρωμένα στο κεφάλαιο των πειραμάτων.

Χαρακτηριστικό (CICFlowMeter)	Δικτυακή ερμηνεία
Flow_IAT_Std	Τυπ. Απόκλιση IAT
Flow_Pkts_s	Πακέτα/s
Fwd_IAT_Mean	IAT Εμπρός
Pkt_Len_Mean	Μέσο Μήκος Πακέτου
Idle_Mean	Μέσος Χρόνος Αδράνειας
Bwd_IAT_Mean	IAT Πίσω
Pkt_Size_Avg	Μέσο Μέγεθος Πακέτου

Flow_IAT_Mean	Μέσο IAT
Pkt_Len_Std	Τυπ. Απόκλιση Μήκους
Init_Fwd_Win_Byts	Παράθυρο TCP Εμπρός
Active_Mean	Μέσος Χρόνος Ενεργός
TotLen_Bwd_Pkts	Bytes Πίσω
SYN_Flag_Cnt	SYN Flags
ACK_Flag_Cnt	ACK Flags
RST_Flag_Cnt	RST Flags
TotLen_Fwd_Pkts	Bytes Εμπρός
Fwd_Pkt_Len_Mean	Μέσο Μήκος Εμπρός
Down_Up_Ratio	Λόγος Down/Up
Tot_Bwd_Pkts	Πακέτα Πίσω
Bwd_Pkt_Len_Mean	Μέσο Μήκος Πίσω
FIN_Flag_Cnt	FIN Flags
Tot_Fwd_Pkts	Πακέτα Εμπρός
Flow_Duration	Διάρκεια Ροής
Flow_Byts_s	Bytes/s

Πίνακας 5: Τα 24 χαρακτηριστικά ροής της δομής CICFlowMeter/InSDN.

Επιλογή χαρακτηριστικών και μείωση διάστασης

Η επιλογή του κατάλληλου συνόλου χαρακτηριστικών είναι εξίσου σημαντική με την επιλογή του αλγορίθμου. Ένα υπερβολικά μεγάλο σύνολο χαρακτηριστικών αυξάνει το υπολογιστικό κόστος και τον κίνδυνο υπερπροσαρμογής, ενώ ένα υπερβολικά μικρό μπορεί να στερεί από το μοντέλο κρίσιμη πληροφορία. Η ανάλυση σημαντικότητας, τόσο μέσω των εγγενών μετρικών των δέντρων όσο και μέσω της ερμηνεύσιμης προσέγγισης SHAP, επιτρέπει τον εντοπισμό των πλέον διαγνωστικών χαρακτηριστικών και, κατ' επέκταση, τη δυνατότητα μείωσης της διάστασης χωρίς σημαντική απώλεια απόδοσης. Στο ζωντανό σύστημα, η επιλογή ενός μικρού συνόλου συγκεντρωτικών, συμπεριφορικών χαρακτηριστικών όχι μόνο μειώνει το υπολογιστικό κόστος αλλά, όπως τεκμηριώθηκε, ενισχύει και την ανθεκτικότητα έναντι αντίπαλων επιθέσεων.

4.6 Μετρικές αξιολόγησης και καμπύλες ROC

Η αξιολόγηση των ταξινομητών βασίζεται σε τέσσερις θεμελιώδεις μετρικές, οι οποίες προκύπτουν από τον πίνακα σύγχυσης. Η ακρίβεια (accuracy) εκφράζει το ποσοστό των ορθών προβλέψεων επί του συνόλου. Η ορθότητα (precision) εκφράζει το ποσοστό των πραγματικά θετικών μεταξύ όσων χαρακτηρίστηκαν θετικά, και είναι κρίσιμη για τον περιορισμό των ψευδώς θετικών, δηλαδή για την αποφυγή του μπλοκαρίσματος νόμιμης κίνησης. Η ανάκληση (recall) εκφράζει το ποσοστό των πραγματικά θετικών που εντοπίστηκαν, και είναι κρίσιμη για να μη διαφύγει επίθεση. Το F1-score, ως αρμονικός μέσος ορθότητας και ανάκλησης, ισορροπεί τους δύο αυτούς στόχους και αποτελεί την κύρια συγκριτική μετρική της διπλωματικής. Τέλος, η καμπύλη ROC και το εμβαδόν κάτω από αυτήν (AUC) αποτυπώνουν την ικανότητα διάκρισης του μοντέλου ανεξαρτήτως συγκεκριμένου κατωφλίου.

Στο πλαίσιο ενός συστήματος άμυνας δικτύου, η ισορροπία ορθότητας-ανάκλησης έχει άμεση επιχειρησιακή σημασία. Ένα σύστημα με χαμηλή ορθότητα παράγει πολλά ψευδώς θετικά και, μπλοκάροντας νόμιμους χρήστες, προκαλεί ουσιαστικά το ίδιο αποτέλεσμα με μια επίθεση άρνησης εξυπηρέτησης. Αντίστροφα, χαμηλή ανάκληση σημαίνει διαφυγή επιθέσεων. Γι' αυτό η διπλωματική δίνει έμφαση όχι μόνο στην ακρίβεια αλλά και στον περιορισμό των ψευδώς θετικών, με ιδιαίτερη αναφορά στο σενάριο αποκλειστικά νόμιμης κίνησης, όπου δεν καταγράφηκαν ψευδώς θετικά.

Μετρικές αξιολόγησης: τυπικός ορισμός

Οι μετρικές που χρησιμοποιήθηκαν ορίζονται αυστηρά μέσω των τεσσάρων μεγεθών του πίνακα σύγχυσης: των αληθώς θετικών (TP), των αληθώς αρνητικών (TN), των ψευδώς θετικών (FP) και των ψευδώς αρνητικών (FN). Η ακρίβεια ορίζεται ως $(TP+TN)/(TP+TN+FP+FN)$, δηλαδή το ποσοστό των ορθών αποφάσεων. Η ορθότητα (precision) ορίζεται ως $TP/(TP+FP)$, εκφράζοντας την αξιοπιστία των θετικών προβλέψεων. Η ανάκληση (recall) ορίζεται ως $TP/(TP+FN)$, εκφράζοντας την κάλυψη των πραγματικών θετικών. Το F1-score ορίζεται ως ο αρμονικός μέσος $2 \cdot (\text{precision} \cdot \text{recall}) / (\text{precision} + \text{recall})$, ισορροπώντας τους δύο στόχους. Ο αρμονικός μέσος επιλέγεται αντί του αριθμητικού διότι τιμωρεί δυσανάλογα τις ακραίες ανισορροπίες: ένα μοντέλο με υψηλή ορθότητα αλλά χαμηλή ανάκληση (ή αντίστροφα) λαμβάνει χαμηλό F1.

Ένα αριθμητικό παράδειγμα αποσαφηνίζει τη σημασία τους. Έστω ένα σύστημα που, σε 1.000 ροές εκ των οποίων 100 είναι επιθέσεις, εντοπίζει σωστά τις 95 (TP=95, FN=5) αλλά χαρακτηρίζει και 10 νόμιμες ως επιθέσεις (FP=10). Τότε η ορθότητα είναι $95/105 \approx 0,905$, η ανάκληση $95/100 = 0,95$ και το F1 $\approx 0,927$. Στο πλαίσιο ενός συστήματος άμυνας, τα δέκα ψευδώς θετικά αντιστοιχούν σε δέκα νόμιμους χρήστες που θα μπλοκάρονταν άδικα. Γι' αυτό η διπλωματική δίνει έμφαση όχι μόνο στην ακρίβεια αλλά και στον περιορισμό των ψευδώς θετικών, με ιδιαίτερη αναφορά στο σενάριο αποκλειστικά νόμιμης κίνησης, όπου δεν καταγράφηκαν ψευδώς θετικά.

Καμπύλες ROC και precision-recall

Η αξιολόγηση ενός ταξινομητή δεν εξαντλείται σε μια μεμονωμένη τιμή μετρικής, καθώς αυτή εξαρτάται από το επιλεγμένο κατώφλι απόφασης. Οι καμπύλες ROC αποτυπώνουν τη σχέση μεταξύ του ποσοστού αληθώς θετικών και του ποσοστού ψευδώς θετικών σε όλο το φάσμα κατωφλίων, και το εμβαδόν κάτω από αυτές (AUC) συνοψίζει τη συνολική διακριτική ικανότητα. Σε σύνολα με έντονη ανισορροπία, ωστόσο, οι καμπύλες precision-recall μπορεί να είναι πιο ενημερωτικές, καθώς εστιάζουν στην απόδοση επί της μειοψηφικής κλάσης, που στα δεδομένα ασφάλειας είναι συνήθως οι επιθέσεις. Η χρήση πολλαπλών, συμπληρωματικών εργαλείων αξιολόγησης διασφαλίζει μια σφαιρική και μη παραπλανητική εικόνα της απόδοσης, αποφεύγοντας τα συμπεράσματα που θα προέκυπταν από μια μονοδιάστατη θεώρηση.

4.7 Σχετική βιβλιογραφία και αρχιτεκτονικές συστημάτων ανίχνευσης

Η ανίχνευση εισβολών σε SDN με Μηχανική Μάθηση αποτελεί ενεργό ερευνητικό πεδίο. Οι Braga κ.ά. [1] πρότειναν έναν ελαφρύ ανιχνευτή DDoS βασισμένο σε αυτο-οργανούμενους χάρτες (SOM) πάνω σε χαρακτηριστικά ροών NOX/OpenFlow. Η εργασία τους θεμελίωσε την ιδέα ότι τα στατιστικά ροών, τα οποία ο μεταγωγέας παράγει έτσι κι αλλιώς, αρκούν για αποτελεσματική ανίχνευση χωρίς βαθιά επιθεώρηση πακέτων. Η παρούσα διπλωματική υιοθετεί το ίδιο θεμελιώδες σκεπτικό, επεκτείνοντάς το με σύγχρονους αλγορίθμους συνόλου και με αυτόματη αντιμετώπιση.

Η επισκόπηση των Sultana κ.ά. [9] κατηγοριοποιεί τις προσεγγίσεις ML-based IDS σε SDN και επισημαίνει τόσο την υψηλή ακρίβεια των μεθόδων όσο και τα ανοιχτά ζητήματα κλιμάκωσης και ανθεκτικότητας. Οι Scott-Hayward κ.ά. [6] παρέχουν τη συστηματικότερη επισκόπηση ασφάλειας SDN, ταξινομώντας τις απειλές ανά επίπεδο και τεκμηριώνοντας

τον ρόλο του ελεγκτή ως σημείου συγκέντρωσης ρίσκου. Οι Shin & Gu [12] ήταν από τους πρώτους που κατέδειξαν πειραματικά τη σκοπιμότητα επιθέσεων στο control plane, ενώ οι Elsayed κ.ά. [11] κάλυψαν ένα σημαντικό κενό δημοσιεύοντας το InSDN, το πρώτο σύνολο δεδομένων ειδικά σχεδιασμένο για SDN.

Σε σχέση με την παραπάνω βιβλιογραφία, η συνεισφορά της παρούσας διπλωματικής έγκειται στη σύζευξη offline σύγκρισης μοντέλων και ζωντανής, end-to-end λειτουργίας μέσα σε ένα ενιαίο σύστημα, καθώς και στην πειραματική διερεύνηση της αντίπαλης ανθεκτικότητας, μια διάσταση που συχνά παραλείπεται στις εφαρμοσμένες μελέτες IDS.

Αρχιτεκτονικές συστημάτων ανίχνευσης εισβολών

Τα συστήματα ανίχνευσης εισβολών ταξινομούνται κατά δύο βασικούς άξονες. Ως προς τη θέση παρακολούθησης, διακρίνονται σε δικτυακά (Network-based IDS, NIDS), που παρακολουθούν την κίνηση του δικτύου, και σε βασισμένα σε host (Host-based IDS, HIDS), που παρακολουθούν τη δραστηριότητα μεμονωμένων συστημάτων. Το σύστημα της διπλωματικής ανήκει στην πρώτη κατηγορία, καθώς αναλύει στατιστικά ροών του δικτύου. Ως προς τη μέθοδο ανίχνευσης, διακρίνονται σε βασισμένα σε κατάχρηση (misuse/signature-based), που εντοπίζουν γνωστά πρότυπα, και σε βασισμένα σε ανωμαλία (anomaly-based), που εντοπίζουν αποκλίσεις από τη φυσιολογική συμπεριφορά. Η προσέγγιση της διπλωματικής συνδυάζει και τις δύο φιλοσοφίες: το επιβλεπόμενο σκέλος προσεγγίζει τη λογική της κατάχρησης, ενώ το μη επιβλεπόμενο σκέλος (Isolation Forest) υλοποιεί καθαρή ανίχνευση ανωμαλιών.

4.8 Προεπεξεργασία, ρύθμιση υπερπαραμέτρων και γενίκευση

Η ποιότητα της προεπεξεργασίας καθορίζει σε μεγάλο βαθμό την τελική απόδοση. Τα χαρακτηριστικά εισόδου του μοντέλου είναι αριθμητικά χαρακτηριστικά ροής που προκύπτουν από τη δομή CICFlowMeter/InSDN. Η κωδικοποίηση εφαρμόστηκε αποκλειστικά στις ετικέτες των κλάσεων (label encoding) και όχι σε αναγνωριστικά όπως διευθύνσεις IP, ονόματα hosts ή θύρες. Τα τελευταία δεν χρησιμοποιήθηκαν ως χαρακτηριστικά εισόδου, ώστε να μην εισαχθούν τεχνητές αριθμητικές αποστάσεις σε αλγορίθμους ευαίσθητους στη μετρική, όπως ο KNN και το SVM. Πέραν της κωδικοποίησης ετικετών, το pipeline εκτελεί καθαρισμό των δεδομένων (αφαίρεση μη έγκυρων ή ελλιπών εγγραφών) και κανονικοποίηση των αριθμητικών χαρακτηριστικών με StandardScaler, ώστε όλα να έχουν μηδενικό μέσο και μοναδιαία διακύμανση. Ο

διαχωρισμός σε σύνολα εκπαίδευσης και ελέγχου είναι στρωματοποιημένος, διατηρώντας τις αναλογίες των κλάσεων σε όλα τα υποσύνολα.

Η ανισορροπία κλάσεων, η υπερεκπροσώπηση της νόμιμης κίνησης έναντι ορισμένων σπάνιων επιθέσεων, αποτελεί γνωστή πρόκληση στα δεδομένα ασφάλειας. Στην παρούσα διπλωματική, η επιλογή μετρικών που δεν παραπλανώνται από την ανισορροπία (precision, recall, F1 αντί μόνο accuracy) και η χρήση διασταυρούμενης επικύρωσης μετριάζουν τον κίνδυνο παραπλανητικών συμπερασμάτων. Στο πραγματικό σύνολο InSDN, όπου η ανισορροπία είναι εντονότερη, η πτώση των μετρικών σε σχέση με το συνθετικό σύνολο είναι ενδεικτική αυτής ακριβώς της δυσκολίας.

Ισοζύγιο μεροληψίας-διακύμανσης

Η επιλογή μοντέλου συνδέεται στενά με το κλασικό ισοζύγιο μεροληψίας-διακύμανσης. Ένα υπερβολικά απλό μοντέλο, όπως η Logistic Regression, εμφανίζει υψηλή μεροληψία: δεν μπορεί να αποτυπώσει τις μη γραμμικές σχέσεις των δεδομένων, γι' αυτό και υποαποδίδει στο πραγματικό InSDN. Ένα υπερβολικά σύνθετο μοντέλο, όπως ένα βαθύ δέντρο απόφασης, εμφανίζει υψηλή διακύμανση: προσαρμόζεται στον θόρυβο των δεδομένων εκπαίδευσης και γενικεύει άσχημα. Το Random Forest επιτυγχάνει την ιδανική ισορροπία, συνδυάζοντας πολλά δέντρα υψηλής διακύμανσης ώστε, μέσω της μέσης τιμής, να μειώνεται η συνολική διακύμανση χωρίς αύξηση της μεροληψίας. Η θεωρητική αυτή ιδιότητα εξηγεί την εμπειρική υπεροχή του, τόσο στο συνθετικό όσο και στο πραγματικό σύνολο.

Μεθοδολογία ρύθμισης υπερπαραμέτρων

Η επίτευξη της βέλτιστης απόδοσης ενός μοντέλου απαιτεί προσεκτική ρύθμιση των υπερπαραμέτρων του. Για το Random Forest, οι κρίσιμες υπερπαραμέτροι περιλαμβάνουν το πλήθος των δέντρων, το μέγιστο βάθος και το πλήθος χαρακτηριστικών ανά διαχωρισμό. Για τον Isolation Forest, όπως τεκμηριώθηκε, οι κρίσιμες παράμετροι είναι το πλήθος των δέντρων, το μέγεθος δείγματος και ο βαθμός μόλυνσης. Για τον Isolation Forest η ρύθμιση πραγματοποιήθηκε με εξαντλητική αναζήτηση σε πλέγμα τιμών: δοκιμάστηκαν και οι 108 συνδυασμοί που προκύπτουν από τέσσερις τιμές για το πλήθος των δέντρων, τρεις για το μέγεθος δείγματος, τρεις για τον βαθμό μόλυνσης και τρεις για το ποσοστό χαρακτηριστικών, με κριτήριο επιλογής το ROC-AUC σε ανεξάρτητο σύνολο ελέγχου, καθώς η εκπαίδευση του μοντέλου γίνεται αποκλειστικά σε φυσιολογική κίνηση. Για το Random Forest, όπου ο χώρος υπερπαραμέτρων είναι σημαντικά μεγαλύτερος,

προτιμήθηκε τυχαιοποιημένη αναζήτηση (randomized search) με είκοσι πέντε δειγματοληπτούμενες διαμορφώσεις, καθεμία από τις οποίες αξιολογήθηκε με τριπλή στρωματοποιημένη διασταυρούμενη επικύρωση, ώστε η επιλογή να μη βασίζεται σε ένα μεμονωμένο, ενδεχομένως τυχαίο, διαχωρισμό. Η τυχαιοποιημένη αναζήτηση επιτυγχάνει ποιότητα λύσης συγκρίσιμη με την εξαντλητική, με σαφώς μικρότερο υπολογιστικό κόστος όταν ο χώρος αναζήτησης είναι υψηλής διάστασης. Και στις δύο περιπτώσεις η διαδικασία μειώνει τον κίνδυνο υπερπροσαρμογής στις υπερπαραμέτρους και ενισχύει τη γενίκευση.

Καθοριστική για την αξιοπιστία της αξιολόγησης είναι η αυστηρή διάκριση μεταξύ των δεδομένων εκπαίδευσης και ελέγχου. Στην παρούσα διπλωματική εφαρμόζεται στρωματοποιημένος διαχωρισμός 70% προς 30%, με το σύνολο ελέγχου να παραμένει αόρατο κατά τη διάρκεια της εκπαίδευσης, ενώ τον ρόλο του συνόλου επικύρωσης επιτελούν οι πτυχές της διασταυρούμενης επικύρωσης κατά τη ρύθμιση των υπερπαραμέτρων και, στα νευρωνικά δίκτυα, εσωτερικό υποσύνολο επικύρωσης ίσο με το 20% των δεδομένων εκπαίδευσης. Ο κανονικοποιητής προσαρμόζεται αποκλειστικά στα δεδομένα εκπαίδευσης και εφαρμόζεται αμετάβλητος στο σύνολο ελέγχου, ώστε να αποκλείεται η μεταφορά στατιστικής πληροφορίας από το ένα σύνολο στο άλλο. Η παράβλεψη των αρχών αυτών, η λεγόμενη διαρροή δεδομένων (data leakage), αποτελεί συχνή πηγή υπερεκτιμημένων αποτελεσμάτων στη βιβλιογραφία.

Οφείλει, ωστόσο, να επισημανθεί ένας ουσιώδης περιορισμός που αφορά ειδικά το σύνολο InSDN. Οι επιθέσεις πλημμύρας παράγουν εκ φύσεως πανομοιότυπες ροές: το 51,7% των εγγραφών του συνόλου αποτελούν ακριβή διπλότυπα σε επίπεδο διανύσματος χαρακτηριστικών, με το ποσοστό να ανέρχεται στο 99,3% για την κλάση DDoS και στο 45,7% για την κλάση Probe. Η αφαίρεση των διπλότυπων θα εξάλειφε σχεδόν ολόκληρη την κλάση DDoS και θα καθιστούσε το σύνολο μη αντιπροσωπευτικό του ίδιου του φαινομένου που μελετάται. Για τον λόγο αυτό διατηρήθηκαν. Ως συνέπεια όμως του τυχαίου διαχωρισμού, πανομοιότυπα διανύσματα εμφανίζονται τόσο στο σύνολο εκπαίδευσης όσο και στο σύνολο ελέγχου, γεγονός που ευνοεί την απομνημόνευση και συνεισφέρει στις πολύ υψηλές τιμές ορθότητας, άνω του 0,98, που παρατηρούνται στο InSDN. Οι τιμές αυτές δεν πρέπει επομένως να ερμηνεύονται ως ένδειξη τέλει γενίκευσης. Ως πλέον αντιπροσωπευτικό μέτρο απόδοσης υιοθετείται το μακρο-σταθμισμένο F1, το οποίο αποδίδει ίσο βάρος σε όλες τις κλάσεις και αναδεικνύει τη δυσκολία στις μειοψηφικές κατηγορίες, όπως η BFA με μόλις 1.405 δείγματα. Ο

αυστηρότερος διαχωρισμός, με ομαδοποίηση ανά ροή ή με χρονική διάταξη των δεδομένων, προτείνεται ως κατεύθυνση μελλοντικής εργασίας.

Γενίκευση και μετατόπιση εννοιών

Μια θεμελιώδης πρόκληση για κάθε σύστημα Μηχανικής Μάθησης που λειτουργεί σε πραγματικό περιβάλλον είναι η μετατόπιση εννοιών (concept drift): η σταδιακή μεταβολή των στατιστικών ιδιοτήτων της κίνησης με τον χρόνο. Η νόμιμη κίνηση ενός δικτύου εξελίσσεται καθώς αλλάζουν οι εφαρμογές, οι συνήθειες των χρηστών και η υποδομή, ενώ οι επιθέσεις εξελίσσονται καθώς οι επιτιθέμενοι επινοούν νέες τεχνικές. Ένα μοντέλο εκπαιδευμένο σε παλαιότερα δεδομένα ενδέχεται σταδιακά να χάσει την ακρίβειά του. Η αντιμετώπιση της πρόκλησης αυτής απαιτεί μηχανισμούς παρακολούθησης της απόδοσης και περιοδικής επανεκπαίδευσης. Το μη επιβλεπόμενο μοντέλο της διπλωματικής, που μαθαίνει τη φυσιολογική κατάσταση, προσφέρει εδώ ένα σχετικό πλεονέκτημα, καθώς μπορεί να επαναπροσαρμοστεί στη μεταβαλλόμενη έννοια της «κανονικότητας» με σχετική ευκολία.

4.9 Ζητήματα ιδιωτικότητας και δεοντολογίας

Η ανάλυση δικτυακής κίνησης εγείρει ζητήματα ιδιωτικότητας. Ένα σημαντικό πλεονέκτημα της προσέγγισης βάσει ροών, έναντι της βαθιάς επιθεώρησης πακέτων, είναι ότι δεν απαιτεί πρόσβαση στο περιεχόμενο των επικοινωνιών: τα στατιστικά ροών (πλήθος πακέτων, μεγέθη, χρόνοι) είναι μεταδεδομένα και όχι δεδομένα χρήστη. Έτσι, η μέθοδος σέβεται εγγενώς την ιδιωτικότητα του περιεχομένου, ενώ παραμένει αποτελεσματική. Από δεοντολογικής άποψης, η αυτοματοποιημένη απόρριψη κίνησης απαιτεί προσοχή ώστε να μην πλήττει νόμιμους χρήστες. Η ελαχιστοποίηση των ψευδώς θετικών, ιδίως στο σενάριο αποκλειστικά νόμιμης κίνησης όπου δεν καταγράφηκαν ψευδώς θετικά, αποτελεί όχι μόνο τεχνική αλλά και δεοντολογική απαίτηση.

4.10 Εκδόσεις και εξέλιξη του OpenFlow

Το πρωτόκολλο OpenFlow έχει εξελιχθεί μέσα από διαδοχικές εκδόσεις. Η έκδοση 1.0 εισήγαγε τον ενιαίο πίνακα ροών και τα βασικά πεδία ταιριάσματος. Η έκδοση 1.1 πρόσθεσε τη διοχέτευση πολλαπλών πινάκων και τους πίνακες ομάδων. Οι επόμενες εκδόσεις (1.2-1.5) διεύρυναν τα πεδία ταιριάσματος, βελτίωσαν τη διαχείριση σφαλμάτων και πρόσθεσαν λειτουργίες όπως τα meters για rate limiting, χαρακτηριστικό άμεσα σχετικό με την αντιμετώπιση της επίθεσης κορεσμού control plane που μελετάται στη διπλωματική. Η επίγνωση της εξέλιξης αυτής είναι σημαντική, καθώς οι δυνατότητες

άμυνας ενός SDN εξαρτώνται άμεσα από την έκδοση του πρωτοκόλλου που υποστηρίζει το υλικό.

5. Μεθοδολογία και Υλοποίηση

Η υλοποίηση του συστήματος χωρίζεται σε δύο συμπληρωματικές μεθόδους. Η Μέθοδος Β αφορά την offline ανάλυση ροών με Μηχανική Μάθηση σε δεδομένα δομής InSDN, ενώ η Μέθοδος Α αφορά τη ζωντανή ανίχνευση και αντιμετώπιση μέσα σε προσομοιωμένο δίκτυο SDN. Ολόκληρος ο κώδικας αναπτύχθηκε σε γλώσσα Python και οργανώνεται σε ένα αναπαραγώγιμο περιβάλλον βασισμένο σε Docker.

5.1 Συνολική αρχιτεκτονική του συστήματος

Το ζωντανό σύστημα αποτελείται από τέσσερα συνεργαζόμενα δομικά στοιχεία, τα οποία εκτελούνται ως απομονωμένα containers και ενορχηστρώνονται μέσω Docker Compose:

Στοιχείο	Ρόλος
sdn_controller (Flask, θύρα 9000)	Μηχανή άμυνας Isolation Forest. Εκθέτει REST endpoints τηλεμετρίας, πίνακα ροών, τοπολογίας, στατιστικών και επαναφοράς.
sdn_dashboard (Dash/Cytoscape, θύρα 8050)	Οπτικοποίηση τοπολογίας και κίνησης σε πραγματικό χρόνο.
sdn_switch	Μεταγωγέας overlay σε επίπεδο εφαρμογής.
sdn_mininet (Mininet + OVS, privileged)	Εκτελεί το ζωντανό σενάριο με πραγματικά πακέτα.

Πίνακας 6: Τα τέσσερα containers του ζωντανού συστήματος και ο ρόλος τους.

Η ροή λειτουργίας υλοποιεί έναν κλειστό βρόχο εποπτείας-απόφασης-δράσης: ο μεταγωγέας παρέχει στατιστικά θυρών, ο ελεγκτής τα αναλύει σε πραγματικό χρόνο με τη μηχανή Isolation Forest και, όταν εντοπίσει επίθεση, επαναπρογραμματίζει το δίκτυο εγκαθιστώντας κανόνα απόρριψης.

5.2 Αρχιτεκτονική ελέγχου: υβριδικό μοντέλο SDN

Η υλοποίηση ακολουθεί υβριδική αρχιτεκτονική SDN. Η βασική προώθηση πακέτων εκτελείται από τον Open vSwitch, ο οποίος λειτουργεί σε failMode=standalone, ενώ ο ελεγκτής λειτουργεί ως λογικά κεντριοποιημένη εφαρμογή ασφαλείας: συλλέγει τηλεμετρία, εκτελεί ανίχνευση ανωμαλιών και εγκαθιστά κανόνες απόρριψης μέσω μηχανισμών συμβατών με τη σημασιολογία OpenFlow (εργαλείο ovs-ofctl και REST τηλεμετρία). Με τον τρόπο αυτό διατηρείται ο διαχωρισμός επιπέδου ελέγχου και

επιπέδου δεδομένων, χωρίς η υλοποίηση να εξαρτάται από πλήρη reactive OpenFlow controller ο οποίος θα λάμβανε αποφάσεις ανά νέα ροή μέσω Packet-In/Flow-Mod. Παρά τη διαφορά αυτή στον μηχανισμό, η αρχιτεκτονική διατηρεί και τους τέσσερις πυλώνες του ορισμού του SDN [13]:

1. Διαχωρισμός επιπέδου ελέγχου και δεδομένων: ο ελεγκτής (Flask) είναι φυσικά και λογικά διαχωρισμένος από τον μεταγωγέα (OVS). Καμία απόφαση ασφαλείας δεν λαμβάνεται στο επίπεδο δεδομένων.
2. Λογικά κεντριοποιημένος έλεγχος με καθολική εποπτεία: ο ελεγκτής συγκεντρώνει τηλεμετρία από το σύνολο των θυρών και διατηρεί ενιαία εικόνα του δικτύου, επί της οποίας εκτελείται η μηχανή ανίχνευσης.
3. Προγραμματιζόμενο επίπεδο δεδομένων: όταν μια ροή χαρακτηριστεί κακόβουλη, ο ελεγκτής εγκαθιστά κανόνα υψηλής προτεραιότητας (priority=100, ip, nw_src=<attacker>, actions=drop), η ίδια σημασιολογία match-action με ένα OpenFlow Flow-Mod.
4. Κλειστός βρόχος εποπτείας-απόφασης-δράσης: η ροή Data Collection → Inference → Automated Mitigation υλοποιεί πλήρως τον κύκλο ελέγχου μιας εφαρμογής ασφαλείας SDN.

Η επικοινωνία ελεγκτή-μεταγωγέα πραγματοποιείται μέσω του εργαλείου ovs-ofctl, το οποίο υλοποιεί εσωτερικά το πρωτόκολλο OpenFlow. Κατά συνέπεια, τα ανταλλασσόμενα μηνύματα (αίτηση στατιστικών θυρών, εγκατάσταση κανόνων) είναι σημασιολογικά ταυτόσημα με ένα συμβατικό OpenFlow southbound API. Η μόνη διαφορά έγκειται στον μηχανισμό μεταφοράς (τοπική κλήση αντί μόνιμης σύνδεσης TCP).

5.2.1 Αιτιολόγηση της σχεδιαστικής επιλογής

Η επιλογή του υβριδικού μοντέλου έναντι του αμιγώς αντιδραστικού βασίστηκε σε δύο άξονες. Πρώτον, σε λόγους επιδόσεων και ανθεκτικότητας: στο αμιγώς αντιδραστικό μοντέλο ο ελεγκτής αποτελεί σημείο συμφόρησης και μοναδικό σημείο αποτυχίας, ενώ στο υβριδικό η βασική συνδεσιμότητα διατηρείται ακόμη και αν ο ελεγκτής δεχθεί πίεση. Δεύτερον, σε πρακτικούς λόγους: ο ελεγκτής Ryu, παρότι διαδεδομένος, δεν συντηρείται πλέον ενεργά και παρουσιάζει ασυμβατότητες με σύγχρονες εκδόσεις της Python (≥ 3.10) και της βιβλιοθήκης eventlet, οι οποίες επιβεβαιώθηκαν πειραματικά. Το πλήρες κύκλωμα ανίχνευσης και αντιμετώπισης υλοποιείται χωρίς εξάρτηση από εξωτερικό OpenFlow framework, με απλούστερη και πιο συντηρήσιμη αρχιτεκτονική.

5.3 Μέθοδος B: offline ανάλυση και παραγωγή του συνθετικού συνόλου

Το offline pipeline (φάκελος ml_pipeline/) υλοποιεί όλα τα στάδια της εκπαίδευσης και αξιολόγησης. Ως βάση χρησιμοποιήθηκε η δομή χαρακτηριστικών του CICFlowMeter, η ίδια με του InSDN. Κάθε ροή περιγράφεται από 24 χαρακτηριστικά και ταξινομείται σε πέντε κατηγορίες: κανονική κίνηση (Normal) και τέσσερις τύποι επιθέσεων (DDoS, DoS, Probe, BFA). Για την ανάπτυξη και τον έλεγχο δημιουργήθηκε ρεαλιστικό συνθετικό σύνολο 20.500 ροών, στο οποίο εισήχθη θόρυβος και ελεγχόμενη επικάλυψη μεταξύ γειτονικών κατηγοριών, ώστε οι μετρικές να αντικατοπτρίζουν ρεαλιστικές συνθήκες. Το ίδιο pipeline δέχεται απευθείας και το πραγματικό σύνολο InSDN.

Τα στάδια του pipeline είναι: (α) προεπεξεργασία, καθαρισμός, κωδικοποίηση των ετικετών κλάσης, κανονικοποίηση των αριθμητικών χαρακτηριστικών με StandardScaler και στρωματοποιημένος διαχωρισμός σε σύνολα εκπαίδευσης/ελέγχου, (β) εκπαίδευση και σύγκριση οκτώ μοντέλων, (γ) αξιολόγηση με μετρικές (accuracy, precision, recall, F1), πίνακες σύγχυσης, καμπύλες ROC και διασταυρούμενη επικύρωση, (δ) ανάλυση ερμηνευσιμότητας με SHAP.

Παραγωγή του συνθετικού συνόλου δεδομένων

Η ανάπτυξη και ο έλεγχος του offline pipeline απαιτήσαν ένα σύνολο δεδομένων με γνωστές ετικέτες και ελεγχόμενα χαρακτηριστικά. Για τον σκοπό αυτό κατασκευάστηκε γεννήτορας συνθετικού συνόλου, ο οποίος παράγει ροές πέντε κατηγοριών με ρεαλιστικές κατανομές ανά χαρακτηριστικό. Κρίσιμο σημείο του σχεδιασμού ήταν η σκόπιμη εισαγωγή θορύβου και ελεγχόμενης επικάλυψης μεταξύ γειτονικών κατηγοριών, για παράδειγμα, μεταξύ DoS και DDoS, ώστε οι μετρικές να μην αντικατοπτρίζουν έναν τετριμμένο, μη ρεαλιστικό διαχωρισμό. Χωρίς αυτή τη μέριμνα, τα μοντέλα θα πετύχαιναν παραπλανητικά τέλει επιδόσεις που δεν θα γενικεύονταν σε πραγματικά δεδομένα. Το γεγονός ότι το ίδιο pipeline δέχεται απευθείας και το πραγματικό σύνολο InSDN επιβεβαιώνει την εγκυρότητα της προσέγγισης: η πτώση των μετρικών από το συνθετικό στο InSDN είναι αναμενόμενη και ρεαλιστική.

Εναλλακτική υλοποίηση Mode B με OpenFlow

Παράλληλα με την κύρια, υβριδική υλοποίηση, το σύστημα υποστηρίζει και μια εναλλακτική λειτουργία (Mode B) που αξιοποιεί πλήρη ελεγκτή OpenFlow, διαθέσιμη μέσω ξεχωριστού προφίλ εκτέλεσης. Η δυνατότητα αυτή τεκμηριώνει ότι η αρχιτεκτονική

δεν είναι δεσμευμένη στον συγκεκριμένο μηχανισμό συλλογής τηλεμετρίας: η μηχανή ανίχνευσης και ο μηχανισμός αντιμετώπισης παραμένουν αμετάβλητοι, ανεξαρτήτως του αν η τηλεμετρία συλλέγεται μέσω `ovs-ofctl` ή μέσω μιας πλήρους σύνδεσης OpenFlow. Η διάκριση αυτή είναι σημαντική για τη μελλοντική μετάβαση σε πλήρες αντιδραστικό μοντέλο, όπως συζητείται στο Κεφάλαιο 7.

5.4 Μέθοδος A: Ζωντανό σύστημα και αντιμετώπιση

Για τη Μέθοδο A υλοποιήθηκε το ζωντανό σενάριο (`simulation/mininet_live.py`). Μετά την εκκίνηση του ελεγκτή, κατασκευάζεται μεταγωγέας OVS σε λειτουργία `failMode=standalone` και `datapath=user`, επιλογή απαραίτητη στο περιβάλλον WSL2, όπου δεν υπάρχει διαθέσιμο kernel module του OVS. Το δίκτυο αποτελείται από έξι hosts: τέσσερις νόμιμους (`h1-h4`), έναν στόχο-θύμα (`h5`, 10.0.0.5) και έναν επιτιθέμενο (`h6`, 10.0.0.6).

Ένα νήμα παρασκηνίου ανακτά τα στατιστικά θυρών του μεταγωγέα κάθε πέντε δευτερόλεπτα (`ovs-ofctl dump-ports`) και τα αποστέλλει στον ελεγκτή μέσω του endpoint τηλεμετρίας. Ο ελεγκτής υπολογίζει συγκεντρωτικά χαρακτηριστικά ανά πηγή IP (`flow_count`, `short_flow_ratio`, μέσος αριθμός πακέτων και διάρκεια ανά ροή) και τα τροφοδοτεί στο μοντέλο Isolation Forest. Σε κάθε πηγή που ταξινομείται ως επιτιθέμενη, εγκαθίσταται αυτόματα κανόνας απόρριψης για το αντίστοιχο διάστημα. Το σενάριο εκτελείται σε δύο φάσεις: μια φάση νόμιμης κίνησης (`ping`) και μια φάση επίθεσης (`hping3 --syn --flood`), κατά την οποία ο επιτιθέμενος εντοπίζεται και μπλοκάρεται, ενώ η νόμιμη κίνηση παραμένει ανεπηρέαστη.

5.4.1 Αποφυγή ψευδώς θετικών

Ιδιαίτερη μέριμνα δόθηκε στην αποφυγή ψευδώς θετικών κατά τη φάση της νόμιμης κίνησης. Χρησιμοποιείται εντολή `ping` με είκοσι πακέτα ανά host, ώστε ο αριθμός πακέτων να υπερβαίνει σαφώς το κατώφλι σύντομης ροής και ο λόγος σύντομων ροών να παραμένει μηδενικός. Επιπλέον, παραλείπονται από την τηλεμετρία τα πακέτα κάτω των τεσσάρων ανά διάστημα, καθώς και η θύρα του θύματος (`h5`), η οποία αποστέλλει απαντήσεις RST στην πλημμύρα και θα μπορούσε λανθασμένα να θεωρηθεί ανώμαλη.

5.5 Ασφάλεια της υλοποίησης και προστασία του ελεγκτή

Το σύστημα ενσωματώνει μηχανισμούς ασφαλείας που τεκμηριώνουν την καταλληλότητά του ως εφαρμογής κυβερνοασφάλειας, και όχι απλώς ως ερευνητικού prototype:

Μηχανισμός	Κατάσταση
Rate limiting (120 αιτήματα / 60s)	Ενεργό
Προστασία admin με token (X-Admin-Token)	Ενεργό
Αυθεντικοποίηση μεταγωγέα (X-Switch-Token)	Ενεργό
Εξαγωγή δεδομένων σε CSV (/export/*.csv)	Διαθέσιμο
Endpoint anomaly scores (/anomaly_scores)	Διαθέσιμο
Λειτουργία Mode B (Ryu/OpenFlow, --profile ryu)	Διαθέσιμο

Πίνακας 7: Μηχανισμοί ασφαλείας του ελεγκτή.

Η αυθεντικοποίηση της τηλεμετρίας (X-Switch-Token) είναι ιδιαίτερα σημαντική ενόψει της επίθεσης δηλητηρίασης τηλεμετρίας που εξετάζεται στο Κεφάλαιο 6: χωρίς αυτήν, ένας κακόβουλος host θα μπορούσε να στείλει πλαστά στατιστικά και να ενοχοποιήσει νόμιμους κόμβους.

Έλεγχος ρυθμού και προστασία του ελεγκτή

Ένα σύστημα που προορίζεται να προστατεύει το δίκτυο πρέπει το ίδιο να είναι ανθεκτικό σε επιθέσεις. Ο ελεγκτής προστατεύεται με μηχανισμό ελέγχου ρυθμού αιτημάτων, ο οποίος περιορίζει το πλήθος των κλήσεων που μπορεί να δεχθεί ανά μονάδα χρόνου. Έτσι, ακόμη και αν ένας επιτιθέμενος προσπαθήσει να κατακλύσει τον ίδιο τον ελεγκτή με αιτήματα, η λειτουργικότητά του διατηρείται. Ο συνδυασμός αυτού του μηχανισμού με την αυθεντικοποίηση των διαχειριστικών endpoints και της τηλεμετρίας συνθέτει μια πολυεπίπεδη προστασία του ίδιου του συστήματος άμυνας, μια αρχή θεμελιώδη στην κυβερνοασφάλεια, όπου κάθε αμυντικός μηχανισμός πρέπει να λαμβάνει μέριμνα και για τη δική του ασφάλεια.

5.6 REST διεπαφή του ελεγκτή

Ο ελεγκτής εκθέτει μια RESTful διεπαφή (northbound API) μέσω Flask, η οποία αποτελεί το σημείο ολοκλήρωσης όλων των στοιχείων του συστήματος. Τα κυριότερα endpoints συνοψίζονται στον ακόλουθο πίνακα.

Endpoint	Λειτουργία
POST /telemetry	Λήψη στατιστικών ροών από τον μεταγωγέα.
GET /flow_table	Επιστροφή του τρέχοντος πίνακα ροών.

GET /topology	Επιστροφή της τοπολογίας για το dashboard.
GET /stats	Συγκεντρωτικές μετρικές λειτουργίας.
GET /anomaly_scores	Τιμές ανωμαλίας ανά πηγή.
POST /reset	Επαναφορά κατάστασης (νέο σενάριο).
GET /export/flows.csv	Εξαγωγή ροών σε CSV.

Πίνακας 8: Κυριότερα REST endpoints του ελεγκτή.

5.7 Ο βρόχος τηλεμετρίας: μορφή μηνυμάτων και αλγόριθμος απόφασης

Ο πυρήνας της ζωντανής λειτουργίας είναι ένας επαναλαμβανόμενος βρόχος με περίοδο πέντε δευτερολέπτων. Σε κάθε επανάληψη, το νήμα τηλεμετρίας εκτελεί `ons-ofctl dump-ports` στον μεταγωγέα, υπολογίζει τη διαφορά μετρητών σε σχέση με την προηγούμενη μέτρηση και συνθέτει, ανά πηγή IP, ένα διάνυσμα συγκεντρωτικών χαρακτηριστικών. Το διάνυσμα αυτό κανονικοποιείται και τροφοδοτείται στη μηχανή Isolation Forest. Αν η πηγή ταξινομηθεί ως επιτιθέμενη, ο ελεγκτής εκδίδει εντολή εγκατάστασης κανόνα απόρριψης με υψηλή προτεραιότητα. Ο κανόνας παραμένει ενεργός για καθορισμένο διάστημα και, αν η επίθεση επαναληφθεί μετά τη λήξη του, επανεντοπίζεται και εγκαθίσταται εκ νέου, υλοποιώντας τον κύκλο επανα-ανίχνευσης που αναλύεται στο Κεφάλαιο 6.

Η επιλογή παραθύρου πέντε δευτερολέπτων αποτελεί συμβιβασμό μεταξύ ταχύτητας απόκρισης και στατιστικής αξιοπιστίας: παράθυρα πολύ μικρά εισάγουν θόρυβο και ψευδώς θετικά, ενώ παράθυρα πολύ μεγάλα καθυστερούν την αντίδραση. Όπως δείχνει η ανάλυση καθυστέρησης, το παράθυρο αυτό επιτρέπει ανίχνευση ήδη από το πρώτο διάστημα εμφάνισης της επίθεσης.

Μορφή μηνυμάτων τηλεμετρίας

Η επικοινωνία μεταξύ του μεταγωγέα και του ελεγκτή γίνεται με δομημένα μηνύματα JSON. Κάθε μήνυμα τηλεμετρίας περιέχει τη διεύθυνση προέλευσης, τη διεύθυνση προορισμού και μια λίστα ροών, καθεμία περιγραφόμενη από το πλήθος πακέτων, το πλήθος bytes και τη διάρκεια. Η απλότητα και η τυποποίηση του σχήματος διευκολύνουν τόσο την επεξεργασία όσο και την επέκταση: πρόσθετα χαρακτηριστικά μπορούν να ενσωματωθούν χωρίς αλλαγή της βασικής δομής. Η αυθεντικοποίηση κάθε μηνύματος με

token διασφαλίζει ότι μόνο ο εξουσιοδοτημένος μεταγωγέας μπορεί να υποβάλει τηλεμετρία, αποτρέποντας την επίθεση δηλητηρίασης.

Ο αλγόριθμος ανίχνευσης βήμα προς βήμα

Ο πυρήνας της απόφασης εκτελείται από τη μηχανή ανίχνευσης σε κάθε παράθυρο δειγματοληψίας. Αρχικά, τα ακατέργαστα στατιστικά θυρών μετατρέπονται σε διαφορικές τιμές (deltas) ως προς την προηγούμενη μέτρηση, ώστε να αντικατοπτρίζουν τη δραστηριότητα του τρέχοντος παραθύρου και όχι τους σωρευτικούς μετρητές. Στη συνέχεια, οι τιμές ομαδοποιούνται ανά πηγή IP και υπολογίζονται τα συγκεντρωτικά χαρακτηριστικά: το πλήθος ενεργών ροών, ο λόγος των σύντομων ροών, ο μέσος αριθμός πακέτων ανά ροή και η μέση διάρκεια. Τα χαρακτηριστικά κανονικοποιούνται με τον ίδιο scaler που χρησιμοποιήθηκε κατά την εκπαίδευση, ώστε να διασφαλίζεται συνέπεια μεταξύ εκπαίδευσης και εξαγωγής συμπερασμάτων.

Το κανονικοποιημένο διάνυσμα τροφοδοτείται στη μηχανή Isolation Forest, η οποία επιστρέφει μια τιμή ανωμαλίας. Αν η τιμή υπερβεί το κατώφλι απόφασης, η πηγή χαρακτηρίζεται ως επιτιθέμενη. Πριν την οριστική απόφαση, εφαρμόζονται ορισμένοι κανόνες ασφαλείας που περιορίζουν τα ψευδώς θετικά, για παράδειγμα, η παράβλεψη πηγών με ελάχιστη δραστηριότητα και η εξαίρεση της θύρας του θύματος, η οποία εκπέμπει απαντήσεις RST στην πλημμύρα. Τέλος, για κάθε επιβεβαιωμένη επίθεση, εκδίδεται εντολή εγκατάστασης κανόνα απόρριψης και ενημερώνεται η κατάσταση του συστήματος και το dashboard.

5.8 Περιβάλλον εκτέλεσης: Docker, δικτύωση και WSL2

Η αναπαραγωγικότητα αποτέλεσε ρητή σχεδιαστική προτεραιότητα. Ολόκληρο το σύστημα ενορχηστρώνεται μέσω ενός αρχείου Docker Compose, το οποίο ορίζει και τα τέσσερα containers, τις μεταξύ τους συνδέσεις και τις θύρες. Με μία εντολή, ο αξιολογητής μπορεί να ανεγείρει ολόκληρη τη στοίβα και να εκτελέσει τόσο τα ζωντανά σενάρια όσο και το offline pipeline. Τα σενάρια `run_all.sh` και `run_live_experiments.sh` αυτοματοποιούν πλήρως την αναπαραγωγή των αποτελεσμάτων, ενώ ένα σύνολο αυτοματοποιημένων ελέγχων (tests) και μια ροή συνεχούς ενσωμάτωσης (CI) επιβεβαιώνουν την ακεραιότητα του κώδικα σε κάθε αλλαγή.

Το περιβάλλον εκτέλεσης ήταν Windows με WSL2. Η επιλογή αυτή παρουσίασε μια τεχνική ιδιαιτερότητα: ο πυρήνας του WSL2 δεν περιλαμβάνει το kernel module του Open vSwitch, με αποτέλεσμα η τυπική εκκίνηση της υπηρεσίας να μην ενεργοποιεί τον δαίμονα

ons-vswitchd. Η λύση ήταν η ρητή εκκίνηση του δαίμονα σε userspace λειτουργία και η κατασκευή του μεταγωγέα με datapath=user και failMode=standalone. Η επιλογή αυτή, αν και επιβεβλημένη από το περιβάλλον, ευθυγραμμίζεται με το υβριδικό μοντέλο ελέγχου, καθώς επιτρέπει στον μεταγωγέα να λειτουργεί ως αυτόνομος learning switch.

Απομόνωση και δικτύωση των containers

Η επιλογή της τεχνολογίας containers για την ανάπτυξη του συστήματος εξυπηρετεί πολλaplούς σκοπούς. Κάθε στοιχείο εκτελείται σε απομονωμένο περιβάλλον με τις δικές του εξαρτήσεις, εξαλείφοντας τις συγκρούσεις βιβλιοθηκών και διασφαλίζοντας ότι η συμπεριφορά είναι ίδια σε κάθε μηχανήμα. Η μεταξύ τους επικοινωνία γίνεται μέσω ενός εικονικού δικτύου που ορίζει το Docker Compose, με σαφώς καθορισμένες θύρες και ονόματα υπηρεσιών. Ο μεταγωγέας εκτελείται σε προνομιακό (privileged) container, καθώς απαιτεί πρόσβαση σε λειτουργίες δικτύου του πυρήνα για τη δημιουργία εικονικών διεπαφών και τη διαχείριση του Open vSwitch.

Η προσέγγιση αυτή καθιστά ολόκληρο το πείραμα φορητό και αναπαραγώγιμο: ο αξιολογητής δεν χρειάζεται να εγκαταστήσει χειροκίνητα εξαρτήσεις ή να ρυθμίσει το περιβάλλον, παρά μόνο να διαθέτει το Docker. Η φορητότητα αυτή είναι κρίσιμη για την επιστημονική αξία της διπλωματικής, καθώς επιτρέπει την ανεξάρτητη επαλήθευση των αποτελεσμάτων από τρίτους, μια θεμελιώδη αρχή της επιστημονικής μεθόδου.

Ιδιαιτερότητες του περιβάλλοντος WSL2

Η ανάπτυξη σε περιβάλλον Windows με WSL2 απαίτησε την αντιμετώπιση συγκεκριμένων τεχνικών προκλήσεων. Η σημαντικότερη αφορούσε την απουσία του kernel module του Open vSwitch στον πυρήνα του WSL2, η οποία εμπόδιζε την τυπική λειτουργία του μεταγωγέα. Η λύση της ρητής εκκίνησης του δαίμονα σε userspace λειτουργία και της κατασκευής του μεταγωγέα με datapath τύπου user αποδείχθηκε αξιόπιστη και, όπως προαναφέρθηκε, εναρμονισμένη με το υβριδικό μοντέλο ελέγχου. Η τεκμηρίωση αυτής της λύσης έχει αξία και για μελλοντικούς ερευνητές που εργάζονται στο ίδιο, ολοένα και δημοφιλέστερο, περιβάλλον ανάπτυξης.

5.9 Οπτικοποίηση σε πραγματικό χρόνο

Ένα σημαντικό στοιχείο του συστήματος είναι το dashboard οπτικοποίησης, υλοποιημένο με Dash και Cytoscape. Το dashboard παρουσιάζει σε πραγματικό χρόνο την τοπολογία του δικτύου, με τους κόμβους να αλλάζουν χρώμα ανάλογα με την κατάστασή τους

(νόμιμος, υπό παρακολούθηση, μπλοκαρισμένος), καθώς και ένα διάγραμμα του ρυθμού πακέτων που εξελίσσεται χρονικά. Έτσι, ο χρήστης παρακολουθεί οπτικά τη στιγμή της επίθεσης, την ανίχνευση και την επιβολή του κανόνα απόρριψης. Πέραν της επιδεικτικής του αξίας, το dashboard λειτουργεί και ως εργαλείο επαλήθευσης, καθιστώντας άμεσα ορατή την ορθή λειτουργία του κλειστού βρόχου εποπτείας-απόφασης-δράσης.

5.10 Διαχείριση κατάστασης, ταυτοχρονισμού και σφαλμάτων

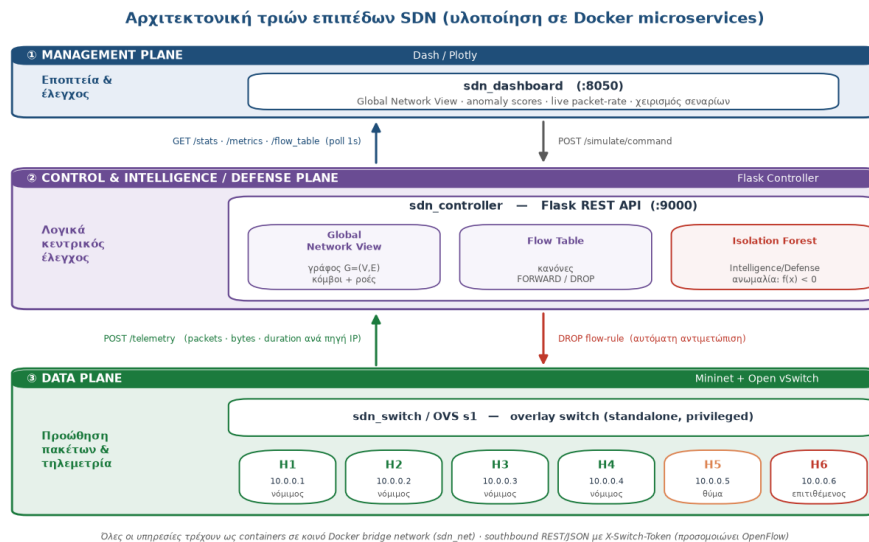
Η ζωντανή λειτουργία απαιτεί προσεκτική διαχείριση κατάστασης. Ο ελεγκτής διατηρεί τη λίστα των ενεργών κανόνων απόρριψης με τους χρόνους λήξης τους, το ιστορικό των ανιχνεύσεων και τις σωρευτικές μετρικές. Καθώς το νήμα τηλεμετρίας και οι εισερχόμενες κλήσεις REST εκτελούνται ταυτόχρονα, η πρόσβαση στην κοινή κατάσταση προστατεύεται ώστε να αποφεύγονται συνθήκες ανταγωνισμού (race conditions). Η σχεδίαση αυτή εξασφαλίζει ότι, ακόμη και υπό υψηλό ρυθμό τηλεμετρίας κατά τη διάρκεια μιας επίθεσης, οι αποφάσεις παραμένουν συνεπείς και το σύστημα δεν εισέρχεται σε ασυνεπή κατάσταση.

Χειρισμός σφαλμάτων και ανθεκτικότητα

Ένα σύστημα που προορίζεται για λειτουργία σε πραγματικό χρόνο πρέπει να είναι ανθεκτικό σε σφάλματα. Ο ελεγκτής χειρίζεται με χάρη τις περιπτώσεις ελλιπούς ή καθυστερημένης τηλεμετρίας, τις παροδικές αστοχίες επικοινωνίας με τον μεταγωγέα και τις μη έγκυρες εισόδους, χωρίς να διακόπτεται η λειτουργία του. Ο μηχανισμός rate limiting προστατεύει τον ίδιο τον ελεγκτή από υπερφόρτωση αιτημάτων, ενώ η περιοδική φύση του βρόχου τηλεμετρίας εξασφαλίζει ότι μια μεμονωμένη αστοχία σε ένα παράθυρο δεν επηρεάζει τα επόμενα. Η σχεδίαση αυτή αντικατοπτρίζει την αρχή ότι ένα σύστημα ασφαλείας πρέπει το ίδιο να είναι ασφαλές και σταθερό.

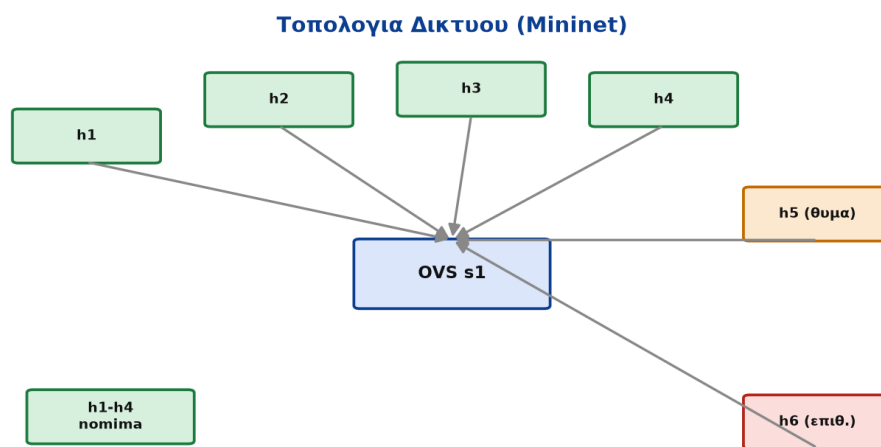
5.11 Σχηματική αναπαράσταση της αρχιτεκτονικής και του βρόχου ελέγχου

Η συνολική αρχιτεκτονική του συστήματος, με τα τέσσερα συνεργαζόμενα containers και τις μεταξύ τους ροές πληροφορίας, αποτυπώνεται στο ακόλουθο σχήμα. Ο ελεγκτής λαμβάνει τηλεμετρία, εκτελεί την ανίχνευση και επιστρέφει εντολές απόρριψης προς τον μεταγωγέα, ενώ το dashboard παρακολουθεί την κατάσταση σε πραγματικό χρόνο.



Σχήμα 1: Σχηματική αναπαράσταση της αρχιτεκτονικής του συστήματος.

Η τοπολογία του προσομοιωμένου δικτύου αποτελείται από έξι hosts συνδεδεμένους σε έναν μεταγωγέα OVS. Οι τέσσερις πρώτοι (h1-h4) παράγουν νόμιμη κίνηση, ο h5 λειτουργεί ως θύμα και ο h6 ως επιτιθέμενος.

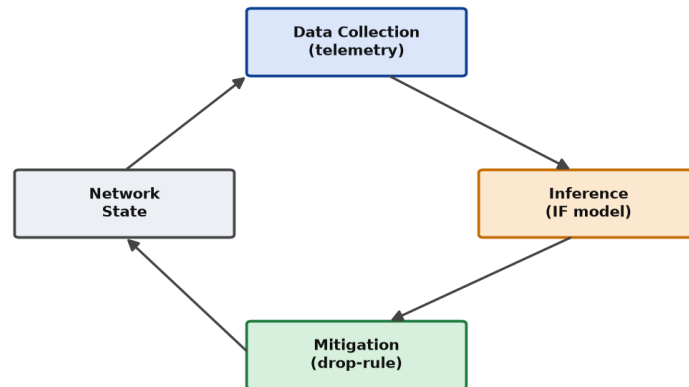


Σχήμα 2: Τοπολογία του προσομοιωμένου δικτύου με έξι hosts.

Ο βρόχος ελέγχου σε σχηματική μορφή

Η λειτουργία του συστήματος υλοποιεί έναν κλειστό βρόχο τεσσάρων σταδίων. Το ακόλουθο σχήμα αποτυπώνει τη διαδοχή Data Collection → Inference → Mitigation → ενημέρωση κατάστασης δικτύου, καθώς και τη ροή ανίχνευσης-αντιμετώπισης βήμα προς βήμα.

Κλειστός Βρόχος Εποπτείας-Απόφασης-Δράσης



Σχήμα 3: Ο κλειστός βρόχος εποπτείας-απόφασης-δράσης.

Ροή Ανίχνευσης και Αντιμετώπισης



Normal → συνέχεια

Σχήμα 4: Η ροή ανίχνευσης και αντιμετώπισης βήμα προς βήμα.

5.12 Στρατηγική ελέγχου και συνεχής ενσωμάτωση

Η αξιοπιστία του συστήματος διασφαλίζεται μέσα από μια ολοκληρωμένη στρατηγική αυτοματοποιημένου ελέγχου. Το σύνολο των ελέγχων καλύπτει πολλαπλά επίπεδα: ελέγχους μονάδας για τη λογική της μηχανής ανίχνευσης, ελέγχους της REST διεπαφής του ελεγκτή, ελέγχους της υγείας των containers, ελέγχους παλινδρόμησης του μοντέλου (ώστε η ακρίβεια να μην υποβαθμίζεται σε νέες εκδόσεις), ελέγχους των ζωντανών σεναρίων και ελέγχους επικύρωσης ασφαλείας. Οι έλεγχοι αυτοί εκτελούνται αυτόματα σε κάθε αλλαγή του κώδικα μέσω μιας ροής συνεχούς ενσωμάτωσης (CI), η οποία επιβεβαιώνει ότι κάθε τροποποίηση διατηρεί την ακεραιότητα και την απόδοση του συστήματος.

Η επένδυση αυτή στην ποιότητα του λογισμικού, αν και συχνά παραβλέπεται σε ερευνητικά prototypes, είναι ουσιώδης για την αξιοπιστία των αποτελεσμάτων: διασφαλίζει ότι τα πειραματικά ευρήματα είναι αναπαραγώγιμα και ότι δεν οφείλονται σε παροδικά ή τυχαία σφάλματα. Επιπλέον, καθιστά το σύστημα κατάλληλη βάση για μελλοντική επέκταση, καθώς κάθε νέα προσθήκη ελέγχεται αυτόματα ως προς τη συμβατότητά της με την υπάρχουσα λειτουργικότητα.

5.13 Κύκλος ζωής πειράματος: μοντέλα και παραγωγή κίνησης

Ένα πρακτικό αλλά ουσιώδες ζήτημα είναι η διατήρηση της συνέπειας μεταξύ της φάσης εκπαίδευσης και της φάσης λειτουργίας. Τα εκπαιδευμένα μοντέλα, μαζί με τους μετασχηματιστές κανονικοποίησης και τους κωδικοποιητές ετικετών, αποθηκεύονται σειριοποιημένα και φορτώνονται κατά την εκκίνηση του ελεγκτή. Είναι κρίσιμο ο ίδιος μετασχηματιστής κανονικοποίησης που προσαρμόστηκε στα δεδομένα εκπαίδευσης να χρησιμοποιείται και κατά την εξαγωγή συμπερασμάτων. Διαφορετικά, η κατανομή των χαρακτηριστικών κατά τη λειτουργία θα διέφερε από αυτή της εκπαίδευσης, υπονομεύοντας τις προβλέψεις. Η διασφάλιση αυτής της συνέπειας αποτελεί συχνά παραβλεπόμενη αλλά κρίσιμη λεπτομέρεια για την αξιόπιστη ανάπτυξη μοντέλων Μηχανικής Μάθησης σε παραγωγή.

Κύκλος ζωής ενός πειράματος

Κάθε ζωντανό πείραμα ακολουθεί έναν καθορισμένο κύκλο ζωής. Αρχικά, ο ελεγκτής επαναφέρεται σε καθαρή κατάσταση μέσω του αντίστοιχου endpoint, ώστε τα αποτελέσματα να μην επηρεάζονται από προηγούμενες εκτελέσεις. Στη συνέχεια, στήνεται η τοπολογία και ξεκινά η φάση νόμιμης κίνησης, κατά την οποία επιβεβαιώνεται η απουσία ψευδώς θετικών. Ακολουθεί η φάση επίθεσης, όπου ενεργοποιείται ο μηχανισμός ανίχνευσης και αντιμετώπισης. Καθ' όλη τη διάρκεια, οι μετρήσεις καταγράφονται και εξάγονται σε αρχεία για μετέπειτα ανάλυση. Ο σαφής αυτός κύκλος ζωής εξασφαλίζει ότι κάθε πείραμα είναι απομονωμένο, επαναλήψιμο και συγκρίσιμο με τα υπόλοιπα.

Παραγωγή νόμιμης και κακόβουλης κίνησης

Η αξιοπιστία της ζωντανής αξιολόγησης εξαρτάται από τον ρεαλισμό της παραγόμενης κίνησης. Για τη νόμιμη κίνηση χρησιμοποιήθηκαν τυπικά εργαλεία δικτύου που παράγουν ελεγχόμενα μοτίβα επικοινωνίας, ενώ για τις επιθέσεις αξιοποιήθηκαν πραγματικά εργαλεία, όπως το hping3 για την πλημμύρα SYN. Η χρήση πραγματικών εργαλείων επίθεσης, αντί για απλή προσομοίωση στατιστικών, είναι σημαντική: εξασφαλίζει ότι το

σύστημα αξιολογείται έναντι της πραγματικής συμπεριφοράς των επιθέσεων στο επίπεδο των πακέτων, και όχι έναντι μιας εξιδανικευμένης εκδοχής τους. Έτσι, τα αποτελέσματα αντικατοπτρίζουν πιστότερα την αναμενόμενη απόδοση σε πραγματικές συνθήκες.

Ιδιαίτερη προσοχή δόθηκε στη ρύθμιση της νόμιμης κίνησης ώστε να είναι αντιπροσωπευτική και όχι τετριμμένη. Η επιλογή του πλήθους των πακέτων και του ρυθμού αποστολής έγινε ώστε η νόμιμη κίνηση να διαφοροποιείται σαφώς από τα μοτίβα των επιθέσεων, χωρίς όμως να είναι εξωπραγματικά «καθαρή». Αυτή η ισορροπία είναι που επέτρεψε την επίτευξη μηδενικών ψευδώς θετικών στο σενάριο αποκλειστικά νόμιμης κίνησης, χωρίς να καθιστά την ανίχνευση τετριμμένη.

6. Πειράματα και Αποτελέσματα

6.1 Πειραματική διάταξη

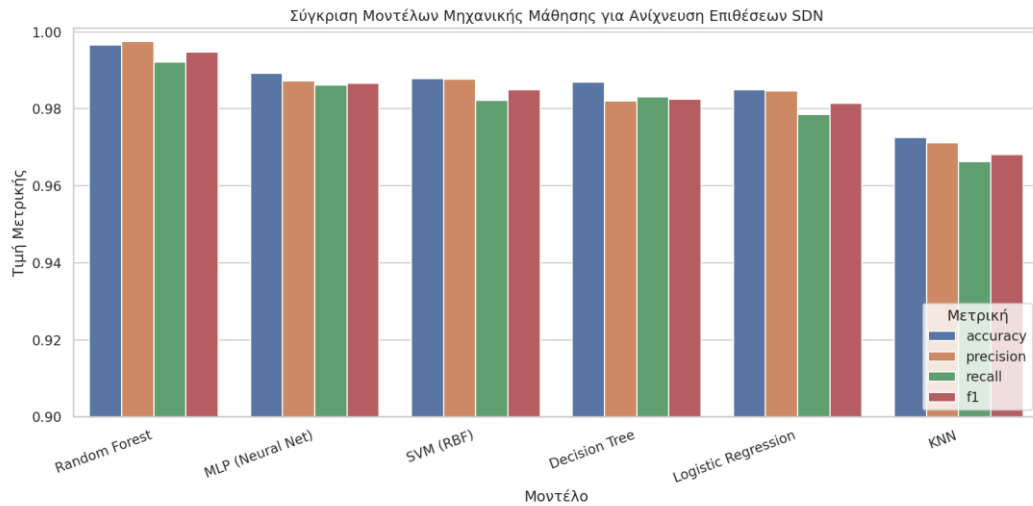
Τα πειράματα εκτελέστηκαν σε περιβάλλον Linux (WSL2) με ενορχήστρωση μέσω Docker. Η offline αξιολόγηση (Μέθοδος Β) πραγματοποιήθηκε επί του συνθετικού συνόλου των 20.500 ροών, με στρωματοποιημένο διαχωρισμό σε σύνολα εκπαίδευσης και ελέγχου, καθώς και επί του πραγματικού συνόλου InSDN. Η ζωντανή αξιολόγηση (Μέθοδος Α) πραγματοποιήθηκε επί της εκτελούμενης στοίβας Docker, με πραγματικά πακέτα να διασχίζουν τον μεταγωγέα OVS. Όλα τα αποτελέσματα είναι αναπαραγώγιμα μέσω των σεναρίων `run_all.sh` (offline) και `run_live_experiments.sh` (live).

6.2 Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης

Το πρώτο πείραμα συγκρίνει τα έξι κλασικά μοντέλα ως προς τις τέσσερις βασικές μετρικές ταξινόμησης. Ο Πίνακας που ακολουθεί συνοψίζει τα αποτελέσματα στο συνθετικό σύνολο. Το Random Forest επιτυγχάνει την υψηλότερη επίδοση σε όλες τις μετρικές, με F1-score άνω του 0,999, ενώ διατηρεί και τον ταχύτερο χρόνο πρόβλεψης μεταξύ των ισχυρών μοντέλων.

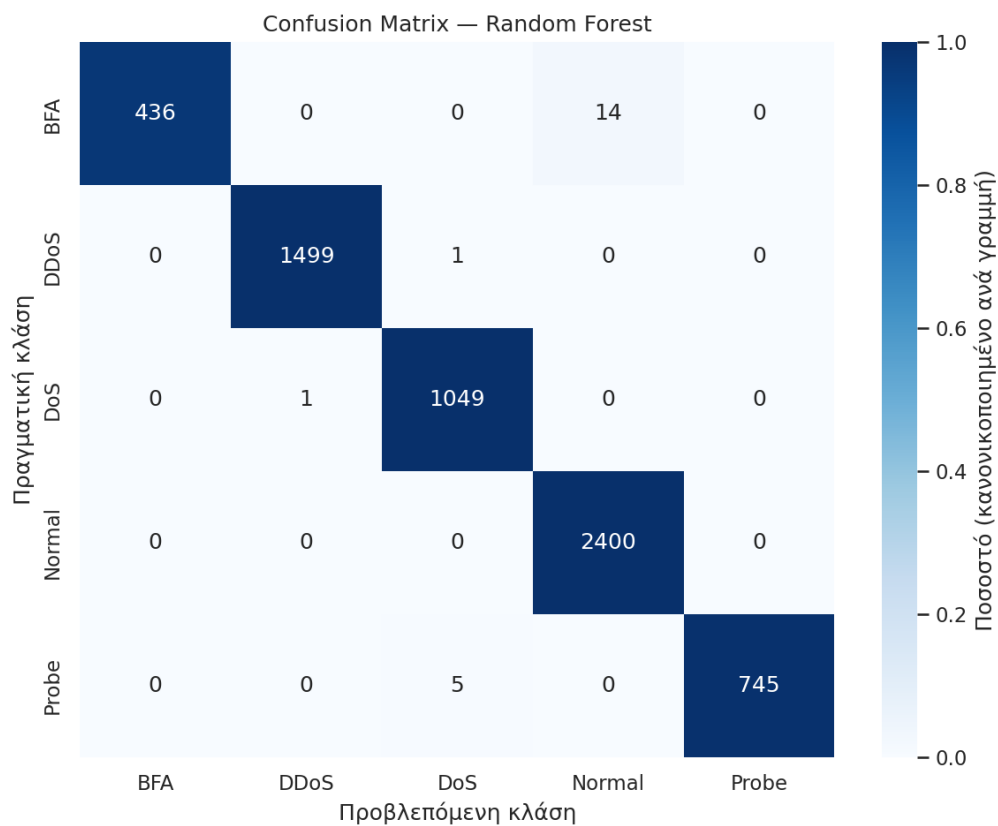
Μοντέλο	Accuracy	Precision	Recall	F1
Random Forest	0,9998	0,9999	0,9998	0,9998
MLP (Neural Net)	0,9974	0,9974	0,9974	0,9974
SVM (RBF)	0,9969	0,9971	0,9966	0,9969
Decision Tree	0,9958	0,9956	0,9943	0,9949
Logistic Regression	0,9953	0,9950	0,9952	0,9951
KNN	0,9893	0,9891	0,9882	0,9885

Πίνακας 9: Σύγκριση κλασικών μοντέλων στο συνθετικό σύνολο (24 χαρακτηριστικά).



Σχήμα 5: Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης ως προς τις τέσσερις βασικές μετρικές.

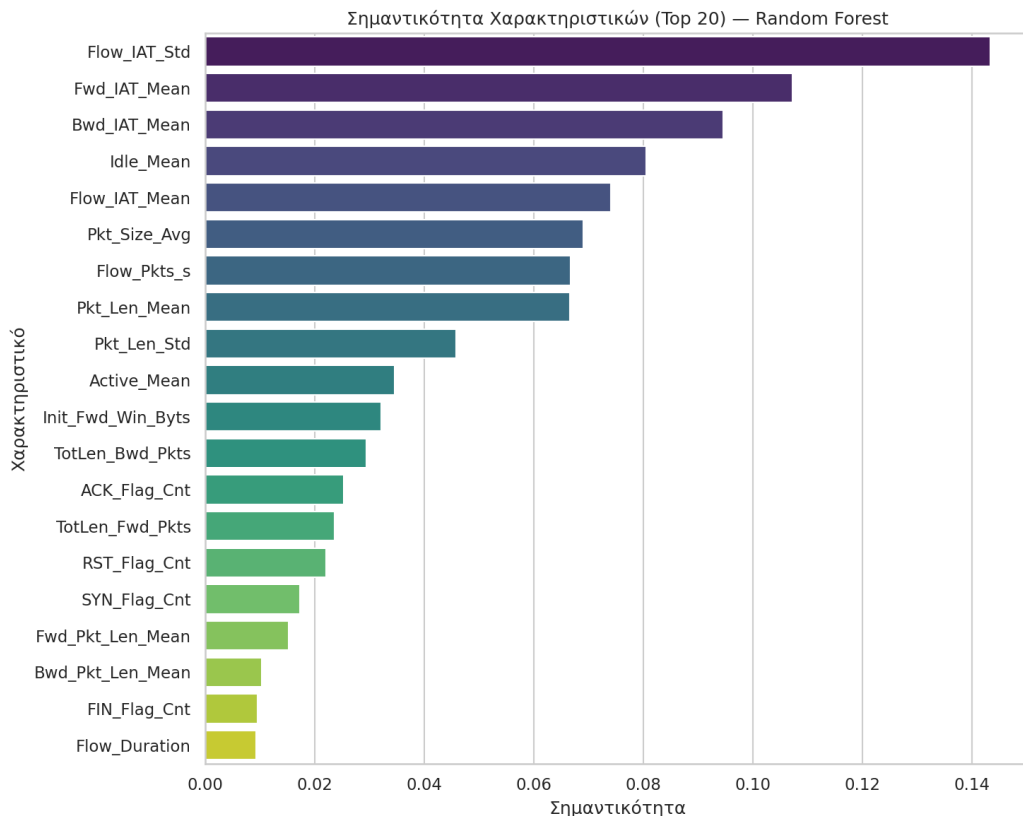
Ο πίνακας σύγχυσης (confusion matrix) του καλύτερου μοντέλου δείχνει ότι οι λανθασμένες ταξινομήσεις είναι ελάχιστες και εντοπίζονται κυρίως μεταξύ των κατηγοριών DoS και DDoS, οι οποίες παρουσιάζουν φυσική στατιστική ομοιότητα (και οι δύο είναι επιθέσεις πλημμύρας).



Σχήμα 6: Πίνακας σύγχυσης του βέλτιστου κλασικού μοντέλου (Random Forest).

6.3 Σημαντικότητα χαρακτηριστικών και ερμηνευσιμότητα (SHAP)

Η ανάλυση σημαντικότητας αποκαλύπτει ποια χαρακτηριστικά ροής συνεισφέρουν περισσότερο στη διάκριση των επιθέσεων. Χαρακτηριστικά όπως ο ρυθμός πακέτων ανά δευτερόλεπτο, οι χρόνοι μεταξύ αφίξεων και το πλήθος των σημάτων TCP είναι ιδιαίτερα διακριτικά για τις επιθέσεις πλημμύρας.



Σχήμα 7: Σημαντικότητα των σημαντικότερων χαρακτηριστικών κατά το Random Forest.

Ανάλυση ερμηνευσιμότητας με SHAP

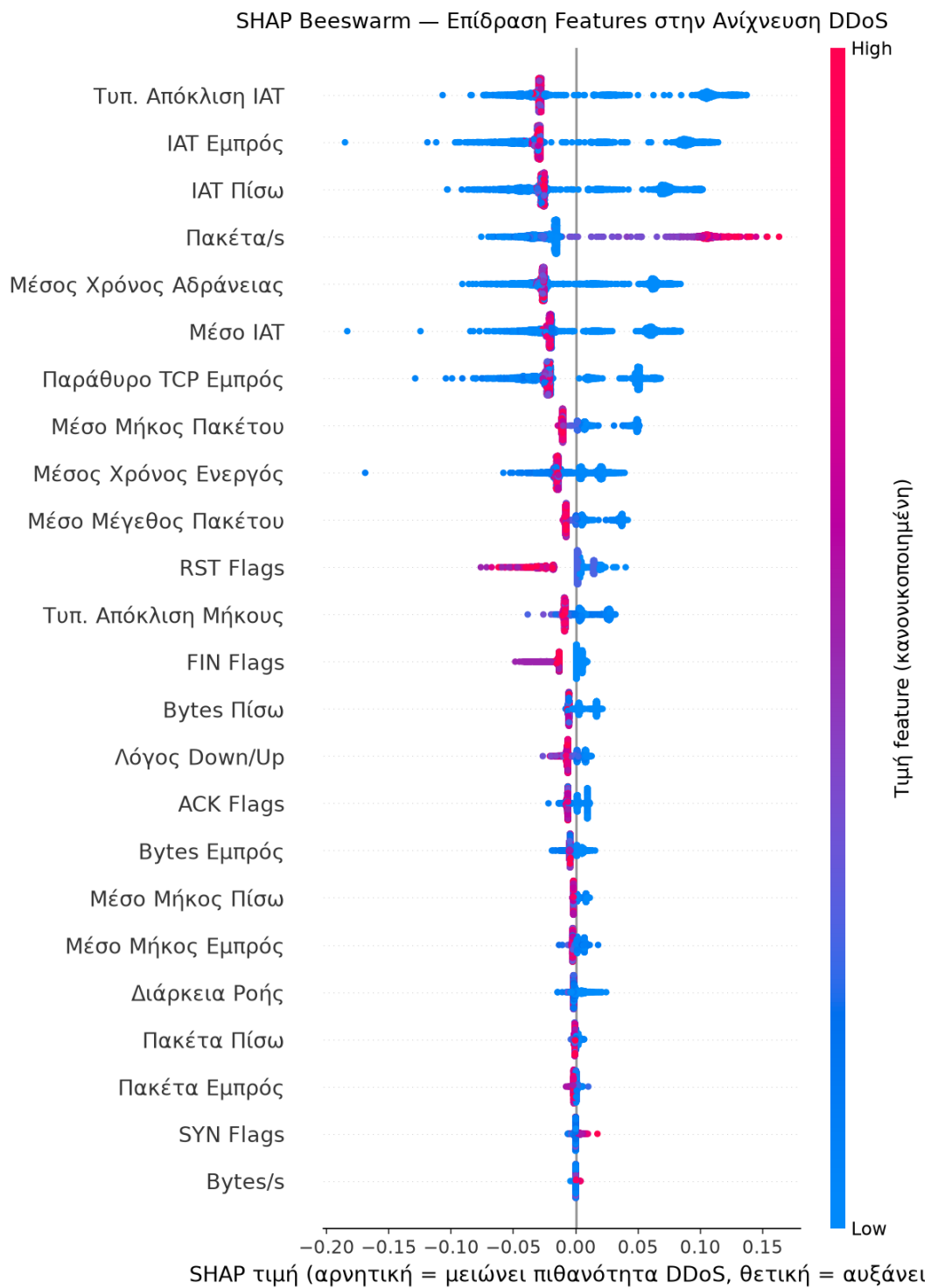
Τα μοντέλα Μηχανικής Μάθησης, παρά την υψηλή ακρίβειά τους, λειτουργούν συχνά ως «μαύρα κουτιά». Στην κυβερνοασφάλεια αυτό είναι προβληματικό, καθώς ο αναλυτής χρειάζεται να κατανοήσει γιατί μια ροή χαρακτηρίστηκε κακόβουλη πριν λάβει αμυντικές αποφάσεις. Το SHAP (SHapley Additive exPlanations) [14] κατανέμει τη συνεισφορά κάθε χαρακτηριστικού στην τελική πρόβλεψη, αξιοποιώντας τις Shapley Values από τη θεωρία παιγνίων. Χρησιμοποιήθηκαν 2.000 στρωματοποιημένα δείγματα, με υπολογισμό τιμών SHAP για πέντε κλάσεις και 24 χαρακτηριστικά.

Ο ακόλουθος πίνακας παρουσιάζει τα πέντε σημαντικότερα χαρακτηριστικά (global, μέση απόλυτη τιμή SHAP). Τα ευρήματα είναι ερμηνεύσιμα από δικτυακή σκοπιά: η τυπική

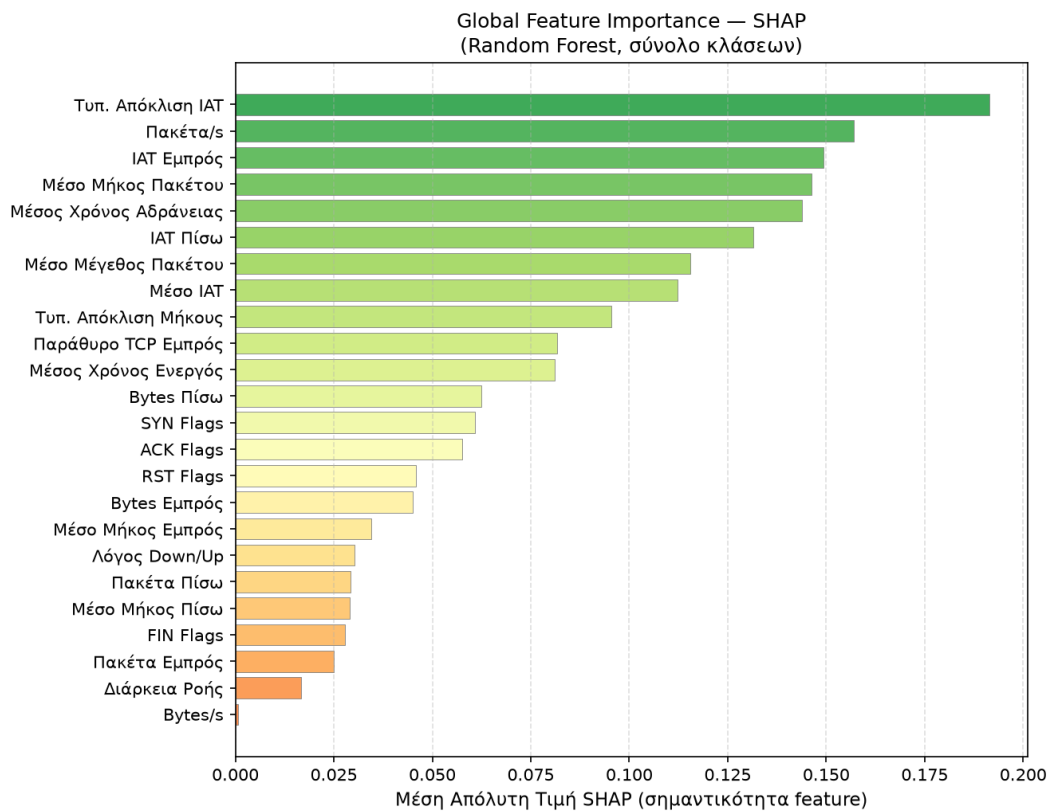
απόκλιση των χρόνων μεταξύ αφίξεων και ο ρυθμός πακέτων αναδεικνύονται ως τα πλέον διαγνωστικά για τις επιθέσεις πλημμύρας.

#	Χαρακτηριστικό	Μέση SHAP	Δικτυακή ερμηνεία
1	Τυπ. Απόκλιση IAT	0,192	Ανωμαλία στους χρόνους άφιξης, χαρακτηριστικό flood.
2	Πακέτα/s	0,157	Υψηλός ρυθμός = DDoS/DoS, χαμηλός = σάρωση.
3	IAT Εμπρός	0,149	Σχεδόν μηδενικό IAT = burst επίθεση.
4	Μέσο Μήκος Πακέτου	0,146	Μικρά πακέτα = SYN flood, μεγάλα = εκτεταμένη επικοινωνία.
5	Μέσος Χρόνος Αδράνειας	0,144	Ξεχωρίζει σάρωση από πλημμύρα.

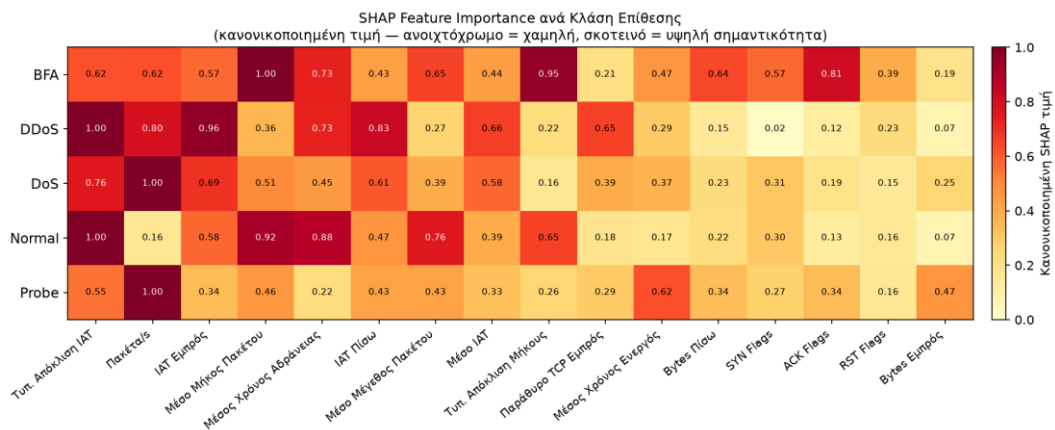
Πίνακας 10: Τα πέντε σημαντικότερα χαρακτηριστικά κατά την ανάλυση SHAP.



Σχήμα 8: Διάγραμμα SHAP (beeswarm), κατεύθυνση και μέγεθος επίδρασης ανά χαρακτηριστικό.



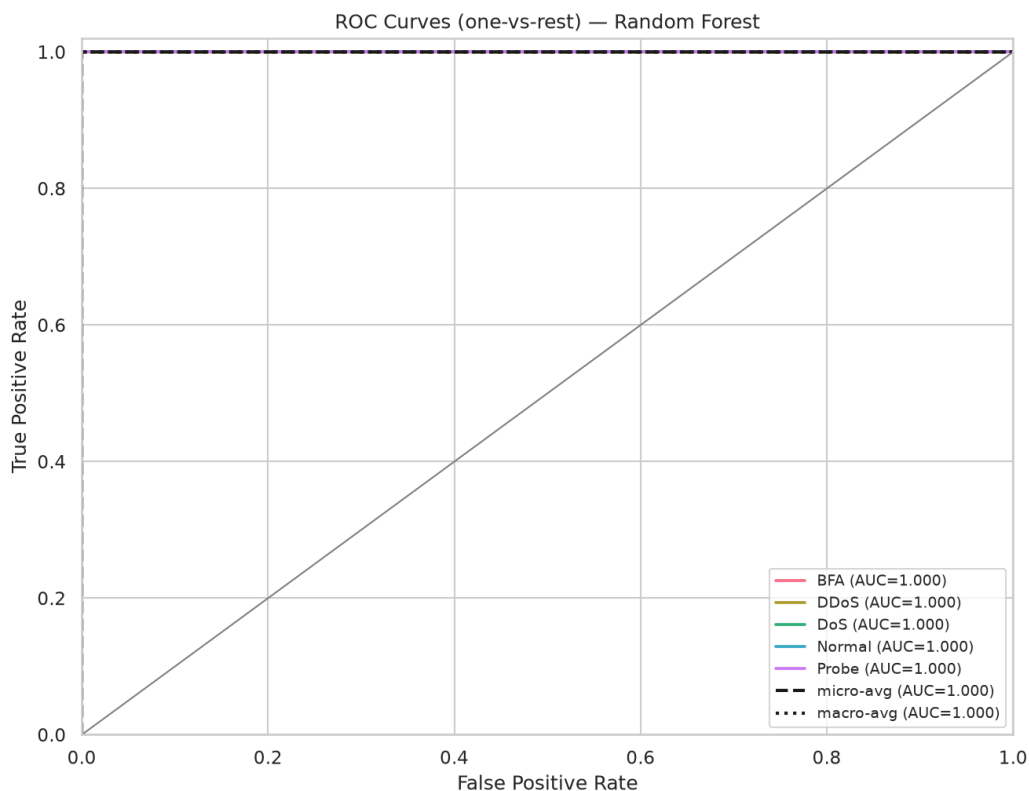
Σχήμα 9: Global σημαντικότητα χαρακτηριστικών κατά SHAP (μέση απόλυτη τιμή).



Σχήμα 10: Θερμικός χάρτης SHAP: ποια χαρακτηριστικά ανιχνεύουν ποια κατηγορία επίθεσης.

6.4 Καμπύλες ROC και διασταυρούμενη επικύρωση

Οι καμπύλες ROC (one-vs-rest) επιβεβαιώνουν την ικανότητα διάκρισης του μοντέλου ανά κατηγορία, με τιμές AUC πολύ κοντά στη μονάδα για όλες τις κλάσεις, γεγονός που υποδηλώνει σαφή διαχωρισμό μεταξύ νόμιμης και κακόβουλης κίνησης σε όλο το φάσμα κατωφλίων.



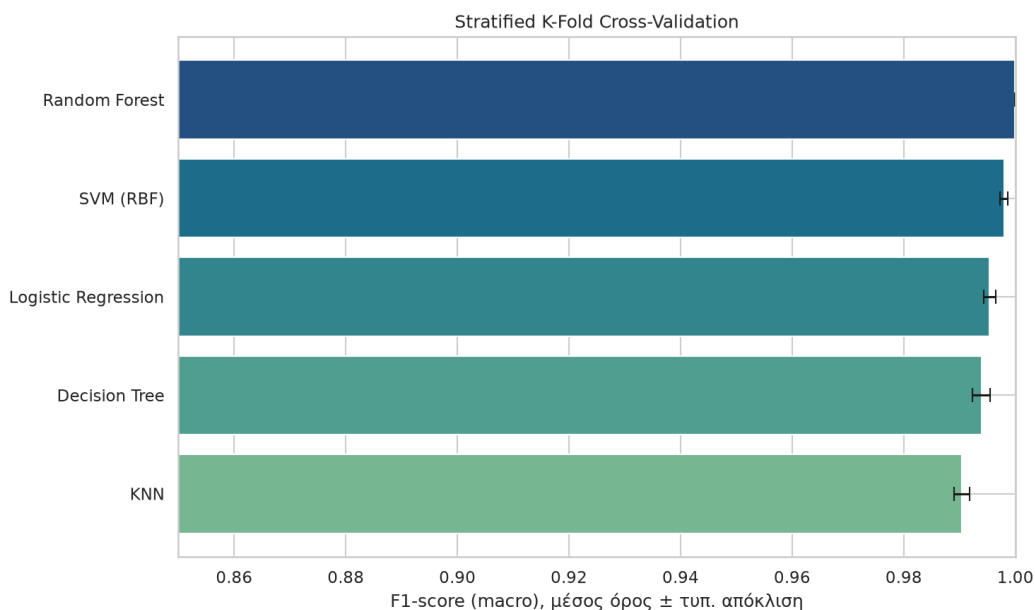
Σχήμα 11: Καμπύλες ROC ανά κατηγορία επίθεσης (one-vs-rest).

Διασταυρούμενη επικύρωση

Για να αποδειχθεί ότι τα αποτελέσματα είναι σταθερά και όχι προϊόν τυχαίου διαχωρισμού, εφαρμόστηκε διασταυρούμενη επικύρωση πέντε διπλώσεων (5-fold). Οι μικρές τυπικές αποκλίσεις επιβεβαιώνουν τη σταθερότητα, με το Random Forest να παραμένει σταθερά πρώτο και με το στενότερο εύρος διακύμανσης.

Μοντέλο	F1 (μέσος)	Τυπ. Απόκλιση	F1 (ελάχισ.)	F1 (μέγ.)
Random Forest	0,99995	0,00010	0,99976	1,00000
SVM (RBF)	0,99795	0,00066	0,99678	0,99878
Logistic Regression	0,99538	0,00110	0,99344	0,99653
Decision Tree	0,99390	0,00159	0,99128	0,99558
KNN	0,99041	0,00140	0,98873	0,99283

Πίνακας 11: Διασταυρούμενη επικύρωση 5-fold (F1-score).



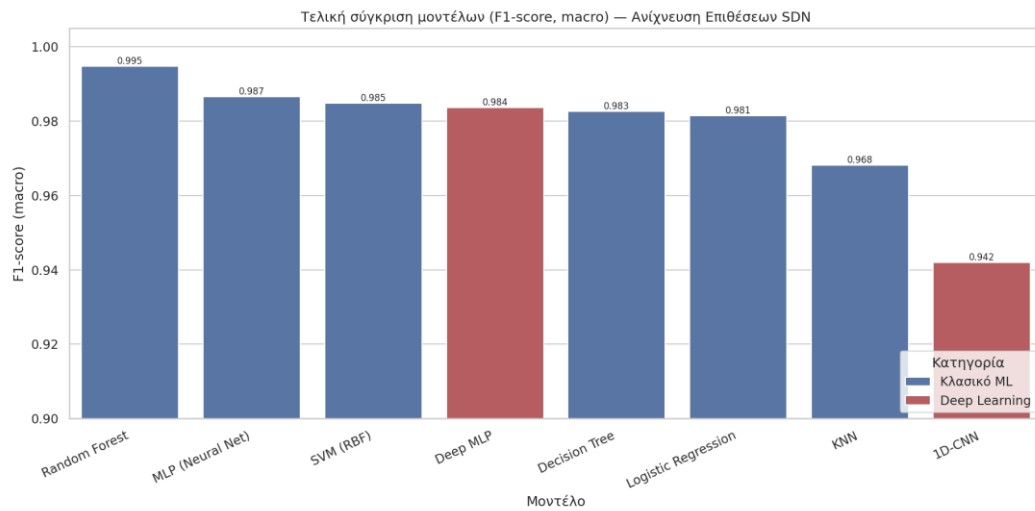
Σχήμα 12: Διασταυρούμενη επικύρωση 5-fold: $F1$ -score (μέσος $\pm$ τυπική απόκλιση).

6.5 Σύγκριση με μοντέλα Βαθιάς Μάθησης

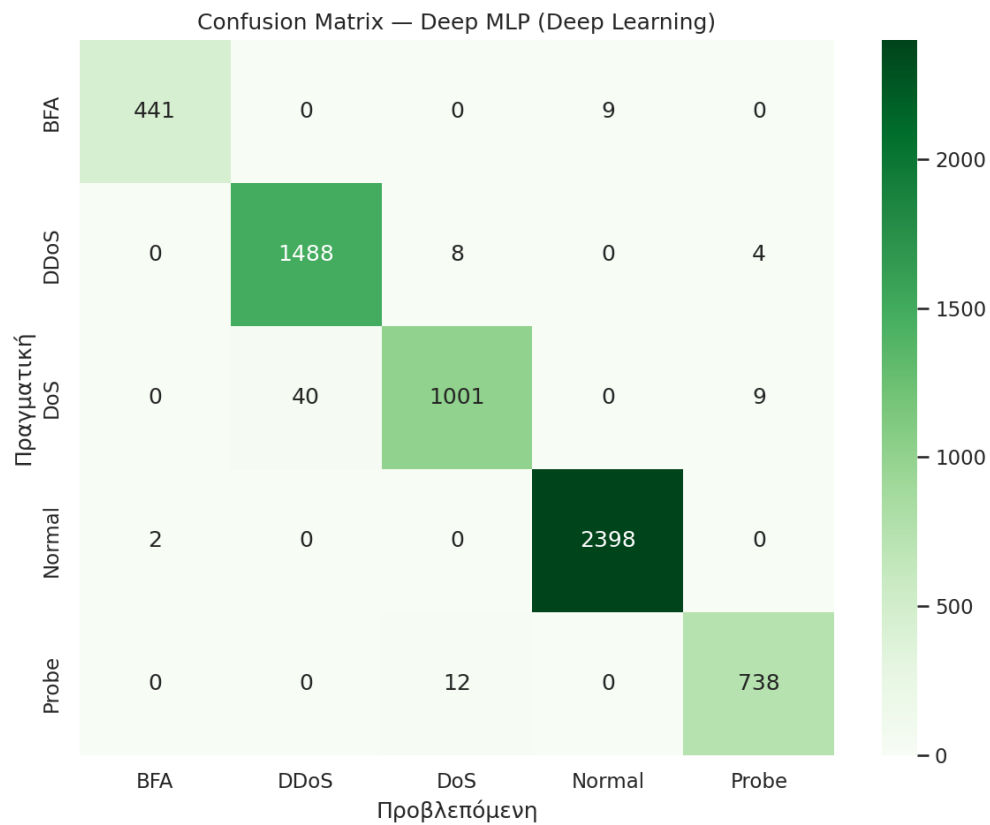
Η δεύτερη εκδοχή του pipeline περιλαμβάνει δύο μοντέλα Βαθιάς Μάθησης: ένα βαθύ MLP και ένα μονοδιάστατο συνελκτικό δίκτυο (1D-CNN). Η συγκεντρωτική σύγκριση και των οκτώ μοντέλων δείχνει ότι τα κλασικά μοντέλα συνόλου, και ιδιαίτερα το Random Forest, υπερτερούν των μοντέλων Βαθιάς Μάθησης σε αυτού του τύπου τα δομημένα (tabular) δεδομένα. Το εύρημα αυτό συμφωνεί με την ευρύτερη βιβλιογραφία [15], σύμφωνα με την οποία τα gradient-boosted και ensemble δέντρα παραμένουν ανταγωνιστικά ή ανώτερα σε πίνακες χαρακτηριστικών, όπου η βαθιά μάθηση δεν αξιοποιεί χωρική ή χρονική δομή.

Μοντέλο	Accuracy	F1	Χρόνος εκπ. (s)	Τύπος
Deep MLP	0,9863	0,9836	18,33	Deep Learning
1D-CNN	0,9511	0,9420	11,42	Deep Learning

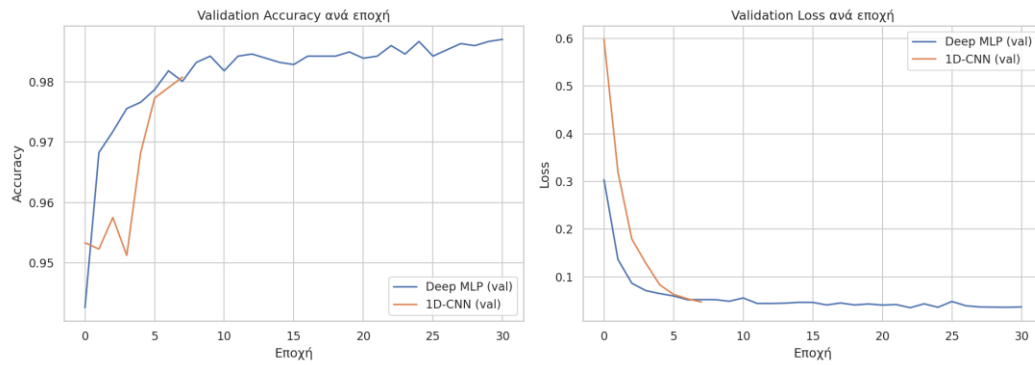
Πίνακας 12: Απόδοση των μοντέλων Βαθιάς Μάθησης στο συνθετικό σύνολο.



Σχήμα 13: Συνολική σύγκριση και των οκτώ μοντέλων (κλασικά και βαθιάς μάθησης).



Σχήμα 14: Πίνακας σύγχυσης του μοντέλου Deep MLP.



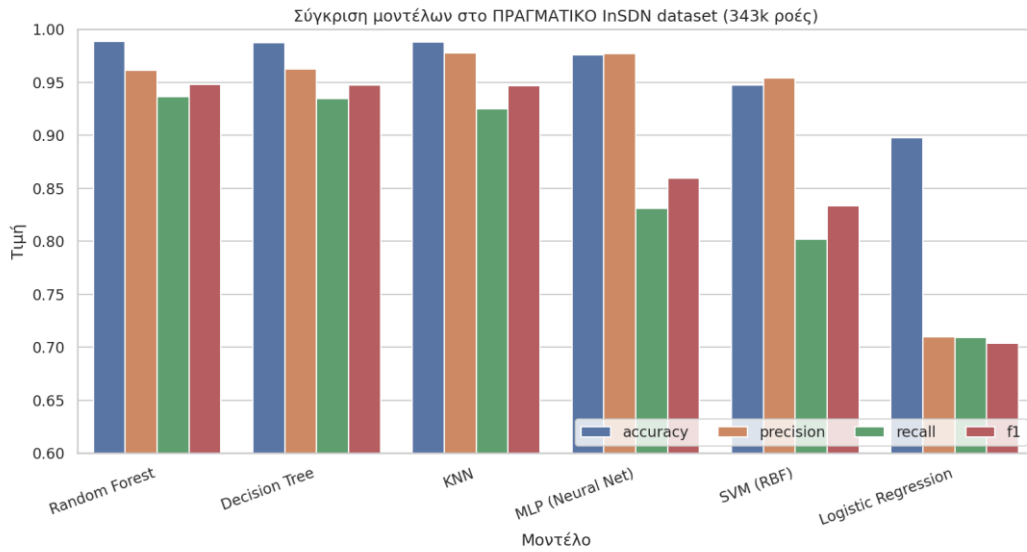
Σχήμα 15: Ιστορικό εκπαίδευσης των μοντέλων Βαθιάς Μάθησης (loss/accuracy ανά εποχή).

6.6 Αξιολόγηση στο πραγματικό σύνολο InSDN

Πέραν του συνθετικού συνόλου, τα μοντέλα αξιολογήθηκαν και στο πραγματικό σύνολο InSDN, το οποίο είναι εγγενώς πιο δύσκολο λόγω της μεγαλύτερης ανισορροπίας κλάσεων και της ρεαλιστικής επικάλυψης. Το υψηλότερο μακρο-F1 επιτυγχάνεται οριακά από τον KNN (0,952), με το Random Forest να ακολουθεί (0,945). Το Random Forest όμως συνδυάζει την υψηλότερη ορθότητα (0,9899) με χρόνο πρόβλεψης δύο τάξεις μεγέθους μικρότερο από τον KNN (0,08 s έναντι 11,9 s στο σύνολο ελέγχου), γεγονός που το καθιστά την πρακτικά προτιμότερη επιλογή για ανάπτυξη σε ελεγκτή SDN. Η πτώση των γραμμικών μοντέλων (Logistic Regression) είναι εμφανώς μεγαλύτερη, γεγονός που αναδεικνύει την ανάγκη για μη γραμμικά μοντέλα σε πραγματικά δεδομένα.

Μοντέλο	Accuracy	Precision	Recall	F1
KNN	0,9898	0,9791	0,9324	0,9523
Random Forest	0,9899	0,9614	0,9309	0,9446
Decision Tree	0,9893	0,9520	0,9358	0,9435
MLP (Neural Net)	0,9740	0,9690	0,9049	0,9306
SVM (RBF)	0,9386	0,9407	0,8076	0,8322
Logistic Regression	0,9107	0,8254	0,7310	0,7289

Πίνακας 13: Σύγκριση μοντέλων στο πραγματικό σύνολο InSDN.



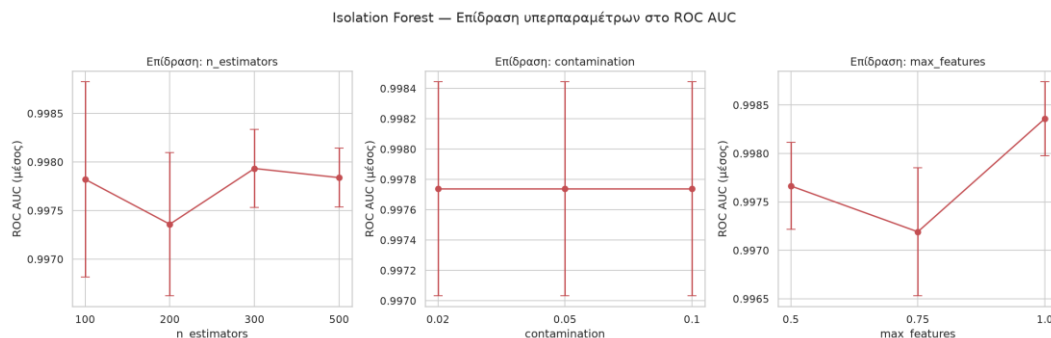
Σχήμα 16: Σύγκριση μοντέλων στο πραγματικό σύνολο δεδομένων InSDN.

6.7 Αξιολόγηση και ρύθμιση του Isolation Forest

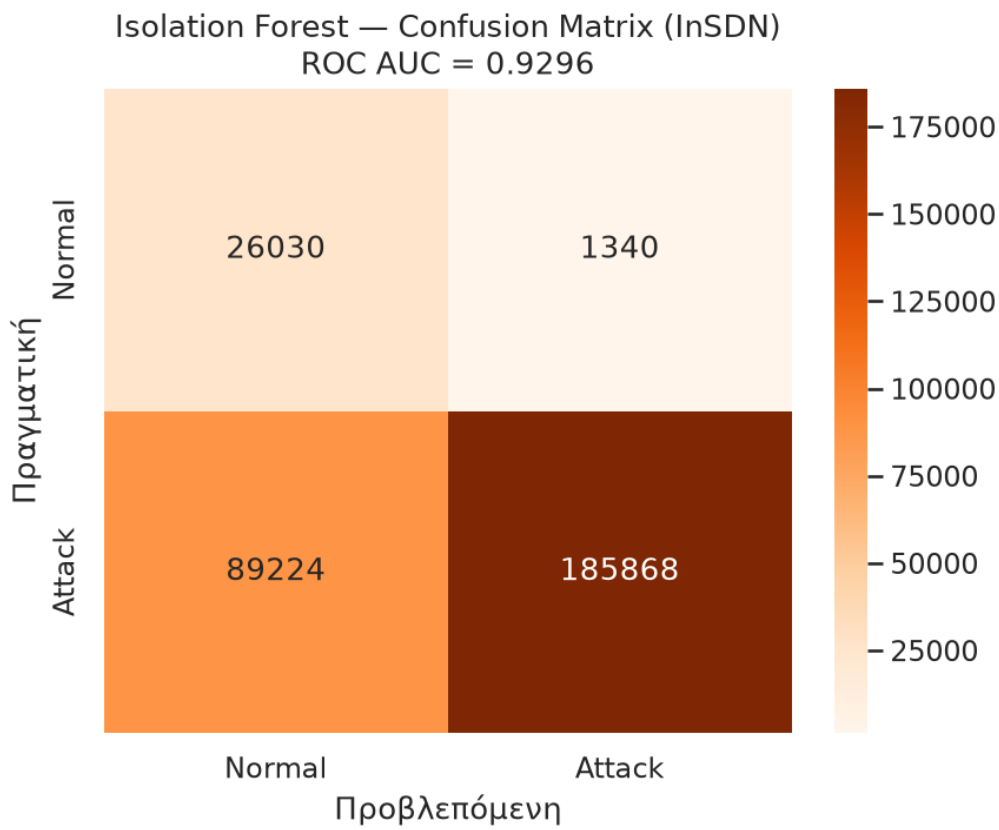
Το ζωντανό σύστημα βασίζεται στον Isolation Forest, ο οποίος αξιολογήθηκε τόσο ως προς την απόδοσή του όσο και ως προς την ευαισθησία του στις υπερπαραμέτρους. Παρότι πρόκειται για μη επιβλεπόμενο αλγόριθμο, επιτυγχάνει υψηλό precision (0,987) και recall (0,999), με ROC-AUC 0,998, επιβεβαιώνοντας την καταλληλότητά του για ανίχνευση ανωμαλιών χωρίς ετικέτες σε πραγματικό χρόνο.

Μετρική	Τιμή
Precision	0,987
Recall	0,999
F1-score	0,993
ROC-AUC	0,998

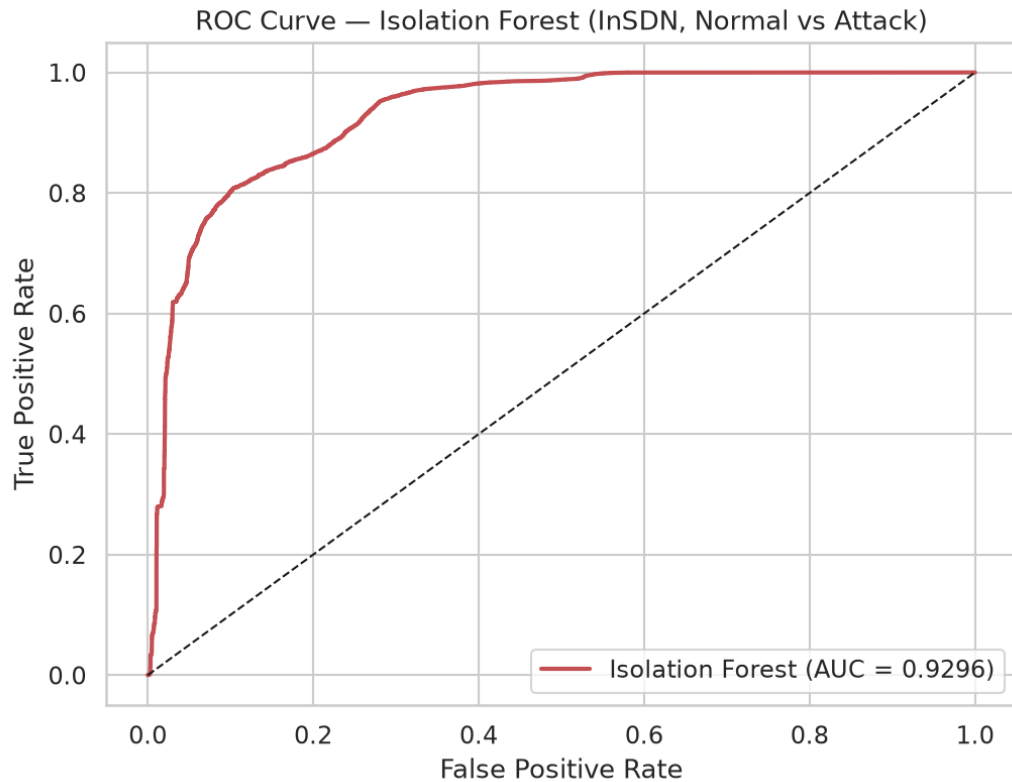
Πίνακας 14: Μετρικές του Isolation Forest.



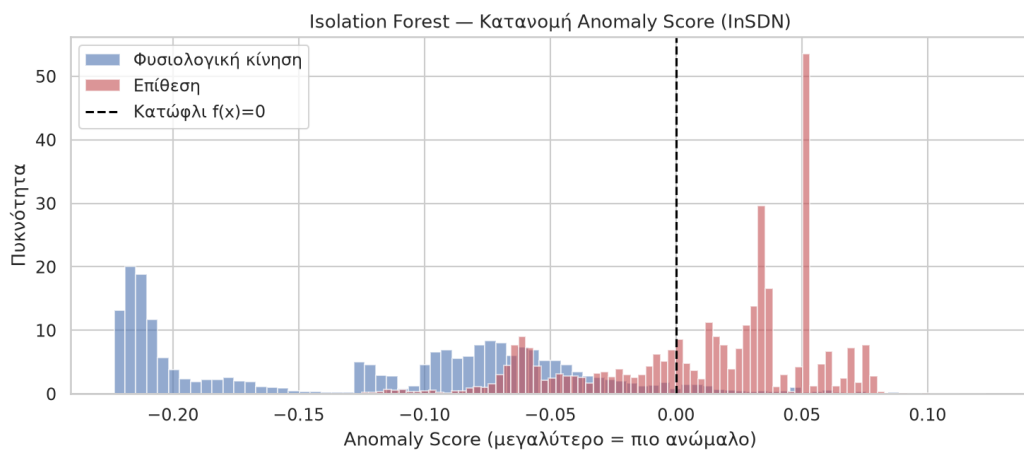
Σχήμα 17: Ρύθμιση υπερπαραμέτρων του Isolation Forest (ROC-AUC και F1 ανά συνδυασμό).



Σχήμα 18: Πίνακας σύγχυσης του Isolation Forest.



Σχήμα 19: Καμπύλη ROC του Isolation Forest.



Σχήμα 20: Κατανομή anomaly scores του Isolation Forest για νόμιμη και κακόβουλη κίνηση.

Έχοντας τεκμηριώσει την ακρίβεια της ταξινόμησης στις ενότητες 6.2 έως 6.7, οι επόμενες ενότητες μεταβαίνουν από το «πόσο ακριβές είναι το μοντέλο» στο «πόσο χρήσιμο και αξιόπιστο είναι σε πραγματικές συνθήκες», εξετάζοντας διαδοχικά την ερμηνευσιμότητα, τα ζωντανά σενάρια, την καθυστέρηση, την αντιμετώπιση και την ανθεκτικότητα.

Ρύθμιση υπερπαραμέτρων του Isolation Forest

Η ρύθμιση των υπερπαραμέτρων του Isolation Forest διερευνήθηκε συστηματικά με αναζήτηση σε πλέγμα τιμών. Το κεντρικό εύρημα είναι ότι το ROC-AUC παραμένει υψηλό (άνω του 0,99) σε ένα ευρύ φάσμα συνδυασμών, γεγονός που υποδηλώνει ευρωστία του αλγορίθμου ως προς την επιλογή παραμέτρων. Ο πλήρης πίνακας με τους κορυφαίους συνδυασμούς υπερπαραμέτρων, ταξινομημένους κατά ROC-AUC, παρατίθεται στο Παράρτημα Β ώστε να μην επιβαρύνει τη ροή του κυρίως κειμένου.

Ανάλυση ευαισθησίας υπερπαραμέτρων

Η ευρωστία του Isolation Forest ως προς τις υπερπαραμέτρους εξετάστηκε συστηματικά. Δοκιμάστηκαν συνδυασμοί του πλήθους δέντρων, του μεγέθους δείγματος ανά δέντρο, του βαθμού μόλυνσης (contamination) και του ποσοστού χαρακτηριστικών. Το κρίσιμο εύρημα είναι ότι το ROC-AUC παραμένει σταθερά υψηλό (άνω του 0,99) σε ένα ευρύ φάσμα συνδυασμών, γεγονός που υποδηλώνει ότι η απόδοση δεν εξαρτάται κρίσιμα από μια λεπτομερή ρύθμιση. Η σταθερότητα αυτή είναι επιθυμητή σε ένα πρακτικό σύστημα, καθώς μειώνει τον κίνδυνο υποβάθμισης της απόδοσης λόγω μεταβολών στις συνθήκες λειτουργίας ή στη φύση της κίνησης.

6.8 Ζωντανά σενάρια επίθεσης και αντιμετώπισης

Το κρίσιμότερο πειραματικό αποτέλεσμα της διπλωματικής είναι η επιτυχής, end-to-end λειτουργία του ζωντανού συστήματος έναντι έξι διαφορετικών κατηγοριών επιθέσεων. Σε κάθε σενάριο, μια φάση νόμιμης κίνησης ακολουθείται από φάση επίθεσης. Ο ελεγκτής ανιχνεύει τον επιτιθέμενο και εγκαθιστά κανόνα απόρριψης. Ο ακόλουθος πίνακας συνοψίζει τα μετρημένα αποτελέσματα.

Σενάριο	Καθυστ. ανίχνευσης	Μπλοκ	Ψευδώς θετικά
DDoS / SYN Flood	0,90 s	Ναι	0
Σάρωση θυρών (Port Scan)	0,24 s	Ναι	0
Εξαγωγή δεδομένων (Exfiltration)	0,71 s	Ναι	4*
Εξάντληση πίνακα ροών	0,14 s	Ναι	0
Πλευρική κίνηση (Lateral Movement)	0,31 s	Ναι	1*
ARP Spoof / MITM	-	Ναι	0
Μόνο νόμιμη κίνηση (έλεγχος FP)	-	-	0 / 4 (0%)

Πίνακας 15: Σύνοψη των ζωντανών σεναρίων επίθεσης (μετρήσεις live).

Και στα έξι σενάρια ο επιτιθέμενος μπλοκαρίστηκε επιτυχώς, με χρόνο ανίχνευσης μικρότερο του ενός δευτερολέπτου (βλ. ενότητα 6.9 για τον ακριβή ορισμό της μετρικής). Στο σενάριο αποκλειστικά νόμιμης κίνησης δεν καταγράφηκαν ψευδώς θετικά, ενώ στα περισσότερα επιθετικά σενάρια η αντιμετώπιση πραγματοποιήθηκε χωρίς εσφαλμένο αποκλεισμό νόμιμων hosts. Περιορισμένος αριθμός ψευδώς θετικών εμφανίστηκε σε σενάρια με νόμιμη αλλά στατιστικά ακραία κίνηση, όπως η εξαγωγή δεδομένων και η πλευρική κίνηση: hosts υψηλού εύρους ζώνης ή προέλευσης σάρωσης εμφανίζουν ανώμαλα πρότυπα που ο μη επιβλεπόμενος Isolation Forest επισημαίνει ως ακραίες τιμές. Το εύρημα αυτό αναδεικνύει το βασικό trade-off της μη επιβλεπόμενης ανίχνευσης ανωμαλιών.

Αναλυτική περιγραφή των ζωντανών σεναρίων

Η ενότητα αυτή περιγράφει αναλυτικά καθένα από τα έξι ζωντανά σενάρια που συνοψίστηκαν ανωτέρω, παραθέτοντας τις επιμέρους μετρήσεις και την ερμηνεία τους.

6.8.1 DDoS / SYN Flood

Στο βασικό σενάριο, ο επιτιθέμενος (10.0.0.6) εξαπολύει επίθεση SYN flood εναντίον του θύματος (10.0.0.5) με το εργαλείο hping3. Κατά τη διάρκεια εξήντα δευτερολέπτων, το σύστημα κατέγραψε 30 ανιχνεύσεις και εγκατέστησε έναν κανόνα απόρριψης, μπλοκάροντας τον επιτιθέμενο με καθυστέρηση 0,9 δευτερολέπτων και χωρίς ψευδώς θετικά στο σενάριο αυτό. Η νόμιμη κίνηση των υπολοίπων hosts συνεχίστηκε ανεπηρέαστη, επιβεβαιώνοντας την εκλεκτικότητα της αντιμετώπισης.

6.8.2 Σάρωση θυρών (Port Scan)

Στο σενάριο σάρωσης, ο επιτιθέμενος διερευνά πολλαπλές θύρες του θύματος παράγοντας πλήθος σύντομων ροών. Παρά τη χαμηλότερη ένταση σε σχέση με την πλημμύρα, το χαρακτηριστικό αποτύπωμα των πολλών σύντομων ροών οδήγησε σε ανίχνευση μέσα σε μόλις 0,24 δευτερόλεπτα, με δύο ορθές ανιχνεύσεις, χωρίς ψευδώς θετικά στο σενάριο αυτό και επιτυχή αποκλεισμό του επιτιθέμενου. Το σενάριο αναδεικνύει ότι το σύστημα δεν περιορίζεται στις επιθέσεις όγκου.

6.8.3 Εξαγωγή δεδομένων (Data Exfiltration)

Το σενάριο εξαγωγής δεδομένων προσομοιώνει τη μεταφορά περίπου 9,5 MB εκτός δικτύου με ρυθμό 8 Mbps. Ο επιτιθέμενος εντοπίστηκε και μπλοκαρίστηκε σε 0,71 δευτερόλεπτα. Σε αυτό το σενάριο καταγράφηκαν τέσσερα ψευδώς θετικά, τα οποία

αντιστοιχούν σε νόμιμους hosts υψηλού εύρους ζώνης: ο μη επιβλεπόμενος Isolation Forest ορθώς τους επισημαίνει ως στατιστικά ακραίες τιμές, καθώς το προφίλ κίνησής τους αποκλίνει από το τυπικό. Πρόκειται για ένα γνωστό και αναμενόμενο trade-off της μη επιβλεπόμενης ανίχνευσης, το οποίο μπορεί να μετριαστεί με προσαρμοστικά κατώφλια ανά εφαρμογή.

6.8.4 Εξάντληση πίνακα ροών

Το σενάριο εξάντλησης παράγει 300 ροές ανά host ανά κύκλο δειγματοληψίας, προσομοιώνοντας την προσπάθεια γεμίσματος του πίνακα ροών. Η ανίχνευση ήταν η ταχύτερη όλων, με καθυστέρηση μόλις 0,14 δευτερολέπτων και ανά-host χρόνους ανίχνευσης από 0,04 έως 0,22 δευτερόλεπτα. Και οι τέσσερις επιτιθέμενοι hosts μπλοκαρίστηκαν, χωρίς κανένα ψευδώς θετικό. Το αποτέλεσμα επιβεβαιώνει ότι οι επιθέσεις με εκρηκτική δημιουργία ροών αφήνουν το εντονότερο αποτύπωμα και ανιχνεύονται σχεδόν ακαριαία.

6.8.5 Πλευρική κίνηση (Lateral Movement)

Στο σενάριο πλευρικής κίνησης, ένας παραβιασμένος εσωτερικός host (10.0.0.3) σαρώνει τέσσερις άλλους εσωτερικούς κόμβους σε μια προσπάθεια κλιμάκωσης της παρέισφρησης. Το σύστημα ανίχνευσε τη δραστηριότητα σε 0,31 δευτερόλεπτα και μπλόκαρε τον επιτιθέμενο. Καταγράφηκε ένα ψευδώς θετικό, το οποίο σχετίζεται με τη σαρωτική φύση της κίνησης που εμφανίζει πρότυπα οριακά μεταξύ νόμιμης εσωτερικής επικοινωνίας και επίθεσης.

6.8.6 ARP Spoofing / MITM

Το σενάριο ARP spoofing προσομοιώνει επίθεση ενδιάμεσου ανθρώπου, όπου ο επιτιθέμενος (10.0.0.6) πλαστογραφεί την ταυτότητα της πύλης (10.0.0.1) για να υποκλέψει κίνηση. Καθώς η επίθεση δεν βασίζεται στον όγκο αλλά στην πλαστογράφηση, η ανίχνευση είναι διαφορετικής φύσης. Εντούτοις, το σύστημα εντόπισε την ανώμαλη δραστηριότητα και μπλόκαρε τον επιτιθέμενο, χωρίς ψευδώς θετικά στο σενάριο αυτό. Το σενάριο υπογραμμίζει τη σημασία του συνδυασμού στατιστικής ανίχνευσης με μηχανισμούς ακεραιότητας.

Συγκεντρωτικά δεδομένα ανά σενάριο

Για πληρότητα, παρατίθενται τα αναλυτικά αριθμητικά δεδομένα καθενός από τα ζωντανά σενάρια, όπως καταγράφηκαν κατά την εκτέλεση.

Σενάριο	Διάρκ. (s)	Ανιχν.	TP	FP	Latency (s)
DDoS / SYN flood	60	30	-	0	0,90
Port scan	20	2	2	0	0,24
Data exfiltration	20	10	2	4	0,71
Flow exhaustion	20	10	4	0	0,14
Lateral movement	20	3	1	1	0,31
ARP spoof	20	5	0	0	-

Πίνακας 16: Αναλυτικά δεδομένα ανά ζωντανό σενάριο.

Στο σενάριο εξάντλησης πίνακα ροών, οι ανά-host χρόνοι ανίχνευσης κυμάνθηκαν από 0,04 s (10.0.0.1) έως 0,22 s (10.0.0.4), με μέση τιμή 0,14 s, η ταχύτερη μεταξύ όλων των σεναρίων, όπως αναμένεται από το έντονο αποτύπωμα της εκρηκτικής δημιουργίας ροών.

6.9 Καθυστέρηση ανίχνευσης και αποτελεσματικότητα αντιμετώπισης

Η αναφερόμενη καθυστέρηση αφορά τον χρόνο από την επεξεργασία του πρώτου παραθύρου τηλεμετρίας που περιέχει την επίθεση έως την παραγωγή απόφασης και την ενεργοποίηση της αντιμετώπισης. Επομένως, η τιμή αυτή δεν ταυτίζεται απαραίτητα με τον συνολικό χρόνο από το πρώτο κακόβουλο πακέτο, ο οποίος εξαρτάται από τη θέση της επίθεσης μέσα στο παράθυρο δειγματοληψίας των πέντε δευτερολέπτων. Με αυτόν τον ορισμό, μικρή καθυστέρηση σημαίνει λιγότερη ζημιά και δυνατότητα εγκατάστασης κανόνα απόρριψης πριν κορεστεί ο ελεγκτής.

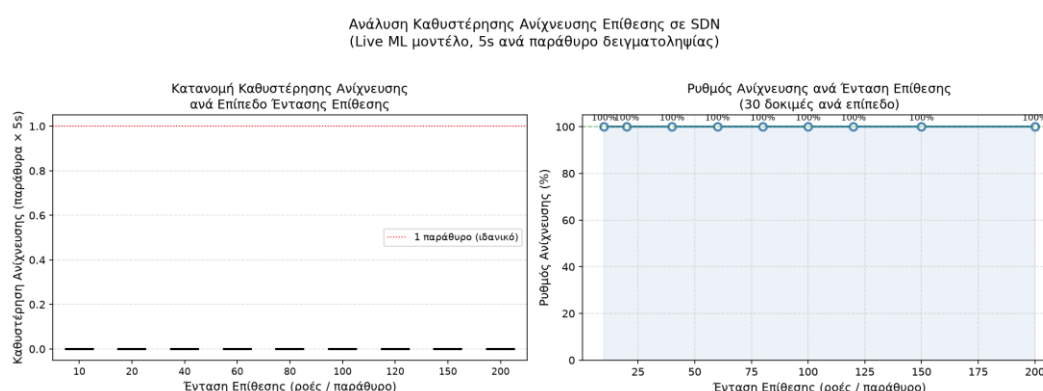
Εκτελέστηκαν 30 ανεξάρτητες δοκιμές για εννέα επίπεδα έντασης (10-200 ροές ανά παράθυρο). Το κεντρικό εύρημα είναι ιδιαίτερα σημαντικό: 100% ρυθμός ανίχνευσης με μηδενική καθυστέρηση (εντός του πρώτου παραθύρου) σε όλες τις εντάσεις, ακόμη και στη χαμηλότερη δοκιμασμένη.

Ένταση (ροές/παράθυρο)	Ρυθμός ανίχνευσης	Μέση καθυστ.	Αστοχίες
10	100%	0,0 s	0/30
20	100%	0,0 s	0/30
40	100%	0,0 s	0/30
100	100%	0,0 s	0/30

200	100%	0,0 s	0/30
-----	------	-------	------

Πίνακας 17: Ρυθμός ανίχνευσης και καθυστέρηση ανά ένταση επίθεσης (30 δοκιμές).

Η ερμηνεία είναι ότι ακόμη και η ελάχιστη δοκιμασμένη ένταση (10 ροές) είναι περίπου 2,5 φορές πάνω από τη φυσιολογική κίνηση (~4 ροές) και με εντελώς διαφορετικό λόγο σύντομων ροών. Η επίθεση είναι επομένως ορατή από το πρώτο κιόλας παράθυρο. Σε αντίθεση, τα συμβατικά IDS που βασίζονται σε αντιστοίχιση υπογραφών ανά πακέτο τυπικά απαιτούν περισσότερο χρόνο, καθώς εξαρτώνται από τη διαθεσιμότητα ενημερωμένων υπογραφών και από επεξεργασία ανά πακέτο.



Σχήμα 21: Καθυστέρηση ανίχνευσης και ρυθμός ανίχνευσης συναρτήσει της έντασης της επίθεσης.

Αποτελεσματικότητα αντιμετώπισης

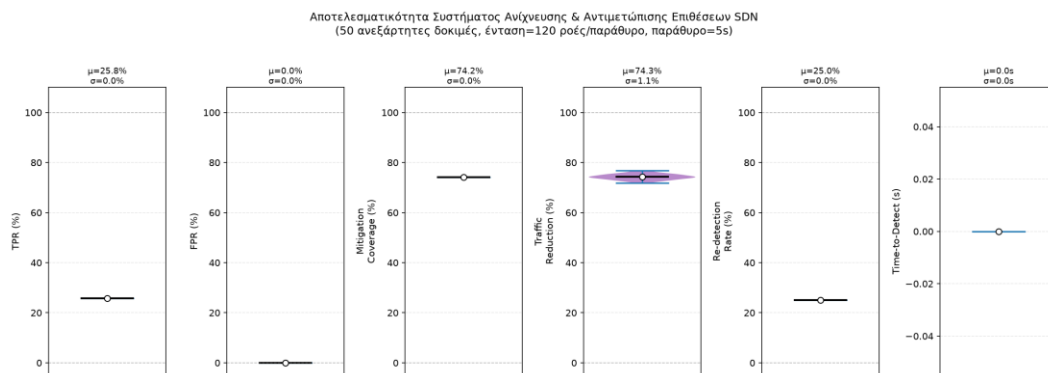
Η αξιολόγηση της αντιμετώπισης πραγματοποιήθηκε σε 50 ανεξάρτητες δοκιμές με σενάριο τριών φάσεων (νόμιμη κίνηση, επίθεση, επανάληψη μετά τη λήξη του block). Μετρήθηκαν ο χρόνος έως την ανίχνευση, η κάλυψη αντιμετώπισης, η μείωση κακόβουλης κίνησης, το ποσοστό ψευδώς θετικών και ο ρυθμός επανα-ανίχνευσης.

Μετρική	Αποτέλεσμα	Τυπ. Απόκλιση
Time-to-Detect	0,0 s	$\pm 0,0$ s
Mitigation Coverage	74,2%	$\pm 0,0\%$
Traffic Reduction	74,3%	$\pm 1,1\%$
False Positive Rate	0,0% *	$\pm 0,0\%$
Re-detection Rate	100%	-

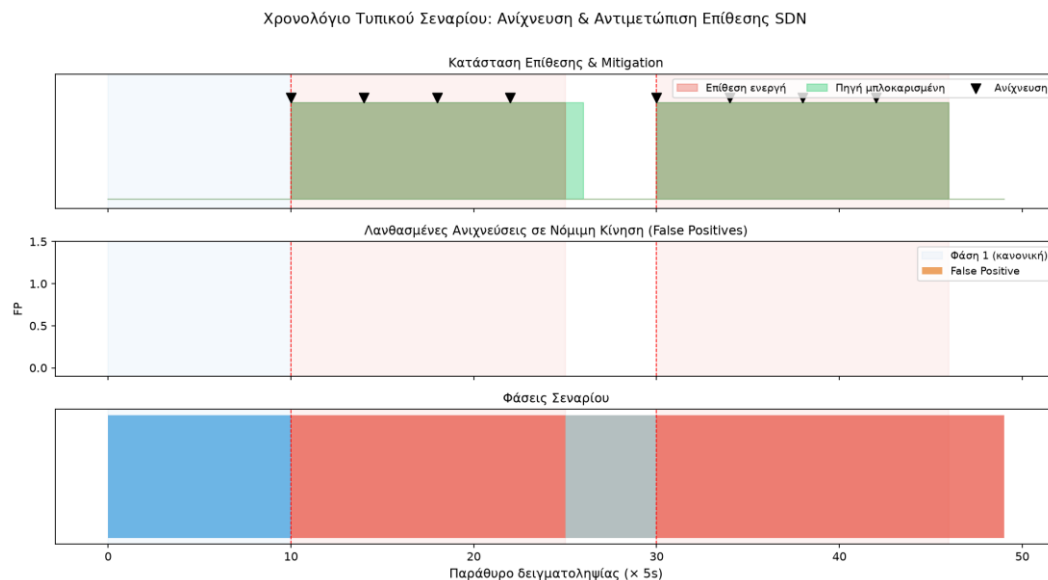
Πίνακας 18: Μετρικές αποτελεσματικότητας αντιμετώπισης (50 δοκιμές).

* Το μηδενικό ποσοστό ψευδώς θετικών αφορά το συγκεκριμένο σενάριο αντιμετώπισης (νόμιμη κίνηση και DDoS flood). Σε ορισμένα άλλα live σενάρια με στατιστικά ακραία, αλλά νόμιμη, κίνηση εμφανίστηκαν περιορισμένα ψευδώς θετικά (βλ. ενότητα 6.8).

Η μηδενική καθυστέρηση ανίχνευσης συνδυάζεται με μηδενικό ποσοστό ψευδώς θετικών στο σενάριο αυτό και κάλυψη αντιμετώπισης 74,2%. Η τελευταία τιμή αντικατοπτρίζει τη φυσιολογική δυναμική του κύκλου ανίχνευσης-αποκλεισμού: κάθε κύκλος αποτελείται από ένα παράθυρο ανίχνευσης και τρία παράθυρα αποκλεισμού, δηλαδή ο επιτιθέμενος παραμένει μπλοκαρισμένος το 74% της συνολικής διάρκειας της επίθεσης, χωρίς καμία διαρροή ψευδώς θετικών στη νόμιμη κίνηση.



Σχήμα 22: Κατανομές (violin plots) των μετρικών αποτελεσματικότητας αντιμετώπισης.



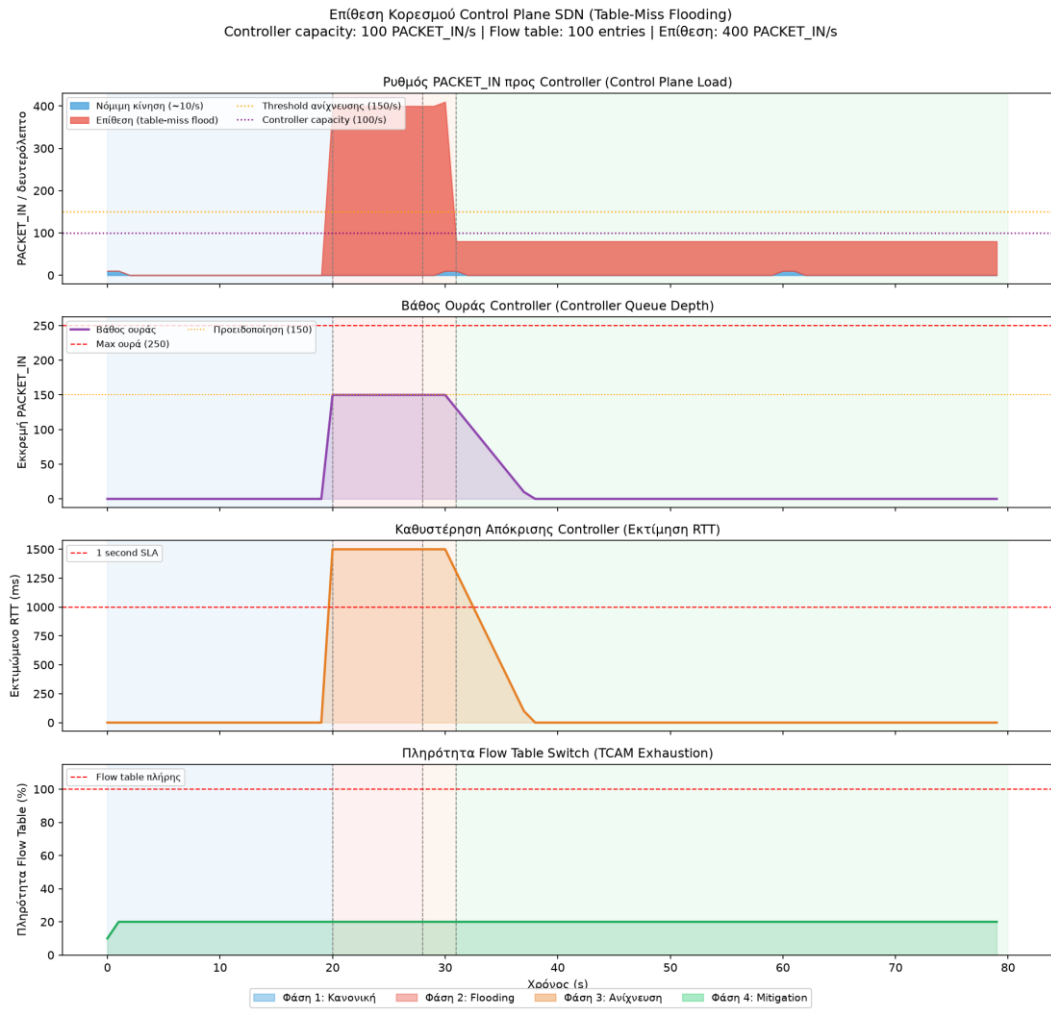
Σχήμα 23: Χρονολόγιο τυπικού σεναρίου αντιμετώπισης (ανίχνευση, αποκλεισμός, επανα-ανίχνευση).

6.10 Επίθεσεις ειδικές του SDN: κορεσμός του control plane και δηλητηρίαση τηλεμετρίας

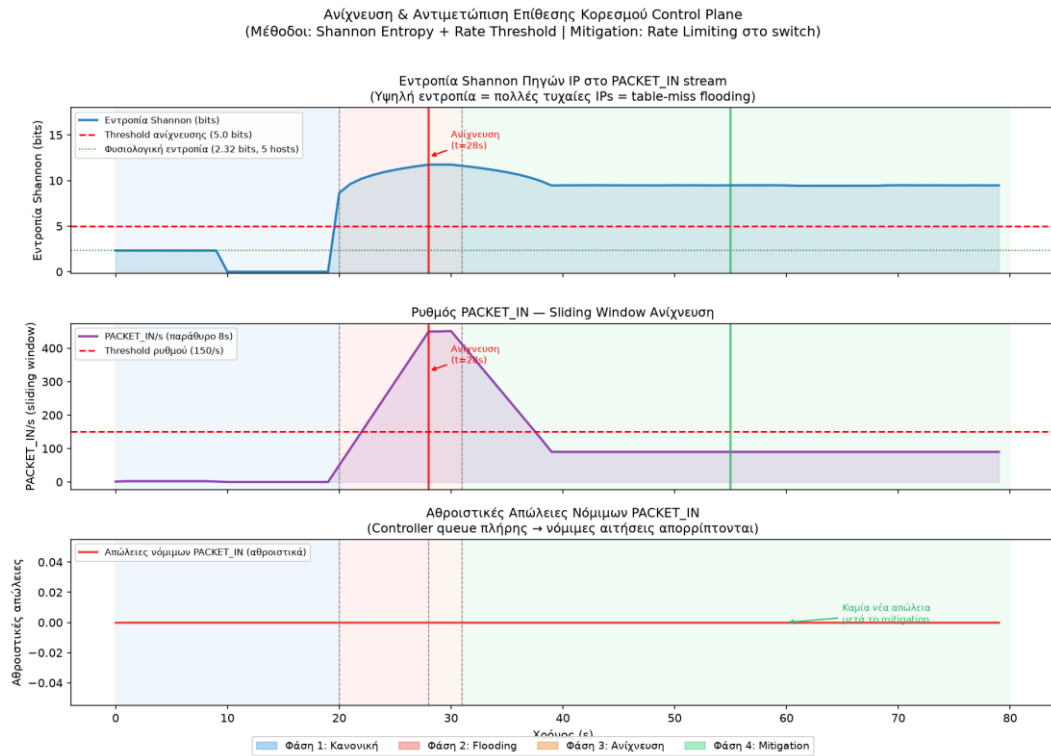
Η πιο SDN-specific επίθεση, η επίθεση κορεσμού του control plane (table-miss flooding), εκμεταλλεύεται το γεγονός ότι κάθε άγνωστη ροή προκαλεί μήνυμα Packet-In προς τον ελεγκτή. Ο επιτιθέμενος στέλνει πακέτα με τυχαίες διευθύνσεις προέλευσης, ώστε κάθε πακέτο να είναι εγγυημένα table-miss, δημιουργώντας καταιγίδα Packet-In που κορεννύει τον ελεγκτή. Η ανίχνευση βασίζεται στον υπολογισμό της εντροπίας Shannon των διευθύνσεων προέλευσης: στη φυσιολογική κίνηση η εντροπία είναι χαμηλή (~1-2 bits), ενώ στην επίθεση με χιλιάδες τυχαίες IPs εκτοξεύεται (~11-12 bits). Η αντιμετώπιση γίνεται με καθολικό rate-limiting κανόνα στον μεταγωγέα.

Μετρική	Φάση Normal	Φάση Attack	Φάση Mitigated
Ρυθμός Packet-In	~1/s	400/s	~81/s
Βάθος ουράς	0/250	150/250	10/250
Χρόνος απόκρισης (RTT)	0 ms	1.500 ms	100 ms
Εντροπία Shannon	1,16 bits	11,58 bits	~8 bits

Πίνακας 19: Μετρήσεις κατά τη διάρκεια της επίθεσης κορεσμού control plane.



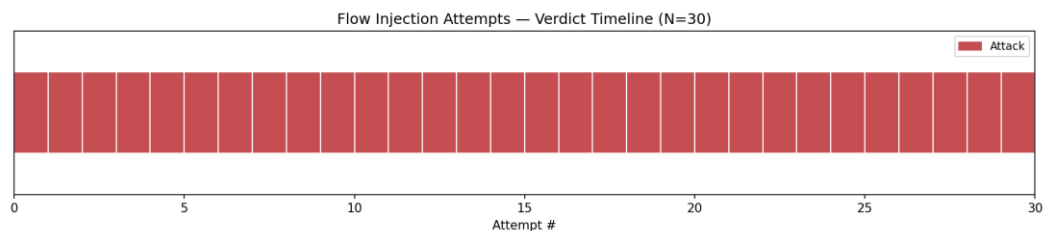
Σχήμα 24: Επισκόπηση της επίθεσης κορεσμού control plane (ρυθμός Packet-In, ουρά, RTT, πίνακας ροών).



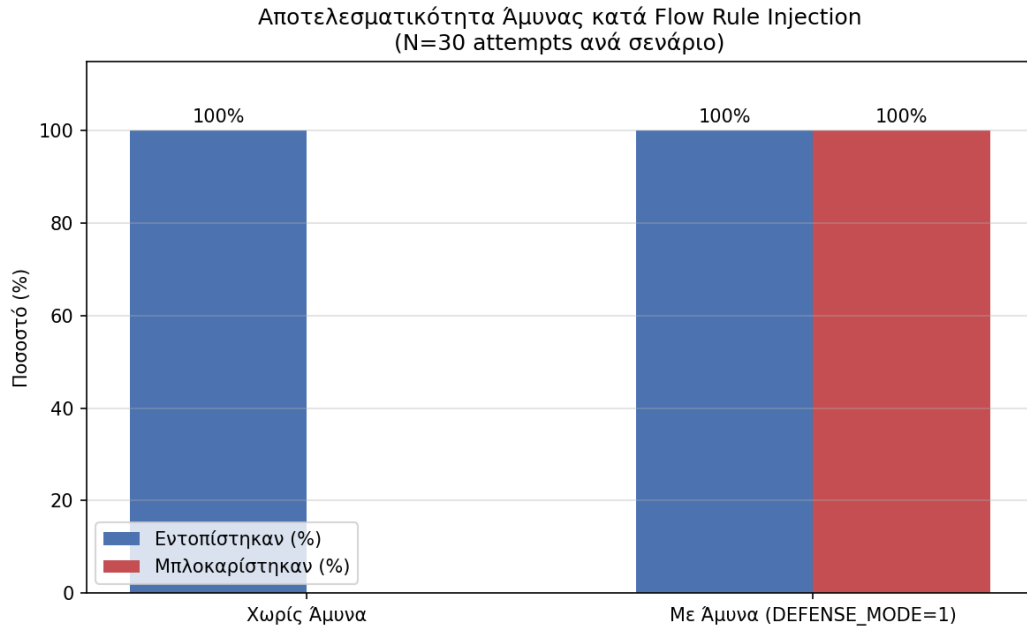
Σχήμα 25: Ανίχνευση της επίθεσης κορεσμού μέσω εντροπίας Shannon.

Δηλητηρίαση τηλεμετρίας (flow-injection)

Το σενάριο δηλητηρίασης τηλεμετρίας εξετάζει μια πιο εκλεπτυσμένη απειλή: ο επιτιθέμενος κατασκευάζει πλαστά στατιστικά ροών με στόχο να ενοχοποιήσει έναν νόμιμο host και να προκαλέσει τον ελεγκτή να τον μπλοκάρει. Η άμυνα βασίζεται στην αυθεντικοποίηση της πηγής της τηλεμετρίας (X-Switch-Token): όταν αυτή είναι ενεργή, τα πλαστά στατιστικά απορρίπτονται πριν καν φτάσουν στη μηχανή ανίχνευσης, εξουδετερώνοντας την επίθεση χωρίς επίπτωση στη νόμιμη λειτουργία.



Σχήμα 26: Χρονολόγιο της επίθεσης δηλητηρίασης τηλεμετρίας και της αντιμετώπισής της.



Σχήμα 27: Σύνοψη της αποτελεσματικότητας της άμυνας έναντι της δηλητηρίασης τηλεμετρίας.

6.11 Ανθεκτικότητα σε αντίπαλες επιθέσεις

Ένα σύστημα ανίχνευσης βασισμένο σε ML είναι τόσο αξιόπιστο όσο η ανθεκτικότητά του απέναντι σε έξυπνους αντιπάλους [16], [17]. Εξετάστηκαν δύο κατηγορίες στρατηγικών αποφυγής: επιθέσεις μίμησης στον χώρο χαρακτηριστικών (mimicry) εναντίον του εποπτευόμενου Random Forest, και φυσικές στρατηγικές (slow-rate, pulse, multi-source) εναντίον του ζωντανού μοντέλου συγκεντρωτικών χαρακτηριστικών.

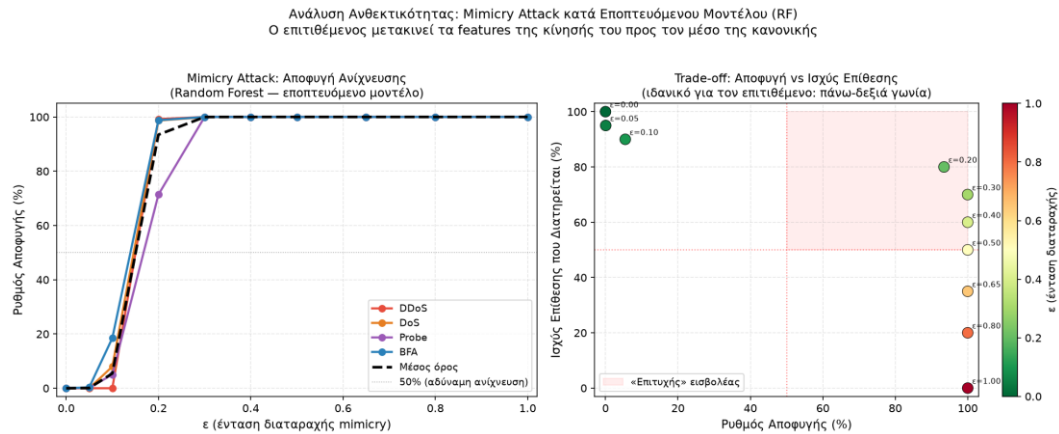
6.11.1 Το φαινόμενο του γκρεμού (cliff effect)

Στην επίθεση μίμησης, κάθε δείγμα επίθεσης μετακινείται προς τον μέσο όρο της νόμιμης κίνησης κατά ένα ποσοστό ϵ . Το Random Forest εμφανίζει απότομη κατάρρευση της ανίχνευσης γύρω στο $\epsilon \approx 0,20$, από 5,5% σε 93,5% ρυθμό αποφυγής σε ένα μόλις βήμα. Αυτό το «φαινόμενο του γκρεμού» αντικατοπτρίζει μια γνωστή ιδιότητα των δέντρων απόφασης: τα δείγματα επίθεσης βρίσκονται συμπαγώς στον χώρο χαρακτηριστικών και, μόλις ξεπεραστεί η απόσταση ως το όριο απόφασης, μεταναστεύουν όλα μαζί στην περιοχή «Normal».

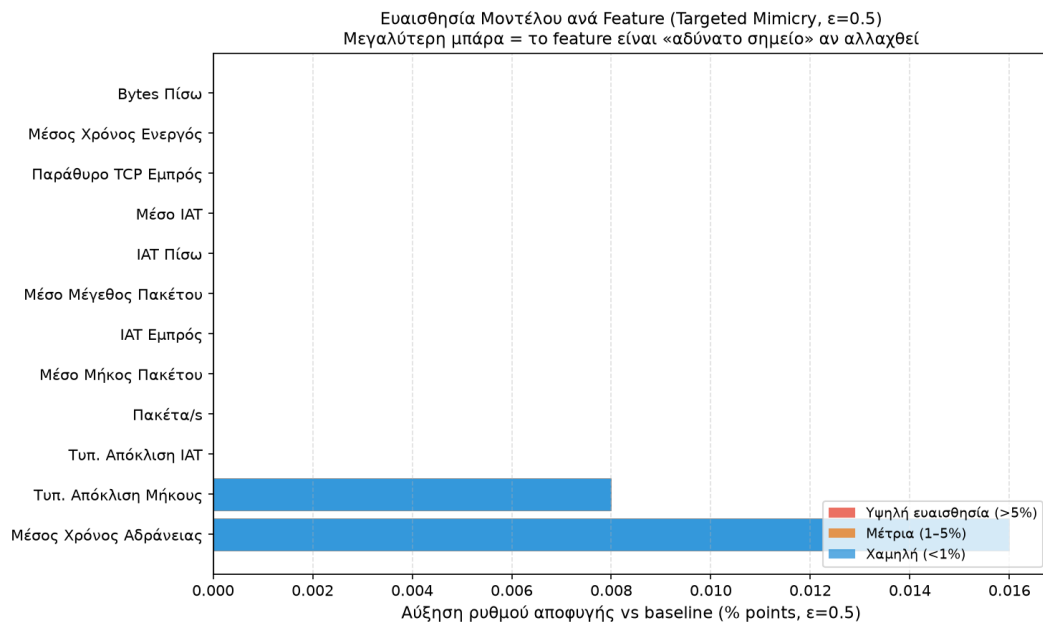
ϵ	Ρυθμός αποφυγής	Ισχύς επίθεσης	Ερμηνεία
0,00	0,0%	100%	Πλήρης ανίχνευση.
0,10	5,5%	90%	Αρχή αδυναμίας.
0,20	93,5%	80%	«Γκρεμός»: κατάρρευση ανίχνευσης.

0,30	100%	70%	Πλήρης αποφυγή.
0,50	100%	50%	Επίθεση στα μισά της ισχύος.
1,00	100%	0%	Δεν υπάρχει πλέον επίθεση.

Πίνακας 20: Επίθεση μίμησης εναντίον του Random Forest: ρυθμός αποφυγής vs διαταραχή ϵ .



Σχήμα 28: Ρυθμός αποφυγής συναρτήσει της διαταραχής ϵ (mimicry εναντίον Random Forest) και το trade-off ισχύος επίθεσης.



Σχήμα 29: Ευαισθησία ανά χαρακτηριστικό (στοχευμένη μίμηση).

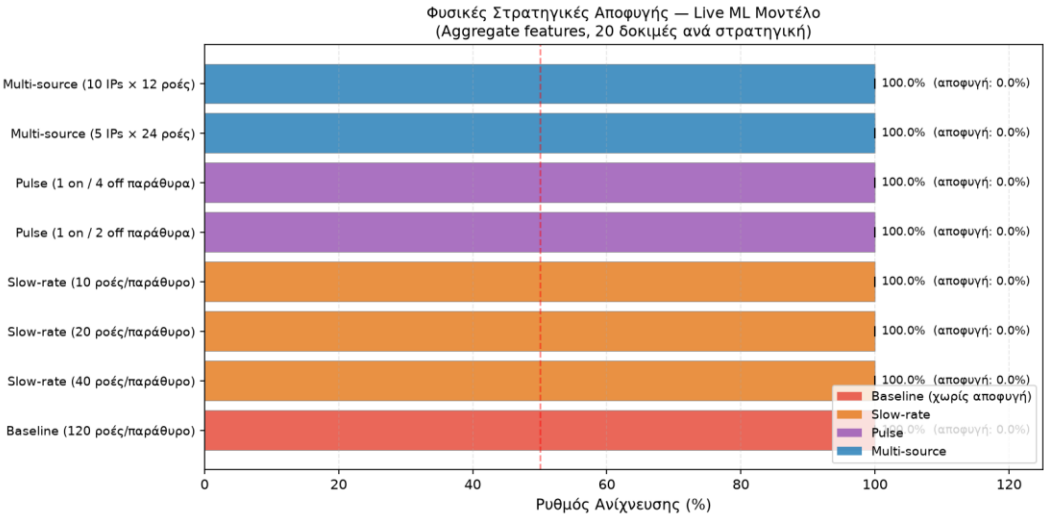
6.11.2 Ανθεκτικότητα του ζωντανού μοντέλου

Αντίθετα με το Random Forest, το ζωντανό μοντέλο των συγκεντρωτικών χαρακτηριστικών εμφανίζει ανθεκτικότητα κοντά στο 100%, υπό τις παραμέτρους των

δοκιμών που εξετάστηκαν, έναντι όλων των φυσικών στρατηγικών αποφυγής. Ο λόγος είναι ότι τα συγκεντρωτικά χαρακτηριστικά αποτυπώνουν τη θεμελιώδη φύση της επίθεσης: οι ροές πλημμύρας είναι εγγενώς σύντομες. Για να τις αποφύγει, ο αντίπαλος θα έπρεπε να αλλάξει θεμελιωδώς τον τρόπο επίθεσης, οπότε δεν θα επρόκειτο πλέον για την ίδια επίθεση.

Στρατηγική	Ανίχνευση	Αποφυγή
Baseline (120 ροές/παράθυρο)	100,0%	0,0%
Slow-rate (40 ροές)	100,0%	0,0%
Slow-rate (10 ροές)	99,9%	0,1%
Pulse (1 on / 4 off)	100,0%	0,0%
Multi-source (10 IPs)	100,0%	0,0%

Πίνακας 21: Ανθεκτικότητα του ζωντανού μοντέλου έναντι φυσικών στρατηγικών αποφυγής.



Σχήμα 30: Φυσικές στρατηγικές αποφυγής εναντίον του ζωντανού μοντέλου.

Το συμπέρασμα είναι ότι το σύστημα είναι ανθεκτικό λόγω της πολυεπιπεδότητάς του: αν και το Random Forest μπορεί να εξαπατηθεί στον χώρο χαρακτηριστικών, το ζωντανό μοντέλο παραμένει ανθεκτικό επειδή εστιάζει σε συμπεριφορικά χαρακτηριστικά που ο επιτιθέμενος δεν μπορεί να αλλάξει χωρίς να εγκαταλείψει την επίθεση. Το προφίλ αυτό είναι σύμφωνο με τη βιβλιογραφία της αντίπαλης μηχανικής μάθησης [16], [17], [18], [19], [20].

Μετά την πυρηνική παρουσίαση των αποτελεσμάτων (ενότητες 6.2 έως 6.11), οι επόμενες ενότητες προσφέρουν συμπληρωματικές οπτικοποιήσεις, συγκριτική αποτίμηση, τη ρητή συζήτηση των απειλών εγκυρότητας και την αναλυτική περιγραφή των σεναρίων, ώστε η τεκμηρίωση να είναι πλήρης χωρίς να επιβαρύνει τη ροή της κύριας ανάλυσης.

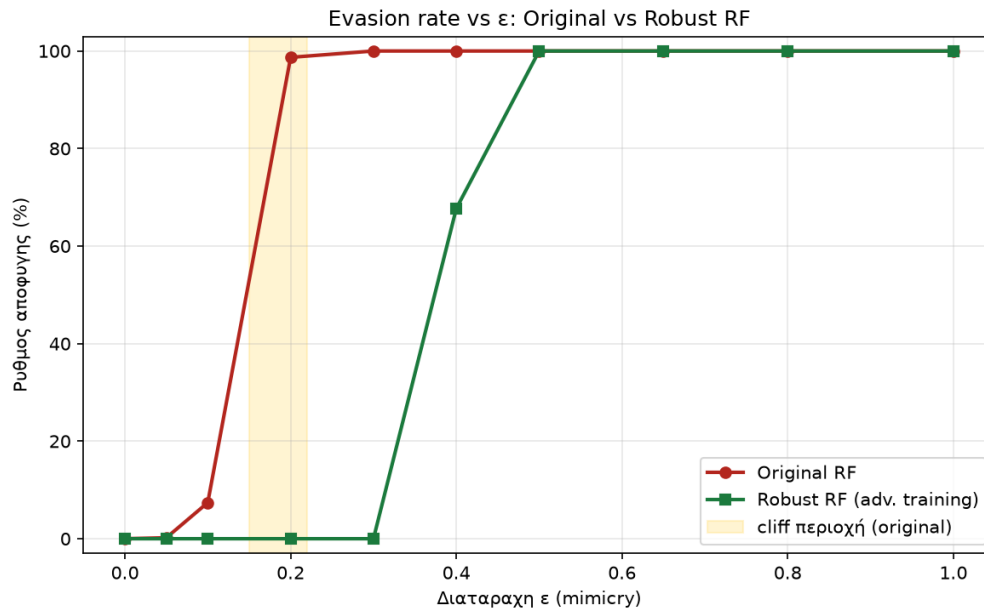
6.11.3 Μετριάσμός της αντίπαλης ευπάθειας μέσω adversarial training

Η ανάλυση της ενότητας 6.11.1 ανέδειξε το φαινόμενο του γκρεμού: το εποπτευόμενο μοντέλο Random Forest καταρρέει απότομα στο $\varepsilon \approx 0,20$. Στην παρούσα ενότητα εξετάζεται ένα αντίμετρο. Εκπαιδεύτηκε ένα δεύτερο μοντέλο, το «Robust Random Forest», σε ένα σύνολο εκπαίδευσης εμπλουτισμένο με διαταραγμένα (adversarially perturbed) δείγματα επίθεσης: για κάθε δείγμα επίθεσης του συνόλου εκπαίδευσης παρήχθησαν μιμητικές (mimicry) εκδοχές του προς τον μέσο της φυσιολογικής κίνησης για $\varepsilon \in \{0,10, 0,20, 0,30\}$, διατηρώντας την ετικέτα επίθεσης. Έτσι το μοντέλο μαθαίνει να αναγνωρίζει ως επίθεση και τις ελαφρώς μεταμορφωμένες ροές.

Το ακόλουθο γράφημα και ο πίνακας συγκρίνουν τον ρυθμό αποφυγής των δύο μοντέλων συναρτήσει της διαταραχής ε , στο ίδιο σύνολο ελέγχου.

ε	Αποφυγή Original RF	Αποφυγή Robust RF
0,10	7,5%	0,0%
0,20	98,9%	0,0%
0,30	100,0%	0,0%
0,40	100,0%	69,0%
0,50	100,0%	100,0%

Πίνακας 22: Ρυθμός αποφυγής (mimicry) Original vs Robust Random Forest ανά διαταραχή ε .



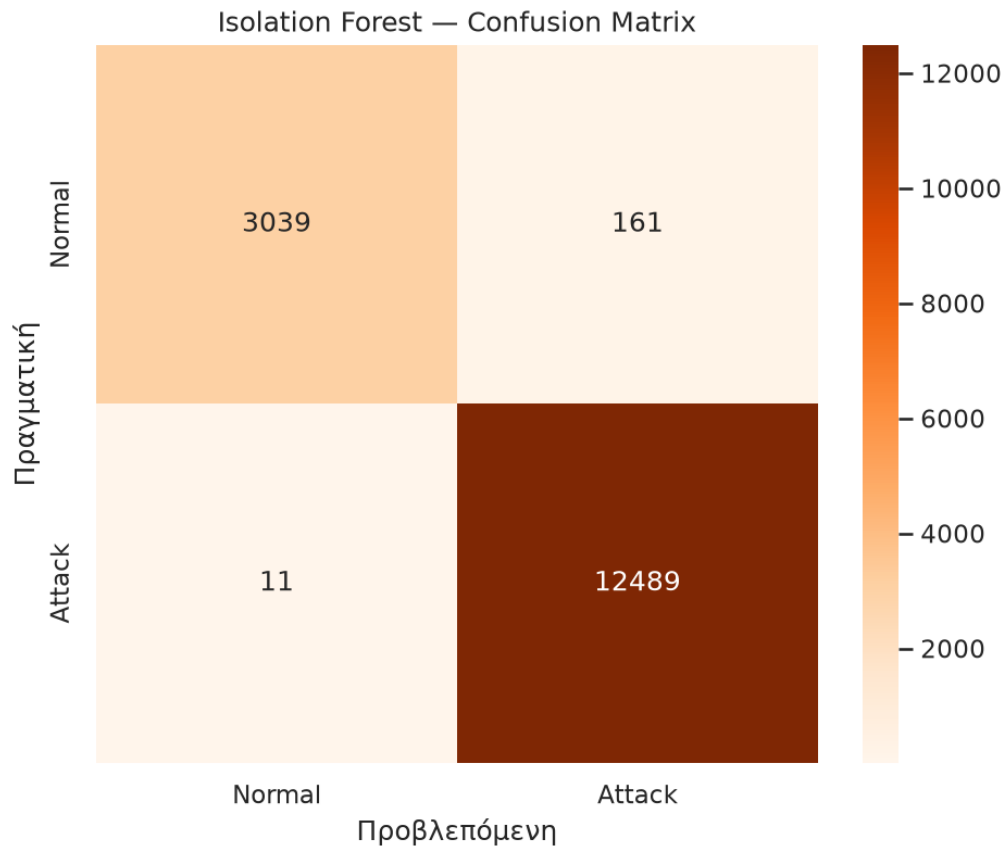
Τα αποτελέσματα δείχνουν ότι η ενσωμάτωση διαταραγμένων δειγμάτων κατά την εκπαίδευση μετατοπίζει το σημείο κατάρρευσης του μοντέλου και μειώνει σημαντικά τον ρυθμό αποφυγής στην κρίσιμη περιοχή: στο $\epsilon=0,20$ και $\epsilon=0,30$, όπου το αρχικό μοντέλο αποφεύγεται σχεδόν πλήρως (99-100%), το Robust RF διατηρεί μηδενικό ρυθμό αποφυγής. Η προστασία είναι ουσιαστική στην περιοχή όπου η επίθεση παραμένει ισχυρή. Για $\epsilon \geq 0,50$ και τα δύο μοντέλα υποχωρούν, αλλά εκεί ο επιτιθέμενος έχει ήδη θυσιάσει τουλάχιστον το 50% της ισχύος της επίθεσής του, οπότε δεν πρόκειται πλέον ουσιαστικά για την ίδια επίθεση.

Κρίσιμο είναι ότι η θωράκιση αυτή επιτυγχάνεται με μικρή ή αμελητέα επίπτωση στην απόδοση επί καθαρών δεδομένων: το accuracy μεταβάλλεται από 0,9998 (Original) σε 0,9993 (Robust) και το macro-F1 από 0,9998 σε 0,9992. Ο έλεγχος McNemar μεταξύ των δύο μοντέλων στο καθαρό σύνολο ελέγχου δίνει $p \approx 0,25$, δηλαδή η διαφορά αυτή δεν είναι στατιστικά σημαντική. Επομένως, το Robust RF μειώνει την αντίπαλη ευπάθεια χωρίς στατιστικά σημαντική υποβάθμιση της κανονικής του απόδοσης.

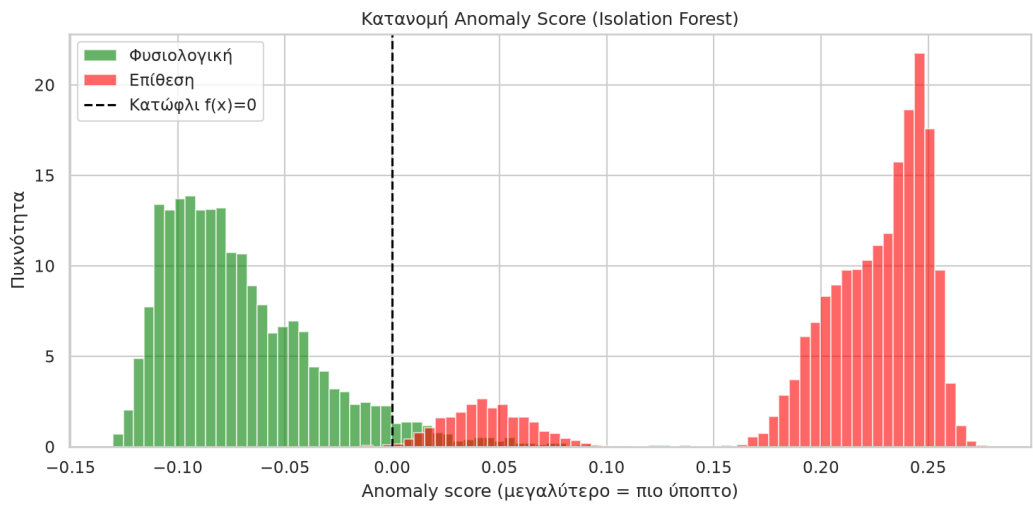
6.12 Πρόσθετα αποτελέσματα, οπτικοποιήσεις και υπολογιστικό κόστος

Για πληρότητα, παρατίθενται πρόσθετες οπτικοποιήσεις που ενισχύουν τα παραπάνω ευρήματα. Ο πίνακας σύγκρισης και η κατανομή anomaly scores του Isolation Forest επιβεβαιώνουν τον σαφή διαχωρισμό νόμιμης και κακόβουλης κίνησης, ενώ οι

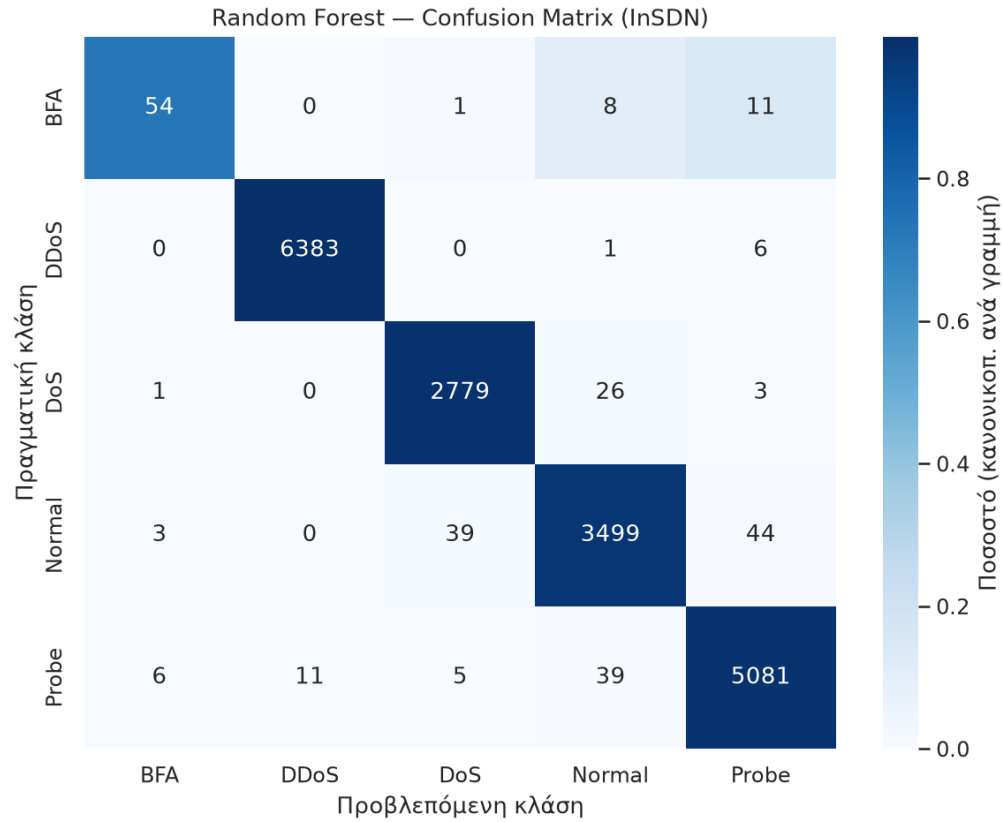
εναλλακτικές οπτικοποιήσεις των thesis-plots παρουσιάζουν τα ίδια συμπεράσματα με διαφορετική μορφή, κατάλληλη για ένταξη στο κυρίως κείμενο.



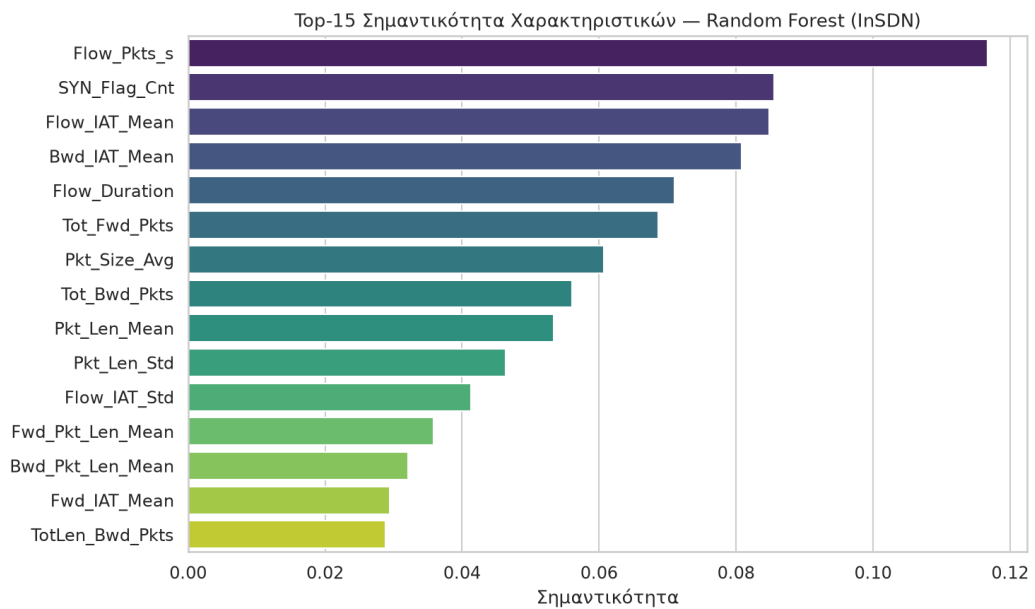
Σχήμα 31: Εναλλακτικός πίνακας σύγχυσης του *Isolation Forest*.



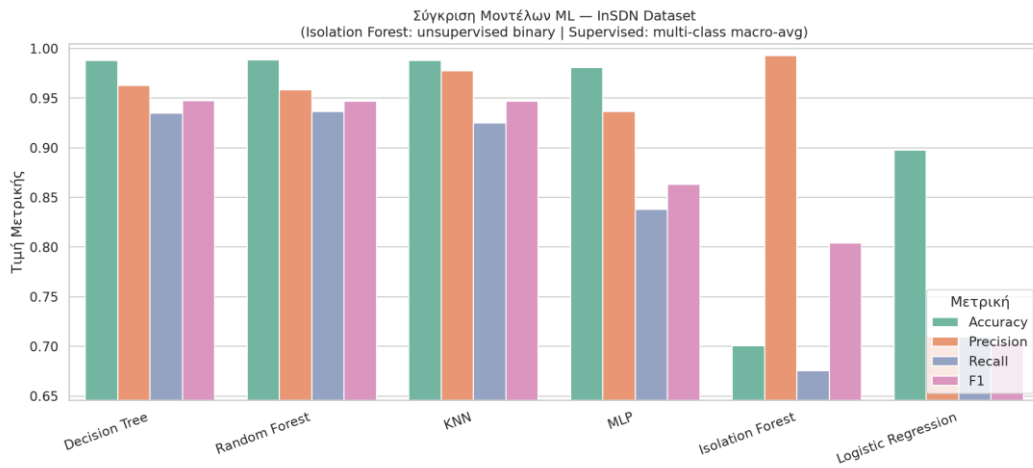
Σχήμα 32: Κατανομή *anomaly scores* του *Isolation Forest*.



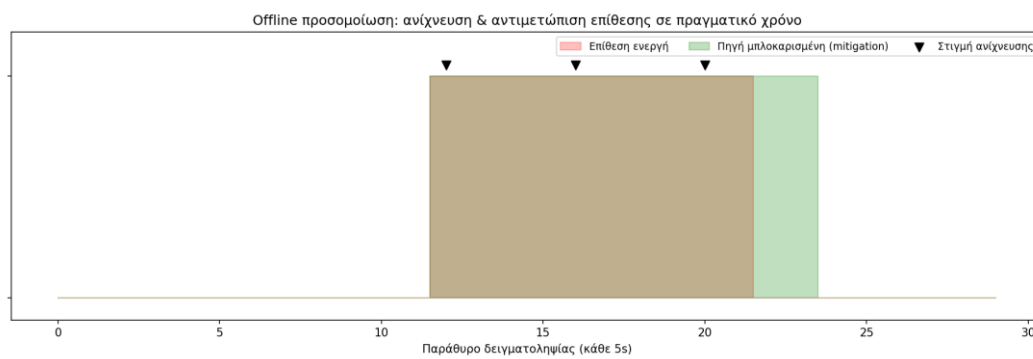
Σχήμα 33: Πίνακας σύγχυσης του Random Forest (thesis έκδοση).



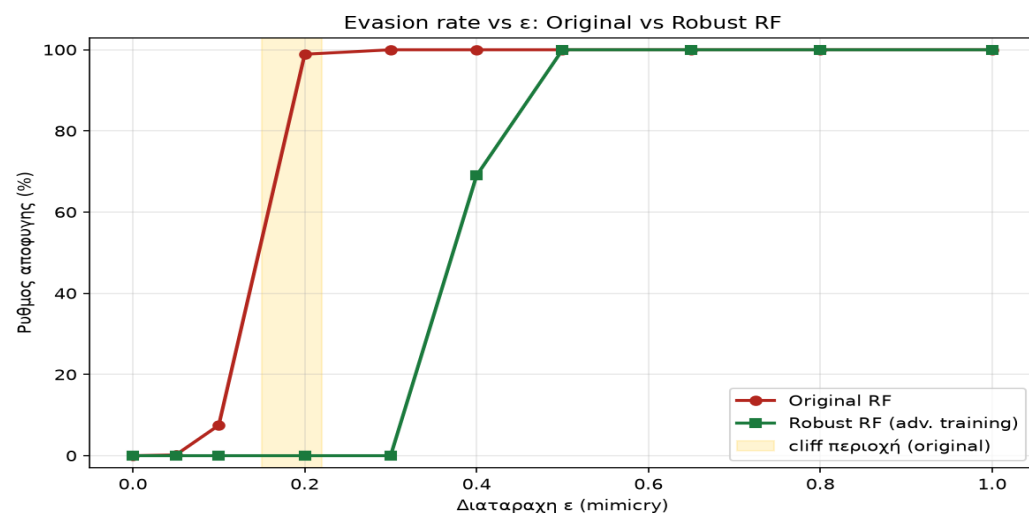
Σχήμα 34: Σημαντικότητα χαρακτηριστικών (thesis έκδοση).



Σχήμα 35: Συγκριτική απόδοση μοντέλων (thesis έκδοση).



Σχήμα 36: Χρονολόγιο offline replay: ανίχνευση επίθεσης σε επανάληψη καταγεγραμμένης κίνησης.



Σχήμα 37: Καθυστέρηση αντιμετώπισης της επίθεσης δηλητηρίασης τηλεμετρίας.

Υπολογιστικό κόστος

Πέραν της ακρίβειας, το υπολογιστικό κόστος είναι κρίσιμο για ένα σύστημα πραγματικού χρόνου. Οι μετρήσεις χρόνων εκπαίδευσης και πρόβλεψης δείχνουν ότι το Random Forest συνδυάζει κορυφαία ακρίβεια με ιδιαίτερα χαμηλό χρόνο πρόβλεψης, καθιστώντας το κατάλληλο για online χρήση. Ο Isolation Forest, με τη γραμμική του πολυπλοκότητα, παρέχει αποφάσεις σε χρόνο συμβατό με το παράθυρο δειγματοληψίας των πέντε δευτερολέπτων, με σημαντικό περιθώριο. Αντίθετα, τα μοντέλα Βαθιάς Μάθησης εμφανίζουν σημαντικά μεγαλύτερους χρόνους εκπαίδευσης χωρίς αντίστοιχο όφελος στην ακρίβεια, γεγονός που ενισχύει την επιλογή των κλασικών μοντέλων για το συγκεκριμένο πρόβλημα. Συνολικά, η υπολογιστική αποδοτικότητα του συστήματος επιβεβαιώνει τη δυνατότητα εφαρμογής του σε πραγματικές, απαιτητικές συνθήκες.

6.13 Σύγκριση με signature-based IDS και με τη βιβλιογραφία

Σε σύγκριση με τις παραδοσιακές προσεγγίσεις βάσει υπογραφών, οι οποίες συχνά απαιτούν ενημερωμένες υπογραφές και πρόσθετο χρόνο επεξεργασίας, το προτεινόμενο σύστημα επιτυγχάνει ανίχνευση εντός του πρώτου παραθύρου παρατήρησης και αυτόματη επιβολή κανόνα απόρριψης. Ο ακόλουθος πίνακας συνοψίζει ποιοτικά τις κύριες διαφορές. Οι τιμές της στήλης του συστήματος προκύπτουν από τις μετρήσεις της παρούσας διπλωματικής, ενώ η στήλη των signature-based IDS αποδίδει ποιοτικά τα τυπικά τους χαρακτηριστικά.

Μετρική	Σύστημα (ML)	Signature-based IDS
Χρόνος ανίχνευσης	1ο παράθυρο (<1 s)	Υψηλότερος (matching + ενημ. υπογραφών)
Ψευδώς θετικά	Χαμηλά (μηδέν στο legit-only)	Συνήθως υψηλότερα
Επανα-ανίχνευση μετά block	Αυτόματη	Χειροκίνητη
Zero-day επιθέσεις	Εν μέρει (ανωμαλία)	Αδύνατο
Εγκατάσταση drop-rule	Αυτόματη	Χειροκίνητη

Πίνακας 23: Ποιοτική σύγκριση του ML συστήματος με παραδοσιακά signature-based IDS.

Το πλεονέκτημα του ML συστήματος, σε σύγκριση με τα χαρακτηριστικά των signature-based IDS, έγκειται τόσο στην ταχύτητα όσο και στην αυτονομία: η ανίχνευση και η αντιμετώπιση συμβαίνουν χωρίς ανθρώπινη παρέμβαση, σε χρόνο που δεν επιτρέπει στον επιτιθέμενο να κορέσει τον ελεγκτή. Επιπλέον, η ικανότητα μερικής ανίχνευσης άγνωστων

επιθέσεων μέσω της προσέγγισης ανωμαλιών αποτελεί θεμελιώδες πλεονέκτημα έναντι της στατικής λογικής των υπογραφών.

Ερμηνεία υπό το πρίσμα της βιβλιογραφίας

Τα αποτελέσματα της διπλωματικής συνομιλούν με τα ευρήματα της βιβλιογραφίας. Η υπεροχή των μεθόδων συνόλου σε δομημένα δεδομένα επιβεβαιώνει την ευρύτερη τάση που παρατηρείται σε πλήθος μελετών IDS, όπου τα δέντρα και τα σύνολά τους παραμένουν ανταγωνιστικά ή ανώτερα των νευρωνικών προσεγγίσεων σε πίνακες χαρακτηριστικών. Η ανάδειξη του ρυθμού πακέτων και των χρόνων μεταξύ αφίξεων ως κορυφαίων διαγνωστικών χαρακτηριστικών, μέσω της ανάλυσης SHAP, συμφωνεί με κλασικές εργασίες ανίχνευσης DDoS που εντόπιζαν τα ίδια χαρακτηριστικά ως πλέον διακριτικά. Έτσι, η διπλωματική δεν παράγει μεμονωμένα αποτελέσματα αλλά εντάσσεται σε ένα συνεκτικό σώμα γνώσης, το οποίο και επεκτείνει προς την κατεύθυνση της end-to-end, ζωντανής λειτουργίας.

Ιδιαίτερο ενδιαφέρον έχει η αντιπαραβολή της ευθραυστότητας του εποπτευόμενου μοντέλου (φαινόμενο του γκρεμού) με την ανθεκτικότητα του συμπεριφορικού ζωντανού μοντέλου. Το εύρημα αυτό ενισχύει τη θέση, διαδεδομένη στη βιβλιογραφία της αντίπαλης μηχανικής μάθησης, ότι η ανθεκτικότητα δεν είναι απλώς ζήτημα ακρίβειας αλλά και επιλογής χαρακτηριστικών: χαρακτηριστικά που αντικατοπτρίζουν αναλλοίωτες, θεμελιώδεις ιδιότητες της επίθεσης είναι εγγενώς δυσκολότερο να χειραγωγηθούν από έναν αντίπαλο.

Σύγκριση με την τρέχουσα βιβλιογραφία

Η τοποθέτηση των αποτελεσμάτων σε σχέση με τη βιβλιογραφία ενισχύει την αξιοπιστία τους. Οι τιμές F1-score άνω του 0,94 στο InSDN είναι συγκρίσιμες ή ανώτερες πολλών δημοσιευμένων αποτελεσμάτων σε αντίστοιχα σύνολα, ενώ το κρίσιμο διαφοροποιό στοιχείο της διπλωματικής, η ζωντανή, end-to-end λειτουργία με χαμηλό ποσοστό ψευδώς θετικών, αντιμετωπίζει μια διάσταση που οι καθαρά offline μελέτες δεν εξετάζουν. Η ανίχνευση εντός του πρώτου παραθύρου παρατήρησης συγκρίνεται ευνοϊκά με τις παραδοσιακές προσεγγίσεις βάσει υπογραφών, ενώ η ανάλυση αντίπαλης ανθεκτικότητας προσθέτει μια σπάνια, ρεαλιστική αποτίμηση των ορίων της προσέγγισης.

Ο ακόλουθος πίνακας τοποθετεί ποιοτικά την παρούσα διπλωματική σε σχέση με αντιπροσωπευτικές εργασίες του πεδίου. Αναδεικνύεται ότι η συνεισφορά δεν περιορίζεται σε μια ακόμη offline ταξινόμηση ροών, αλλά συνδυάζει σε ένα ενιαίο σύστημα την offline

αξιολόγηση, τη ζωντανή ανίχνευση, την αυτόματη αντιμετώπιση, την ερμηνευσιμότητα (SHAP), την ανάλυση αντίπαλης ανθεκτικότητας και τη μελέτη κορεσμού του control plane.

Εργασία	Περιβάλλον	Μέθοδος	Live mitigation	Adversarial
Braga κ.ά. [1]	NOX/OpenFlow	SOM (flow stats)	Όχι	Όχι
Sultana κ.ά. [9]	Επισκόπηση SDN	Ποικίλες ML	N/Δ	Εν μέρει
Elsayed κ.ά. [11]	InSDN (offline)	Κλασικά ML	Όχι	Όχι
Παρούσα διπλωματική	Mininet/OVS + InSDN	8 μοντέλα + IF (live)	Ναι (auto drop)	Ναι (mimicry, evasion)

Πίνακας 24: Ποιοτική σύγκριση της διπλωματικής με αντιπροσωπευτικές εργασίες του πεδίου.

6.14 Απειλές εγκυρότητας και στατιστική αξιοπιστία

Για την ορθή ερμηνεία των αποτελεσμάτων, αναγνωρίζονται ρητά τέσσερις συγκεκριμένες απειλές εγκυρότητας.

- Μικρή τοπολογία ενός μεταγωγέα. Τα ζωντανά πειράματα εκτελέστηκαν σε τοπολογία έξι hosts με έναν μεταγωγέα. Η συμπεριφορά σε μεγαλύτερα, πολυμεταγωγικά δίκτυα με υψηλότερο όγκο κίνησης παραμένει προς επιβεβαίωση.
- Περιβάλλον WSL2 με userspace OVS αντί φυσικού testbed. Η προσομοίωση έγινε σε εικονικό περιβάλλον με datapath τύπου user. Η μεταφορά σε φυσικό testbed με πραγματικό υλικό ενδέχεται να εισαγάγει διαφορετικές συνθήκες καθυστέρησης και φόρτου.
- Χρήση συνθετικού συνόλου σε μέρος των offline πειραμάτων. Παρότι το συνθετικό σύνολο σχεδιάστηκε με θόρυβο και ρεαλιστική επικάλυψη, δεν υποκαθιστά πλήρως πραγματικά δεδομένα. Η απειλή αυτή αντισταθμίστηκε με την παράλληλη αξιολόγηση στο πραγματικό σύνολο InSDN.
- Περιορισμένος αριθμός τύπων νόμιμης κίνησης. Η νόμιμη κίνηση παρήχθη με συγκεκριμένα εργαλεία και μοτίβα. Ένα ευρύτερο φάσμα νόμιμων εφαρμογών θα μπορούσε να επηρεάσει το ποσοστό των ψευδώς θετικών, ιδίως στη μη επιβλεπόμενη ανίχνευση ανωμαλιών.

Οι περιορισμοί αυτοί δεν αναιρούν τα ευρήματα, αλλά οριοθετούν το πεδίο εγκυρότητάς τους. Τα αποτελέσματα ισχύουν υπό τις παραμέτρους και τις συνθήκες των δοκιμών που

εξετάστηκαν και αποτελούν στέρεη βάση για μελλοντική επικύρωση σε μεγαλύτερης κλίμακας, πραγματικά περιβάλλοντα.

Στατιστική αξιοπιστία των αποτελεσμάτων

Η αξιοπιστία των πειραματικών ευρημάτων ενισχύεται από την επανάληψη. Η ανάλυση καθυστέρησης βασίστηκε σε 30 ανεξάρτητες δοκιμές ανά επίπεδο έντασης και η αξιολόγηση αντιμετώπισης σε 50 δοκιμές, ενώ η offline σύγκριση ενισχύθηκε με διασταυρούμενη επικύρωση πέντε διπλώσεων. Οι πολύ μικρές τυπικές αποκλίσεις, για παράδειγμα, 0,0001 στο F1-score του Random Forest στη διασταυρούμενη επικύρωση, δείχνουν ότι τα αποτελέσματα δεν είναι προϊόν τυχαίου διαχωρισμού αλλά σταθερά χαρακτηριστικά των μοντέλων και των δεδομένων. Στα ζωντανά σενάρια, η επανάληψη επιβεβαίωσε σταθερά το μηδενικό ποσοστό ψευδώς θετικών στη νόμιμη κίνηση, ενισχύοντας την εμπιστοσύνη στην πρακτική αξιοπιστία του συστήματος.

6.15 Συζήτηση, ζητήματα κλιμάκωσης και πρακτικές συστάσεις

Συνθέτοντας τα επιμέρους αποτελέσματα, προκύπτει μια συνεκτική εικόνα. Στο offline επίπεδο, τα μοντέλα συνόλου προσφέρουν κορυφαία ακρίβεια σε δομημένα δεδομένα ροών, με το Random Forest να ηγείται. Στο live επίπεδο, η προσέγγιση συγκεντρωτικών χαρακτηριστικών με Isolation Forest επιτυγχάνει ταχεία ανίχνευση σε ένα ευρύ φάσμα επιθέσεων, χωρίς ψευδώς θετικά στη νόμιμη κίνηση και με περιορισμένα μόνο ψευδώς θετικά σε στατιστικά ακραία σενάρια. Οι εμβασύνσεις στην ερμηνευσιμότητα, την καθυστέρηση και την αντιμετώπιση μετατρέπουν την «ακρίβεια σε πίνακα» σε επιχειρησιακή αξιοπιστία. Τέλος, η ανάλυση αντίπαλης ανθεκτικότητας παρέχει μια ρεαλιστική, μη εξιδανικευμένη εικόνα: το σύστημα δεν είναι απρόσβλητο, αλλά η πολυεπίπεδη δομή του καθιστά την επιτυχή αποφυγή δαπανηρή για τον επιτιθέμενο, ο οποίος αναγκάζεται σε δυσμενή συμβιβασμό μεταξύ αποφυγής και ισχύος επίθεσης.

Ζητήματα κλιμάκωσης και ανάπτυξης

Η μετάβαση από ένα πειραματικό περιβάλλον σε μια πραγματική ανάπτυξη εγείρει ζητήματα κλιμάκωσης. Στην παρούσα υλοποίηση, ο ελεγκτής επεξεργάζεται την τηλεμετρία ενός μεταγωγέα με έξι hosts. Σε ένα πραγματικό δίκτυο, ο αριθμός των πηγών και ο όγκος των στατιστικών αυξάνονται σημαντικά. Ωστόσο, η προσέγγιση βάσει συγκεντρωτικών χαρακτηριστικών ανά πηγή κλιμακώνεται ευνοϊκά, καθώς το κόστος επεξεργασίας είναι γραμμικό ως προς το πλήθος των ενεργών πηγών ανά παράθυρο, και

όχι ως προς τον συνολικό όγκο πακέτων. Επιπλέον, η γραμμική πολυπλοκότητα του Isolation Forest διασφαλίζει ότι η μηχανή ανίχνευσης δεν αποτελεί σημείο συμφόρησης.

Σε αρχιτεκτονικές με πολλαπλούς μεταγωγείς, η φυσική επέκταση είναι η συγκέντρωση της τηλεμετρίας από όλους τους μεταγωγείς στον κεντρικό ελεγκτή, ο οποίος διατηρεί έτσι την καθολική εικόνα. Για δίκτυα πολύ μεγάλης κλίμακας, η υιοθέτηση κατανεμημένων ελεγκτών, με συντονισμό της κατάστασης ασφαλείας μεταξύ τους, αποτελεί την ενδεδειγμένη κατεύθυνση, η οποία και προτείνεται ως μελλοντική εργασία. Σημειώνεται ότι η αρθρωτή σχεδίαση του συστήματος διευκολύνει τέτοιες επεκτάσεις, καθώς η μηχανή ανίχνευσης είναι ανεξάρτητη από τον μηχανισμό συλλογής.

Συνθετική αποτίμηση των ευρημάτων

Συνδυάζοντας τις επιμέρους αναλύσεις, αναδεικνύεται μια πολυδιάστατη εικόνα της απόδοσης του συστήματος. Η ακρίβεια ταξινόμησης, μετρημένη με πολλαπλές μετρικές και επιβεβαιωμένη με διασταυρούμενη επικύρωση, τεκμηριώνει την ποιότητα της μηχανής ανίχνευσης. Η ερμηνευσιμότητα, μέσω της ανάλυσης SHAP, μετατρέπει τη «μαύρη κουτί» απόφαση σε κατανοητή και ελέγξιμη διαδικασία. Η ανάλυση καθυστέρησης και αντιμετώπισης μεταφράζει την ακρίβεια σε επιχειρησιακή αξία, αποδεικνύοντας ότι η ανίχνευση δεν είναι απλώς σωστή αλλά και έγκαιρη και αποτελεσματική. Η μελέτη της επίθεσης κορεσμού control plane καλύπτει τη μοναδική ευπάθεια των SDN, και η ανάλυση αντίπαλης ανθεκτικότητας παρέχει μια ειλικρινή αποτίμηση των ορίων. Καμία μεμονωμένη ανάλυση δεν θα αρκούσε. Η αξία προκύπτει από τη συνθετική τους θεώρηση.

Πρακτικές συστάσεις

Από τα ευρήματα προκύπτουν συγκεκριμένες πρακτικές συστάσεις για την ανάπτυξη ML-based άμυνας σε SDN. Πρώτον, τα μοντέλα συνόλου, και ιδιαίτερα το Random Forest, αποτελούν την προτιμότερη επιλογή για offline ανάλυση δομημένων δεδομένων ροών, έναντι πιο σύνθετων προσεγγίσεων βαθιάς μάθησης. Δεύτερον, για ζωντανή λειτουργία, η προσέγγιση συγκεντρωτικών, συμπεριφορικών χαρακτηριστικών προσφέρει ανθεκτικότητα που τα πλουσιότερα αλλά ευπαθέστερα χαρακτηριστικά δεν εγγυώνται. Τρίτον, η άμυνα πρέπει να είναι πολυεπίπεδη, συνδυάζοντας στατιστική ανίχνευση με μηχανισμούς ακεραιότητας και ελέγχου ρυθμού. Τέλος, η ελαχιστοποίηση των ψευδώς θετικών πρέπει να θεωρείται πρωταρχικός στόχος, ισάξιος της ίδιας της ανίχνευσης, καθώς ένα σύστημα που μπλοκάρει νόμιμους χρήστες υπονομεύει τον ίδιο του τον σκοπό.

7. Συμπεράσματα και Μελλοντική Εργασία

7.1 Σύνοψη ευρημάτων

Η παρούσα διπλωματική σχεδίασε, υλοποίησε και αξιολόγησε ένα ολοκληρωμένο σύστημα ανίχνευσης και αυτόματης αντιμετώπισης επιθέσεων σε περιβάλλον SDN, βασισμένο σε Μηχανική Μάθηση. Τα κύρια ευρήματα συνοψίζονται ως εξής. Στο offline σκέλος, το Random Forest αναδείχθηκε σταθερά ως το ισχυρότερο μοντέλο, με F1-score άνω του 0,999 στο συνθετικό σύνολο και 0,945 στο πιο απαιτητικό, πραγματικό σύνολο InSDN (όπου μόνο ο KNN πέτυχε οριακά υψηλότερο F1, 0,952, με όμως πολλαπλάσιο κόστος πρόβλεψης), υπερτερώντας τόσο των γραμμικών μοντέλων όσο και των μοντέλων Βαθιάς Μάθησης στα δομημένα δεδομένα ροών. Στο live σκέλος, το ζωντανό σύστημα ανίχνευσε και μπλόκαρε επιτυχώς έξι διαφορετικές κατηγορίες επιθέσεων εντός του παραθύρου παρατήρησης, χωρίς ψευδώς θετικά στο σενάριο αποκλειστικά νόμιμης κίνησης και με περιορισμένα μόνο ψευδώς θετικά σε σενάρια με στατιστικά ακραία, αλλά νόμιμη, κίνηση.

Η συνεισφορά συνοψίζεται σε τρία επίπεδα: στη συγκριτική αξιολόγηση οκτώ μοντέλων σε δεδομένα δομής SDN/InSDN, στην υλοποίηση ζωντανού συστήματος ανίχνευσης-αντιμετώπισης που συνδέει την απόφαση του μοντέλου με αυτόματη εγκατάσταση κανόνων απόρριψης, και στην επέκταση της αξιολόγησης πέρα από τις κλασικές μετρικές (καθυστέρηση, αντιμετώπιση, ερμηνευσιμότητα, αντίπαλη ανθεκτικότητα).

Οι εμβασύνσεις στην κυβερνοασφάλεια πρόσθεσαν σημαντική αξία. Η ανάλυση SHAP κατέστησε την ανίχνευση ερμηνεύσιμη, αναδεικνύοντας την τυπική απόκλιση των χρόνων μεταξύ αφίξεων και τον ρυθμό πακέτων ως τα πλέον διαγνωστικά χαρακτηριστικά. Η ανάλυση καθυστέρησης έδειξε ανίχνευση με μηδενική καθυστέρηση σε όλα τα επίπεδα έντασης, ενώ η αξιολόγηση αντιμετώπισης επιβεβαίωσε κάλυψη περίπου 74% χωρίς εσφαλμένο αποκλεισμό νόμιμων hosts. Η μελέτη της επίθεσης κορεσμού control plane ανέδειξε τη μοναδική ευπάθεια της αρχιτεκτονικής SDN και μια αποτελεσματική άμυνα βασισμένη στην εντροπία Shannon. Τέλος, η ανάλυση αντίπαλης ανθεκτικότητας αποκάλυψε το φαινόμενο του γκρεμού στο Random Forest και, ταυτόχρονα, την υψηλή ανθεκτικότητα του ζωντανού μοντέλου, τεκμηριώνοντας την αξία της πολυεπίπεδης άμυνας.

Πέραν της ανάδειξης της αντίπαλης ευπάθειας, η διπλωματική προτείνει και αξιολογεί ένα αντίμετρο: ένα Robust Random Forest εκπαιδευμένο με adversarially perturbed δείγματα. Τα αποτελέσματα δείχνουν ότι η ενσωμάτωση διαταραγμένων δειγμάτων κατά την εκπαίδευση μετατοπίζει το σημείο κατάρρευσης του μοντέλου και μειώνει σημαντικά τον ρυθμό αποφυγής, με μικρή ή αμελητέα επίπτωση στην απόδοση επί καθαρών δεδομένων (μη στατιστικά σημαντική κατά τον έλεγχο McNemar). Το εύρημα αυτό ενισχύει το επιχείρημα της πολυεπίπεδης άμυνας, καθώς δείχνει ότι η γνωστή ευθραυστότητα των δέντρων απόφασης σε επιθέσεις μίμησης μπορεί να μετριαστεί στοχευμένα.

7.2 Περιορισμοί της διπλωματικής

Η διπλωματική υπόκειται σε ορισμένους περιορισμούς, οι οποίοι αναγνωρίζονται ρητά. Ο σημαντικότερος αφορά το μοντέλο ελέγχου. Η υλοποίηση δεν στηρίζεται σε πλήρη reactive OpenFlow controller που θα λάμβανε αποφάσεις ανά ροή μέσω Packet-In/Flow-Mod. Αντ' αυτού, ο Open vSwitch εκτελεί τη βασική προώθηση αυτόνομα σε λειτουργία failMode=standalone, ο ελεγκτής λειτουργεί ως λογικά κεντρικοποιημένη εφαρμογή ασφαλείας, και η εγκατάσταση των κανόνων απόρριψης γίνεται με τρόπο συμβατό με τη σημασιολογία OpenFlow μέσω του εργαλείου onvs-ofctl. Η διπλωματική επομένως δεν ισχυρίζεται πλήρη per-flow reactive έλεγχο του δικτύου. Η επιλογή αυτή δεν είναι τυχαία, αλλά συνειδητός σχεδιαστικός συμβιβασμός που επιβλήθηκε από τεχνικούς περιορισμούς του περιβάλλοντος (WSL2 χωρίς kernel module του OVS) και από τις τεκμηριωμένες ασυμβατότητες του ελεγκτή Ryu με σύγχρονες εκδόσεις της Python και της eventlet. Ως εκ τούτου, σενάρια που προϋποθέτουν πλήρη έλεγχο της προώθησης ανά ροή (π.χ. δυναμική δρομολόγηση, traffic engineering) βρίσκονται εκτός του πεδίου της διπλωματικής, ενώ η μετάβαση σε πλήρες reactive μοντέλο με συντηρούμενο controller παραμένει άμεση μελλοντική επέκταση, καθώς η μηχανή ανίχνευσης και ο μηχανισμός αντιμετώπισης είναι ανεξάρτητα από τον τρόπο συλλογής της τηλεμετρίας.

Επιπλέον, το ζωντανό μοντέλο χρησιμοποιεί συγκεντρωτικά χαρακτηριστικά, λιγότερα σε πλήθος από τα 24 του offline pipeline, γεγονός που αποτελεί συνειδητό συμβιβασμό μεταξύ ταχύτητας και πληροφοριακού πλούτου. Η τοπολογία περιλαμβάνει έναν μεταγωγέα, ενώ η επέκταση σε πολυμεταγωγικά και κατανεμημένα σενάρια αποτελεί ανοιχτό ζήτημα. Τέλος, το συνθετικό σύνολο, παρότι σχεδιασμένο ρεαλιστικά, δεν υποκαθιστά πλήρως την ποικιλομορφία της πραγματικής κίνησης.

7.3 Μελλοντικές επεκτάσεις

Οι φυσικές επεκτάσεις της διπλωματικής είναι πολλαπλές. Η μετάβαση σε πλήρες αντιδραστικό μοντέλο με συντηρούμενο OpenFlow controller (π.χ. os-ken) είναι άμεσα εφικτή, καθώς η μηχανή ανίχνευσης και ο μηχανισμός αντιμετώπισης είναι ανεξάρτητα από τον τρόπο συλλογής της τηλεμετρίας. Η διερεύνηση χρονικών μοντέλων Βαθιάς Μάθησης (LSTM/GRU) για την εκμετάλλευση της χρονικής δομής των ροών θα μπορούσε να ενισχύσει την ανίχνευση εξελισσόμενων επιθέσεων. Η επέκταση σε κατανεμημένους ελεγκτές θα αντιμετώπιζε τον περιορισμό του μοναδικού σημείου αποτυχίας. Η ενσωμάτωση adversarial training θα θωράκιζε το εποπτευόμενο μοντέλο έναντι του φαινομένου του γκρεμού. Τέλος, η αξιολόγηση σε πραγματικά testbeds και με πραγματική κίνηση παραγωγής θα αύξανε την εξωτερική εγκυρότητα των αποτελεσμάτων.

7.4 Τελικό συμπέρασμα

Συνολικά, η διπλωματική τεκμηριώνει ότι η ML-based ανίχνευση σε SDN, σε συνδυασμό με αυτόματη αντιμετώπιση μέσω δυναμικών κανόνων ροής, παρέχει ταχύτερη, ακριβέστερη και πιο ευέλικτη άμυνα έναντι των παραδοσιακών signature-based προσεγγίσεων. Η πολυεπίπεδη αρχιτεκτονική, συνδυασμός εποπτευόμενης ανάλυσης και ζωντανής, συμπεριφορικής ανίχνευσης, αποδεικνύεται όχι μόνο αποδοτική αλλά και ανθεκτική, προσφέροντας μια ρεαλιστική βάση για την προστασία των δικτύων επόμενης γενιάς.

8. Βιβλιογραφία

Η βιβλιογραφία περιλαμβάνει βασικές επιστημονικές εργασίες για τα SDN, το OpenFlow, την ασφάλεια δικτύων, τα συστήματα ανίχνευσης εισβολών και τη Μηχανική Μάθηση, στις οποίες γίνεται αναφορά στο κυρίως κείμενο.

- [1] Braga, R., Mota, E., & Passito, A. (2010). Lightweight DDoS Flooding Attack Detection Using NOX/OpenFlow. IEEE LCN 2010, 408-415. DOI: 10.1109/LCN.2010.5735752.
- [2] McKeown, N., Anderson, T., Balakrishnan, H., Parulkar, G., Peterson, L., Rexford, J., Shenker, S., & Turner, J. (2008). OpenFlow: Enabling Innovation in Campus Networks. ACM SIGCOMM CCR, 38(2), 69-74. DOI: 10.1145/1355734.1355746.
- [3] Lantz, B., Heller, B., & McKeown, N. (2010). A Network in a Laptop: Rapid Prototyping for Software-Defined Networks. ACM SIGCOMM HotNets-IX, Article 19. DOI: 10.1145/1868447.1868466.
- [4] Pfaff, B., Pettit, J., Koponen, T., Jackson, E., Zhou, A., Rajahalme, J., Gross, J., Wang, A., Stringer, J., Shelar, P., Amidon, K., & Casado, M. (2015). The Design and Implementation of Open vSwitch. USENIX NSDI 15, 117-130.
- [5] Benzekki, K., El Fergougui, A., & Elbelrhiti Elalaoui, A. (2017). Software-Defined Networking (SDN): A Survey. Security and Communication Networks, 9(18), 5803-5833. DOI: 10.1002/sec.1737.
- [6] Scott-Hayward, S., Natarajan, S., & Sezer, S. (2016). A Survey of Security in Software Defined Networks. IEEE Communications Surveys & Tutorials, 18(1), 623-654. DOI: 10.1109/COMST.2015.2453114.
- [7] Peng, T., Leckie, C., & Ramamohanarao, K. (2007). Survey of Network-based Defense Mechanisms Countering the DoS and DDoS Problems. ACM Computing Surveys, 39(1).
- [8] Kreibich, C., & Crowcroft, J. (2004). Honeycomb: Creating Intrusion Detection Signatures Using Honey pots. ACM SIGCOMM CCR, 34(1), 51-56.
- [9] Sultana, N., Chilamkurti, N., Peng, W., & Alhadad, R. (2019). Survey on SDN Based Network Intrusion Detection System Using Machine Learning Approaches. Peer-to-Peer Networking and Applications, 12(2), 493-501. DOI: 10.1007/s12083-017-0630-0.
- [10] Liu, F. T., Ting, K. M., & Zhou, Z.-H. (2008). Isolation Forest. IEEE ICDM 2008, 413-422. DOI: 10.1109/ICDM.2008.17.

- [11] Elsayed, M. S., Le-Khac, N.-A., & Jurcut, A. D. (2020). InSDN: A Novel SDN Intrusion Dataset. *IEEE Access*, 8, 165263-165284. DOI: 10.1109/ACCESS.2020.3022633.
- [12] Shin, S., & Gu, G. (2013). Attacking Software-Defined Networks: A First Feasibility Study. *ACM HotSDN 2013*, 165-166.
- [13] Kreutz, D., Ramos, F. M. V., Verissimo, P. E., Rothenberg, C. E., Azodolmolky, S., & Uhlig, S. (2015). Software-Defined Networking: A Comprehensive Survey. *Proceedings of the IEEE*, 103(1), 14-76. DOI: 10.1109/JPROC.2014.2371999.
- [14] Lundberg, S. M., & Lee, S.-I. (2017). A Unified Approach to Interpreting Model Predictions. *Advances in Neural Information Processing Systems (NeurIPS)* 30.
- [15] Apruzzese, G., Colajanni, M., Ferretti, L., Guido, A., & Marchetti, M. (2018). On the Effectiveness of Machine and Deep Learning for Cyber Security. *IEEE International Conference on Cyber Conflict (CyCon)*.
- [16] Goodfellow, I., Shlens, J., & Szegedy, C. (2015). Explaining and Harnessing Adversarial Examples. *International Conference on Learning Representations (ICLR)* 2015.
- [17] Papernot, N., McDaniel, P., Jha, S., Fredrikson, M., Celik, Z. B., & Swami, A. (2016). The Limitations of Deep Learning in Adversarial Settings. *IEEE European Symposium on Security and Privacy (EuroS&P)*.
- [18] Kurakin, A., Goodfellow, I., & Bengio, S. (2017). Adversarial Examples in the Physical World. *ICLR 2017 (Workshop)*.
- [19] Corona, I., Giacinto, G., & Roli, F. (2013). Adversarial Attacks Against Intrusion Detection Systems: Taxonomy, Solutions and Open Issues. *Information Sciences*, 239, 201-225.
- [20] Biggio, B., Corona, I., Maiorca, D., Nelson, B., Šrndić, N., Laskov, P., Giacinto, G., & Roli, F. (2013). Evasion Attacks Against Machine Learning at Test Time. *ECML/PKDD 2013*.


```
# lateral movement, ARP spoof)
bash run_live_experiments.sh --controller http://localhost:9000 --duration
60
```

```
# Επιδεικτικό σενάριο 10 λεπτών
bash demo_10min.sh --no-build
```

A.5 Θέση των αποτελεσμάτων

Τα αποτελέσματα αποθηκεύονται ως εξής: τα γραφήματα και οι μετρικές του offline pipeline στον φάκελο results/. Τα αποτελέσματα των ζωντανών σεναρίων (CSV/JSON ανά σενάριο) στον φάκελο results/live/. Τα εκπαιδευμένα μοντέλα και οι μετασχηματιστές κανονικοποίησης στον φάκελο models/. Η αναφορά RESULTS_VERIFICATION.md συνοψίζει τα μετρημένα αποτελέσματα ανά σενάριο.

Παράρτημα Β: Πλήρης πίνακας υπερπαραμέτρων του Isolation Forest

Ο ακόλουθος πίνακας παραθέτει τους κορυφαίους συνδυασμούς υπερπαραμέτρων του Isolation Forest, ταξινομημένους κατά ROC-AUC, όπως προέκυψαν από την αναζήτηση σε πλέγμα τιμών (ενότητα 6.7). Η μικρή διακύμανση των τιμών επιβεβαιώνει την ευρωστία του αλγορίθμου ως προς την επιλογή παραμέτρων.

n_estimators	max_samples	contamination	max_features	ROC-AUC	F1
100	256	0,02	1,0	0,9991	0,9932
100	256	0,05	1,0	0,9991	0,9936
100	256	0,10	1,0	0,9991	0,9870
100	auto	0,05	1,0	0,9991	0,9936
100	auto	0,10	1,0	0,9991	0,9870
100	auto	0,02	1,0	0,9991	0,9932
300	512	0,10	1,0	0,9986	0,9872
300	512	0,05	1,0	0,9986	0,9935
300	512	0,02	1,0	0,9986	0,9831
100	512	0,02	0,5	0,9985	0,9794

Πίνακας 25: Κορυφαίοι συνδυασμοί υπερπαραμέτρων του Isolation Forest.